REPORT · 23 OCTOBER 2026

ApexMail

Business Model & Tech Plan

The plan, the deep review of every important crate, the work packages, tests and verification ledger, and the audits of 15, 16 and 22 October.

Checked at	commit 61e3db3, head of main
Source	Claude Doc “ApexMail — Business Model & Tech Plan”
Length	213 pages after this cover and contents

Contents

Audit · 22 October 2026 1
Latest audit at commit 61e3db3

Deep review · 22 October 2026 14
Method, crate scorecard, findings by severity

- Money 20
- Mail delivery 24
- API and console 34
- Data protection 40
- Security 46
- Sales and AI 53
- Platform and operations 58
- Dependencies 64
- Website and claims 69

Plan 74
Business model and technical plan

Sales engine 89
Autonomous loop, scoring, sequences, experiments

Work packages 110
112 work packages in eleven groups

Tests & enforcement 173
Invariants, tests and CI gates

Verification ledger 184
Every claim with its source

Audit · 16 October 2026 197
Earlier audit

Audit · 15 October 2026 207
Earlier audit

Numbers here count from the page after this one; the footer on each page counts within its section.

Audit — 22 October 2026

Oct 22, 2026 · @Aaron

Checked at `61e3db3`, the head of `main` on 22 Oct. The three launch blockers from 15 Oct are fixed in code: customers can cancel, the legal pages name Adyen correctly, and production config can run a checkout. But the CAPTCHA-solver hook is still in the sales engine, nothing yet lets the engine sell without you, and the tests are strong in volume but weak in kind. Most of the 18 new commits went to performance, wiring claimed features and live UX sweeps rather than the open work packages. Production was not reachable from here, so nothing is verified live.

Deep review: the full read

A second pass read every important crate end to end, with its configuration and deployment. It found 64 findings (13 High, 23 Medium, 27 Low, 1 to verify), scored 25 crate groups, and added work packages V1–V27 to Work packages. Details and evidence: Deep review · 22 Oct, with pages for Money, Mail delivery, API and console, Data protection, Security, Sales and AI, Platform and operations, Dependencies and Website and claims.

The ones that matter most:

- **Live payments would fail.** The live Adyen URL lacks the merchant prefix everywhere, and the gate requires the wrong value; renewals omit `shopperInteraction: ContAuth` (MON-1, MON-2; V1).
- **The config says Germany.** `HETZNER_DEFAULT_LOCATION` defaults to `fsn1`, so dedicated IPs would be created in Falkenstein, and the generated subprocessor register publishes Germany (DP-4; V24).
- **Backups never leave the host**, and there is no WAL archiving (OPS-1; V6). When the host fails, the status page, monitors and alerts fail with it, and no alert channel is configured (OPS-2; V11).
- **Prospects' data is outside access and erasure requests**, so the sales engine's own data subjects cannot get a copy or deletion (DP-1; V23).
- **Every received message is also stored in plaintext, forever**, in `inbound_messages`, beside the encrypted mailbox copy (DEL-9; V19).
- **SAML SSO rejects every standard IdP signature** although Business and Enterprise include it (SEC-1, WEB-4; V5).
- **The privacy policy does not describe how prospects' data is collected** or the unconditional right to object to direct marketing (WEB-5; V27).
- **The home page claims DANE and MTA-STS**; neither is enforced (WEB-2; V26).

Verdicts

Question	16 Oct	22 Oct
Is it a good business model?	Stronger, unproven	Unchanged. The sovereign offer has working code behind it; there is still no evidence of paying customers
Is it close to launching?	Closer on product, not on revenue	Close for paid self-serve. What remains: your Adyen live account, one wrong FAQ line, three public claims that are wrong or early (hosting is Finland-only), the 99.9% SLA on one host, and confirming which commit is deployed
Can the sales engine sell by itself?	Not assessed	No. It still needs a human for every outbound send (no country legal rows, no approved sequences, outbound autonomy gates missing), and it learns from a biased signal. S1–S10 have not started; S11–S24 below make it autonomous
Are the tests enough?	Not assessed	Plenty of tests (about 13,400 in Rust alone), but the coverage gate is advisory, there are almost no property tests, the two fuzz targets never run, nothing measures assertion strength, and the live sweeps that found this week's bugs are not in CI. T1–T17 fix this
Plan progress	8 of 32 non-sales packages done	Groups A–H: 7 done, 14 in progress, 3 waiting on you, 8 not started. S1–S24 and T1–T17: not started

What changed

Eighteen commits landed between `f9221fc` (16 Oct) and `61e3db3` (22 Oct, 14:00), about 53,000 lines added. `main` is the only branch apart from Dependabot updates.

Date	Change	Commits	Plan effect
17 Oct	Cancellation as a local state change, console cancel form, renewal sweep skips cancelled plans; Adyen facts fixed on all legal pages with a new gate (`tools/check_processor_facts.py`); Adyen settings wired to api-server with a new gate (`tools/check_prod_billing_wiring.py`)	`98a60a5`	H1 done; H2 one sentence short; H3 done in code
17–19 Oct	Performance campaign: N+1 and O(n²) paths removed, 26 hot-path indexes added, 20 redundant indexes and 17 dead tables dropped (migrations 262, 263, 266, 268)	`1236957`, `0f8c524`, `f6b614b`	None directly; real quality gain
17–18 Oct	Claimed-but-unwired features made live: mail journaling (migration 264), white-label, provider throttling at both send boundaries, SES deliverability monitor	`d1570e4`, `f6b614b`	E5 mostly done; B2 partly
19–20 Oct	Hermetic CI image fixed for Apple Silicon; cargo-vet installed; Kiwi pipeline definition added (`.kiwi/pipeline.yaml`)	`9a2a94a`, `4735d12`, `4415ed0`	A1 tooling
22 Oct	Live journey sweeps across 15 user types: WAF blocked real browsers on their second page, health probes were rate-limited, login lockout from the dev captcha, two dead forms	`21b0652`, `a2f3b08`, `576355d`	None; real bugs fixed
22 Oct	GitHub branch protection retired as unsatisfiable on a one-person repo	`61e3db3`	Enforcement now rests entirely on the gate blessing (see Other findings)

The sales engine changed only for performance (batched policy, consent and reward writes). None of S1–S10 started, and the CAPTCHA-solver hook is still there.

CAPTCHA bypassing: remove it

The solver hook from 15 Oct (`986d053`, migration 258) is still in the code at `61e3db3`. It lets an operator send a CAPTCHA-blocked page to an outside solving service and retry. It is now a required removal (WP S10), and a new gate keeps it from coming back.

Footprint to remove

Where	What	Lines matching "solver"
`crates/sales-autopilot/src/discovery/blocked.rs`	`SolverConfig`, `attempt_solve`, the opt-in and audit logic, its module docs	162
`crates/sales-autopilot/src/routes.rs`	`POST /discovery/hosts/:host/solver-optin` (line 199) and the solve-attempt handler (lines 1104–1140)	28
`crates/sales-autopilot/src/discovery/fetch.rs`	References to the hook	12
`crates/sales-autopilot/src/schema.rs`	Solver table names	3
`crates/sales-autopilot/tests/scrape_challenges.rs`	Solver tests (replace with "a CAPTCHA permanently excludes the host" tests; never delete tests without replacing them)	77
`migrations/258_scrape_challenge_readiness.sql`	Columns `solver_enabled`, `solver_enabled_at`, `solver_enabled_by`; table `sales_scrape_solver_audit`	11
`docs/architecture/sales-autopilot.md`	Description of the hook	4

Migration 258 is applied, so it must not be edited. A new forward migration (the next free number, 269 at 61e3db3) drops the three columns and the audit table, after exporting any rows to the audit archive.

What stays. CAPTCHA and challenge detection stays: it is what tells the engine to stop. The new rule is that a detected CAPTCHA, a robots.txt refusal or a terms-of-use prohibition marks the host excluded permanently, and no code path retries it.

Keeping it out. `tools/check_no_bypass.py`, a required validate-stage gate with a self-test, fails on solver and proxy-rotation vocabulary (`SCRAPE_CAPTCHA_SOLVER`, `solver_enabled`, `sales_scrape_solver`, `2captcha`, `anti-captcha`, `capsolver`, `capmonster`, `rotating proxy`, `residential proxy`) in `crates/sales-autopilot`, env examples, compose files and new migrations. `docs/audit/` and applied migrations are exempt. An integration test serves a CAPTCHA from a fixture site and asserts that the host is excluded and receives no further request. The existing `tools/check-forbidden-patterns.sh` cannot do this job: it scans the built marketing site, not the source.

Also out of bounds: rotating or residential proxies after a block, stealth browsers that hide automation, pages behind a login, sources whose terms forbid collection (LinkedIn among them), and bought lists without a consent or notice trail. Sales lose little: operator-listed pages were the thinnest source, and the sources in S11, S13 and S14 are larger, lawful in every target country, and carry buying intent.

Work package check

Each package was tested against its "Done when" criteria at `61e3db3`. Three earlier verdicts were too generous and are corrected here (marked "Corrected").

WP	Status	Change since 16 Oct and gap left
H1	Done	Cancellation works (`billing-service/src/subscriptions.rs` , `POST /web/billing/cancel`), and the renewal sweep skips cancelled plans. The stale FAQ sentence is tracked under H2
H2	In progress	All legal pages fixed; `tools/check_processor_facts.py` gates 18 surfaces. Left: the pricing FAQ still promises an "Adyen billing portal" (`partials/generated/pricing-faq-island.html:31`) because `tools/validate_pricing_drift.py:880` requires that phrase
H3	Waiting on you	api-server gets all Adyen settings; `tools/check_prod_billing_wiring.py` gates it. Left: Adyen live account and a staging run of buy, renew, refund, cancel
A1	In progress	Gates run in the hermetic image on the CI machine. Left: images still built on the production host; no registry
A2	Done	Unchanged
A3	Not started	99.9% SLA still in 8 site files, on one host
A4	In progress	Generator and `--check` in validate. Left: no scheduled export; the committed metrics file is from 15 Oct; no staleness limit
A5, A6	Not started	—

WP	Status	Change since 16 Oct and gap left
B1	In progress	`AWS_REGION` now defaults to `eu-west-1` (fixed). Left: subaccount and domain scope
B2	In progress	Provider throttling at relay and SES boundaries (`f6b614b`). Left: outbound MTA-STS/DANE, placement parity evidence
B3	Done	Unchanged
B4, B6	In progress	Unchanged
B5, C4	Not started	—
C1	Done	Unchanged
C2, C3	Waiting on you	Tax rates file empty; US DPA addendum unapproved
D1	In progress (corrected)	No test runs the official SendGrid, Postmark, Resend or Mailgun SDKs against the compat endpoints, which was the done-when criterion. The existing tests check the mapping only
D2	In progress (corrected)	Importer done; the shadow-send verifier does not exist
D3	In progress	No registry publication step
D4, E1	Done	Unchanged
E2, E3, E4	In progress	Unchanged
E5	In progress	Journaling built: migration 264, inbound and outbound copies, `/v1/journal` retrieval, console page (`d1570e4`). Left: retention defaults to forever and `mail_journal` is missing from the erasure map (T11)
E6, G1	Not started	BYOC still in 32 marketing files
G2	Not started (corrected)	`isolation` runs as its own production service (`docker-compose.prod.yml:1092`), so only `pattern-matcher` is unused in production
G3	Done	Unchanged
S1–S10	Not started	Bandit posterior unchanged (`experiments.rs:407-437`), no holdout, no propensities, solver hook still present

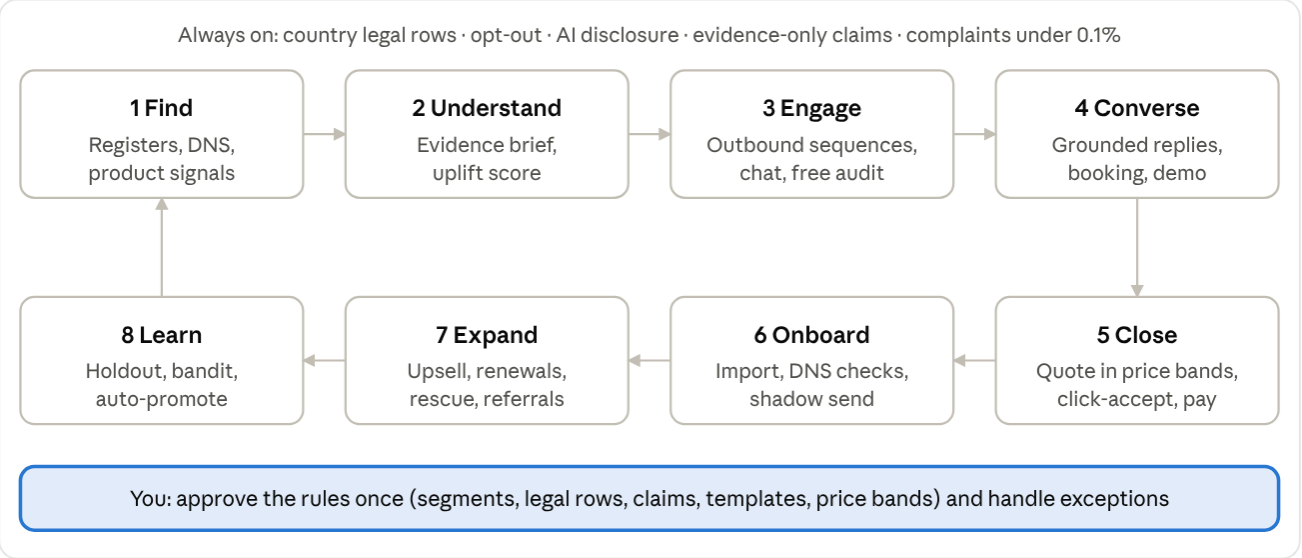
WP	Status	Change since 16 Oct and gap left
S11–S24, T1–T17	Not started	New on 22 Oct: selling without the owner, and tests that bind

Autonomous selling

Today the engine finds, scores and drafts, but you approve every outbound send, every sequence and every legal basis. A buyer also cannot finish a deal without you: price, DPA and security questions all route to you, a thread cannot carry a quote or payment link, and there is no self-serve order form. To sell by itself it needs three changes:

1. You approve **rules once**, not messages one by one.
2. Every stage, from first touch to renewal, has a path with no human in it.
3. The engine promotes what works and demotes what fails by itself, inside hard limits.

The machine runs every stage; you approve the rules once



autonomous selling loop · 8 stages, owner sets rules once

Read it clockwise from Find. The loop runs continuously; you appear only at the bottom.

Stage	Runs without you once built	Work packages	Your part
Find	Domains from the public domain check, product signups, Certificate Transparency, Tranco and open business registers; triggers from competitor status pages and job-board APIs	S11, S12, S13, F5	None
Understand	Sending stack, provider and DMARC posture read for every account, with precision measured on labelled domains	S8, S13, F3	None
Engage	First touches only inside an approved policy pack and where the country's legal row allows; consent only in Germany; Article 14 notice on first contact	S14, S21, F1, F7	Approve each pack version once
Converse	First reply within 5 minutes; canonical price and legal answers; questionnaires from the evidence bank; sandbox demos and booking; AI disclosure on every machine-written message	S9, S15, S16, S18, S19, F9	Questions with no approved answer
Close	Payment links, order forms and the standard DPA inside your price bands; Adyen payment or SEPA invoice	S17, F10	Out-of-band prices and redlines
Onboard	DNS, import, shadow send and cut-over tracked per tenant; stalls nudged automatically	S22, D2, D4	Second stalls only
Expand	Usage-triggered add-ons, renewals, churn rescue, referrals and partners	S12, S23, S24	Approve partners and monthly payouts

Stage	Runs without you once built	Work packages	Your part
Learn	Correct posteriors, holdout and off-policy checks; a class promotes itself after a 48-hour veto window and demotes on any breach; one daily exception digest	S1–S7, S20, T15, T17	Read the digest; veto if you want

Two legal points shape the design.

- **AI disclosure.** The EU AI Act's transparency duty to tell people they are dealing with an AI system has applied since 2 August 2026; the 2026 Digital Omnibus did not delay it. The site chat already discloses (`ai-service/src/chat.rs:44`). The mailbot and the auto-send path (`reply_autosend.rs`) do not. Any email written and sent by AI without human review should say so; have counsel confirm the wording.
- **No bypassing refusals.** "Aggressive" means faster, wider and more persistent within the rules: 5-minute replies, signal triggers, more sending identities while complaints stay low, persistent follow-up on open quotes with their real expiry dates. It never means bypassing a CAPTCHA, a country's consent rule or an opt-out.

Tests and expectations

Every ApexMail package was scanned: 55 Rust crates, six SDKs, smtp-auth-proxy, the AI training scripts, 70 tools and the CI scripts. KiwiCaptcha is a separate project with its own repository and tests, so it is left out. The repo tests widely and enforces softly: 13,403 Rust tests, about 400 SDK tests, and required SDK and dogfood lanes. The checks that would catch weak or missing tests do not bind:

- Coverage is advisory (`ci/pipeline.conf:73`), passes silently when `cargo-llvm-cov` is missing (`ci/stages/test.sh:364`), and is one workspace number (`ci/coverage-baseline.txt`), so a crate can decay behind the average.
- Mutation testing is manual (`services/mail-server/mutants.toml`). The dogfood harness's live battery and seeded mutations never run in CI (`CI_DOGFOOD_LIVE=0`).
- The workspace has 8 property-test uses, all inside `fuzz-tests`. Money, routing, receipts and rate limits have none.
- Two cargo-fuzz targets exist and nothing runs them. The SMTP, MIME, DKIM/SPF/DMARC, webhook and import parsers have no target.
- The live journey sweeps that found this week's WAF, rate-limit and dead-form bugs (`a2f3b08`, `576355d`) are scripts in `tests/browser` that no lane runs.

- No test walks every route for auth and tenant scope; 57 cross-tenant tests cover chosen routes.
- 22 of the 41 tools CI runs have no self-test, and `validate_pricing_drift.py:880` enforces a false sentence.
- The six SDKs test mocked payloads only; none runs against a live API, and none has a publish lane.
- Branch protection is gone (`61e3db3`). The blessing that replaces it is unsigned and records stage status only (`ci/pipeline.sh:459`).

How it gets enforced. Every package declares what it must prove in `ci/test-expectations.toml`, and every critical invariant names its test and gate in `docs/invariants.toml`. `tools/check_invariants.py` fails the validate stage when either is incomplete (T14). Coverage and mutation floors only rise (T2, T3). Every gate proves it can fail (T10). A required lane never skips for a missing tool, and the deploy host accepts only a signed blessing that lists every required lane as run and passed (T1).

WP	Adds	Fails the build when
T1	Signed, lane-level blessing; dated waivers	A lane is skipped or missing, a waiver has expired, or the blessing is unsigned
T2	Per-crate coverage floors; diff coverage on tier 1	A crate falls below its floor
T3	`cargo mutants --in-diff` per change; weekly full runs	A mutant survives in changed tier-1 lines
T4	Property tests for invoices, cancellation, the ledger, EU-only routing, receipts, suppression, legal rows and rate limits	An invariant fails on generated input
T5	Route × role authorization and tenant matrix	A route has no matrix row or returns the wrong status
T6	Live end-to-end lane: dogfood battery, product journeys, legitimate-traffic replay	A journey step or probe fails, or real traffic is blocked
T7	Nightly fuzzing for every parser	A target crashes, or a parser has no target
T8	OpenAPI and router drift gate	A route and the spec disagree
T9	SDKs run against a live API, then published	An SDK fails against the live stack

WP	Adds	Fails the build when
T10	A self-test for every gate; a meta-gate	A gate has no self-test, or passes its known-bad fixture
T11	Personal-data map and erasure completeness	A personal-data column is unmapped
T12	Claims checked against infrastructure	A page claims a location or capability above its readiness stage
T13	Restore drill, failover and load SLOs	A restore misses its objective, or load regresses more than 10%
T14	Invariant and expectations registry	A package or invariant lacks its declared tests
T15	Statistics simulations for the sales engine	Posterior, holdout, off-policy or sequential-test checks fail
T16	Tests for smtp-auth-proxy and the AI training scripts	Either suite fails or is skipped
T17	AI answer evaluation set	Any uncited claim, or correct answers drop more than 2 points

Per-crate and per-package detail, the 22 invariants and the 21 gates are in `Tests & enforcement`; the packages themselves are in `Work packages`. Build T1 and T10 first, because they make every other gate binding; then T5, T4, T11, T12 and S10; then the rest.

Other findings

1. **Three public claims are wrong or early.** Hosting is Finland-only (`ARCHITECTURE.md:12`), yet "Germany primary, Finland backup" appears on `eu-sovereign/index.md:13`, `data-locations.md:46`, two compare pages and the homepage partial `partials/home/sovereignty.html`. Those pages should say Finland. "Own EU MTAs" (`eu-sovereign/index.md:13`) needs B2. The "DORA/NIS2 evidence pack" (`:87`) is partly real: the public claims registry and the DORA and NIS2 mappings exist (`compliance/src/admin_routes.rs:130`), but the pack generator (B6) is unfinished. `tools/check_capability_claims.py` would catch all three if the capability registry recorded Finland as the only hosting location and listed the other two (T12).
2. **The governance register records a US transfer that does not happen.** Production sends through SES in `eu-west-1`, so no data goes to the US. But `compliance/src/governance.rs:733-760` still seeds SES in `us-east-1` and a transfer

record `TIA-AWS-SES-US`, citing an old `.env.example` value. The seed runs at every compliance boot (`compliance/src/bootstrap.rs:127`) and never overwrites an existing row, so the false record is probably already in the production register, where a buyer's DPIA or a register export would read it. Fix the seed and delete that row in a forward migration (T12).

3. **The 99.9% uptime promise rests on one host.** It appears in 8 site files, including the SLA page and the pricing plans. Either ship the second host (A3) or state the SLA the current setup can meet.
4. **The journal outlives erasure.** `mail_journal` (migration 264) is missing from the erasure map in `compliance/src/gdpr_automation.rs`, and retention defaults to forever. Keeping it can be lawful, but the reason must be recorded, the period configurable per tenant, and erasure answers must say what was kept (T11).
5. **Images are still built on the production host.** `ci/install.sh` gives the host the stages fetch, images, migrate, deploy, verify and notify. Building in CI and pulling by digest finishes A1.
6. **Autonomous messages carry no AI notice.** The site chat discloses; the mailbot and `reply_autosend.rs` do not. This is a legal duty today, not a future one (S19).

What this check could not verify

- **Production.** The live site and the deploy host were not reachable from this workspace. Which commit is deployed, and whether live pages match the repo, is unknown.
- **Test results.** Tests were counted by script, not run: crates.io is unreachable from this workspace, so nothing was built. Pass or fail comes from commit messages and CI files.
- **Coverage and mutation scores.** Never measured in the repo. The T2 and T3 floors start from the first required run.
- **Owner-side state.** The Adyen live account, the tax rates file and the US DPA approval live outside the repo.
- **Legal readings.** The AI Act, UWG §7 and CNIL points are summaries for planning, not legal advice. Have counsel confirm the disclosure wording and each country's consent rule.

Next steps, in order

1. **T1.** Sign the blessing and make it lane-complete. With branch protection retired, it is the only gate.
2. **S10.** Remove the solver hook and its tables (migration 269), and add `tools/check_no_bypass.py`.

3. **H2.** Invert `validate_pricing_drift.py:880`, then fix the FAQ sentence.
4. **S19.** Put the AI disclosure and an audit row on every autonomous send path.
5. **T12.** Change the hosting pages to say Finland only. Fix the own-MTA, evidence-pack and 99.9% SLA claims, or ship B2, B6 and A3. Fix the governance seed and delete the false transfer row.
6. **V1, V24, V6.** Fix the live Adyen URL and `ContAuth`; set `hel1` everywhere and regenerate the register; send backups to a Helsinki Storage Box with WAL archiving.
7. **T10, then T2.** Self-tests for the 22 gates; a required coverage lane with per-crate floors.
8. **S1–S5.** Correct the posterior, then add the holdout, logged propensities and the experiment registry. Every autonomous decision depends on them.
9. **S21, S15, S17, S20.** Policy packs, canonical answers, the deal desk and the veto-window ladder: the core of selling without you.
10. **Your steps.** Adyen live account and a staging purchase run (H3), tax rates (C2), the US DPA (C3), and your first policy pack.

Sources

- Repository `sbelakho2/ApexMail` at `61e3db3` (22 Oct), read file by file. Tests counted with scripts over every package, not run.
- CNIL, intérêt légitime et moissonnage: robots.txt and CAPTCHA refusals exclude a site.
- UWG §7 on dejure.org: email advertising needs prior express consent in Germany.
- Gibson Dunn, EU AI Act Omnibus agreement and Process Excellence Network, EU AI Act 2026: Article 50 transparency duties were not postponed and apply from 2 Aug 2026.
- Adyen, live endpoints and Adyen, make token payments: live Checkout needs the merchant prefix; subscription token payments need `shopperInteraction: ContAuth`.
- PwC Romania, Law 141/2025: Romania's standard VAT rate is 21% from 1 August 2025.
- RFC 5321 §4.5.4.1 (give-up time of at least 4–5 days) and §5.1 (implicit MX).
- OASIS SAML 2.0 Core §5.4.2: the signature Reference names the signed element's ID.
- Bloomreach, identifying Gmail opens: a GoogleImageProxy request indicates the message was opened in Gmail.
- RustSec advisory database, cloned 22 Oct 2026 at `640bf5a`.

Deep review · 22 Oct

How this review was done

Scope. Commit `61e3db3`, still the head of `main`. The Rust workspace has 55 crates: 49 with production or library code (357,850 non-test lines, 12,875 tests) and 6 test-only crates. Also read: both compose files merged as production runs them, `.env.production.example`, nginx, the backup and deploy scripts, 240 migration files, the CI stages, the Zola site in four languages, and the SDK manifests. KiwiCaptcha is a separate project and is out of scope.

Method. Every important crate was read at its entry points and core modules, then checked against how it is configured and deployed. Scans written for this review (not part of the repo) covered: lines, tests and risky patterns per crate; SQL strings that touch tenant tables without naming `tenant_id`; every external host in production code; every environment variable read against compose and the env file; the lockfile against the RustSec database with reverse-dependency traces; and per-service container hardening in the merged compose. Each finding below cites file and line at `61e3db3`.

Outside sources were used only where the code depends on an outside fact: Adyen's live endpoint and token-payment rules, Romania's VAT rate, Gmail's image proxy behaviour, RFC 5321 and SAML Core.

What could not run. Nothing was compiled or tested: crates.io, npm and PyPI are not reachable from this workspace, Zola is not installed, and production was not reachable. Test counts are counted, not run; every "no caller" claim comes from a search of the whole workspace.

Scorecard

Ratings: **A** no finding above Low; **B** at least one Medium; **C** at least one High; **D** blocks launch. "Tests" rates kind as well as count (property, fuzz and end-to-end coverage, not just density per 1,000 lines).

Crate	Page	Lines	Tests per 1,000	Correctness	Security	Tests	Maintainability	Main reason
`billing-service`	Money	24,196	23.6	D	B	C	C	Live charges fail (MON-1, MON-2)
`billing-common`	Money	732	110.7	B	A	A	A	Romania VAT 19% (MON-3)
`accounting-core`	Money	3,968	12.9	A	A	C	B	Lowest test density; no property tests

Crate	Page	Lines	Tests per 1,000	Correctness	Security	Tests	Maintainability	Main reason
`platform-catalog`, `billing-entitlements`	Money	877	28.5	A	A	B	A	Example tests only
`mta`	Mail delivery	14,025	54.4	B	C	A	C	Plaintext copy of all inbound mail (DEL-9); 8,877-line `inbound.rs`
`outbound-mta`	Mail delivery	5,203	38.2	B	B	B	B	No MTA-STS or DANE (DEL-1)
`worker-processors`	Mail delivery	19,155	43.4	A	A	B	C	22,724-line `email/processor.rs`
`mail-common`	Mail delivery	1,496	35.4	B	B	B	A	Receipts omit the route (DEL-8)
`tracking-service`	Mail delivery	5,148	49.1	B	A	A	B	Open counts wrong (DEL-6)
`imap-server`	Mail delivery	4,891	60.7	A	B	B	C	One 9,855-line file, not fuzzed
`mailstore-core`	Mail delivery	3,582	26.0	A	A	C	B	Low density
`api-server`	API	82,259	29.3	B	B	B	C	Published spec wrong (API-3); 9,082-line `web.rs`
`ui-foundation`	API	17,511	33.4	A	A	B	C	6,660-line `leptos_views.rs`
`compliance`	Data protection	46,589	24.4	C	B	C	C	Sales data outside DSRs (DP-1); filings untested
`enterprise`	Data protection	16,342	27.2	C	C	B	B	SAML rejects real IdPs (SEC-1)
`spam-filter`	Security	3,189	25.7	B	B	C	B	Untrained model (SEC-3)
`sandbox`, `ids-engine`, `dlp-engine`	Security	6,456	49.4	A	B	B	B	Tag-only, no antivirus (DEL-3)
`waf-engine`, `ddos-protection`	Security	9,175	95.7	A	A	A	B	Strong
`sales-autopilot`	Sales and AI	33,314	31.6	C	C	B	C	Posterior (SAI-2); solver hook (SAI-1)
`ai-service`	Sales and AI	8,533	54.6	A	A	A	B	Strong; model off in production
`sales-knowledge`	Sales and AI	502	23.9	A	B	B	A	Thin tests on the claim gate (SAI-7)

Crate	Page	Lines	Tests per 1,000	Correctness	Security	Tests	Maintainability	Main reason
`ha`	Platform	5,434	40.9	B	A	B	B	Nothing to fail over to; backups on-host (OPS-1)
`analytics`, `observability-service`	Platform	7,710	49.2	A	A	B	B	Inherits DEL-6
`apexmail-db`, `migrator`	Platform	4,149	32.5	A	A	B	B	Schema drift unproven (OPS-6)
`isolation`, `devex-service`, `edge-cases`, `ai-embeddings`, `pattern-matcher`, `queue-provider`	Several	13,638	—	—	—	—	C	Not used in production (OPS-4, DP-7)

Findings by severity

13 High, 23 Medium, 27 Low, 1 to verify. Cross-references (SAI-3, WEB-6) are listed once under their main ID.

ID	Severity	Finding	Work package
MON-1	High	Live Adyen URL wrong in config, compose, code and the gate	V1
MON-2	High	Renewals and usage charges omit `shopperInteraction: ContAuth`	V1
DEL-9	High	Every received message also stored as plaintext forever in `inbound_messages`	V19
DP-1	High	Sales prospects' data outside access and erasure	V23
DP-4	High	Config and the public register say Germany (`fsn1`), not Finland	V24
SEC-1	High	SAML rejects every standard IdP signature	V5
SAI-1	High	CAPTCHA-solver hook still in code	S10
SAI-2	High	Bandit posterior ignores silence and stacks rewards	S1

ID	Severity	Finding	Work package
OPS-1	High	All backups on the host they protect; no WAL archiving	V6
WEB-1	High	"Germany primary, Finland backup" across the site and legal pages	V24
WEB-2	High	Home page claims DANE and MTA-STS built in	V26
WEB-4	High	SAML SSO sold on Business and Enterprise	V5, V26
WEB-5	High	Privacy policy omits prospect data sources and the direct-marketing objection	V27
MON-3	Medium	Romania VAT 19%; no dated rates	V2
MON-4	Medium	Refunds and chargebacks do not reach invoices, ledger or VAT	V3
DEL-1	Medium	Port 25 TLS opportunistic only; DANE code unwired	B2
DEL-2	Medium	Two-tenant messages filed under one tenant; Bcc exposed	V13
DEL-3	Medium	Spam never reaches Junk; no antivirus	V14
DEL-6	Medium	Gmail and Outlook opens dropped, Apple prefetches counted	V18
DEL-7	Medium	Load tests exercise a queue production does not use	V16
DEL-8	Medium	Receipts omit route and digest; no key history	V17
API-3	Medium	Published OpenAPI lists seven paths that do not exist	V20
API-4	Medium	No provider-shaped webhook payloads	V21
DP-2	Medium	Erasure skips ClickHouse in production	V23
DP-5	Medium	Governance register seeds a false US transfer	T12
SEC-2	Medium	One internal token shared by 11 services	V25
SEC-3	Medium	Spam Bayes layer empty in production	V14
SAI-4	Medium	Autonomous replies carry no AI notice	S19
SAI-7	Medium	Claim validator has 12 tests	T15

ID	Severity	Finding	Work package
OPS-2	Medium	Status page, monitors and alerts on the same host; no alert channel set	V11
OPS-3	Medium	Production host builds its own images	A1, V11
OPS-5	Medium	252 env variables invisible to the deployment	V12
OPS-8	Medium	Pool sizes exceed Postgres `max_connections`	V12
DEP-1	Medium	Two new unignored advisories fail `cargo audit`	V7
DEP-2	Medium	Two legacy TLS/HTTP stacks behind 7 ignores	V7
WEB-3	Medium	"All data encrypted at rest and in transit"	V26
MON-5	Low	Invoice "PDF" is HTML; PDF path unused, defaults to AWS S3 Frankfurt	V4
MON-6	Low	Non-hex webhook key accepted silently	V1
DEL-4	Low	Retry window about 25 hours	V15
DEL-5	Low	No implicit MX; wrong DSN codes	V15
DEL-10	Low	SMTP and IMAP server parsers not fuzzed	T7
API-1	Low	Three API-key hash formats accepted	V22
API-2	Low	Redis outage stops all authenticated traffic	V9
API-5	Low	No stable event id on webhooks	V21
API-6	Low	`devex-service` not deployed	V20
API-7	Low	No passkeys	V22
DP-3	Low	Mail journal kept forever by default	T11
DP-6	Low	Register gate blind to the AI endpoint	V24
DP-7	Low	Isolation service deployed, unused; no RLS	V10
SEC-4	Low	Container hardening gaps	V8
SEC-5	Low	No panic catcher on handlers	V9
SEC-6	Low	Threat-intel feeds empty	V14
SEC-7	Low	Backups use unauthenticated CBC	V6
SAI-5	Low	`ai-embeddings` unused	V12

ID	Severity	Finding	Work package
SAI-6	Low	Dead `Role::from_plan`	V12
OPS-4	Low	Five crates ship nothing	V12
OPS-6	Low	Production schema equality unproven	T14
OPS-7	Low	Migrator docs cite a deleted workflow	V12
DEP-3	Low	Vendored `imap-proto` 0.10 and OpenSSL in inbox-placement	V7
DEP-4	Low	No `rust-toolchain.toml`	V7
DEP-5	Low	Axum split 0.7 / 0.8	V7
WEB-7	Low	Pricing FAQ promises an Adyen billing portal	T10
WEB-8	Low	"Respond within 30 days" versus one month	V27
MON-7	To verify	First checkout may be routed as a renewal; token event must be enabled	V1

Money

Checked at `61e3db3`. Line counts are non-test code lines; tests are counted, not run.

billing-service

Role. Subscriptions, renewals, usage and overage collection, invoices, credit notes, dunning, Estonian VAT returns (KMD and the e-MTA X-Road transport) and US sales tax. 24,196 lines, 571 tests (23.6 per 1,000 lines, the second-lowest density in the workspace after accounting-core).

How it works. Checkout opens an Adyen session from api-server with `storePaymentMethod` and `shopperReference` set to the tenant id (`api-server/src/routes/billing.rs:3267–3300`). Adyen's webhook lands on the same api-server process (`app.rs:454`). `adyen_webhooks.rs` verifies each item's in-body HMAC, dedupes it, and dispatches on `eventCode`. Renewals (`maintenance.rs`) and usage collection (`overage.rs`) charge the stored token with `POST /payments`, each with a deterministic `Idempotency-Key`, and settle when the webhook arrives.

What is solid

- All money is integer minor units. VAT is computed in `i128` tenths of a percent with half-up rounding (`billing-common/src/vat_rates.rs:149–163`), and a source-scanning test refuses floats in money paths (`money_invariants.rs:510–580`).
- Reverse charge needs recorded VIES evidence for the invoice date, not just a well-formed VAT number (`invoices.rs:173–193`).
- HMAC checks use `Mac::verify_slice`, which is constant time, and are tested against Adyen's official SDK vector (`adyen_webhooks.rs:333–349`, `:3379`).
- A charged total that disagrees with the local invoice blocks settlement and opens a finance incident instead of booking it (`adyen_webhooks.rs:1433`).

Findings

ID	Severity	Finding	Evidence	Fix
MON-1	High	The live Adyen URL is wrong everywhere it is set, and the production gate requires the wrong value. Live Checkout calls need your merchant prefix: `https://[prefix]-checkout-live.adyenpayments.com/checkout/v71`. `checkout-live.adyen.com` is not a live Checkout host, so the first live checkout and every renewal would fail	`.env.production.example:163`; `docker-compose.prod.yml:488, 1877`; `api-server/src/routes/billing.rs:1023`; `tools/check_prod_billing_wiring.py:38`	V1

ID	Severity	Finding	Evidence	Fix
MON-2	High	Renewal and usage charges on a stored card omit `shopperInteraction: "ContAuth"`, which Adyen lists as required for subscription token payments alongside `recurringProcessingModel`	`maintenance.rs:5016-5027`; `overage.rs:2346-2357`	V1
MON-4	Medium	Refunds and chargebacks only write an audit row and an operator notification. Nothing marks the invoice, issues a credit note, reverses the ledger or adjusts VAT, and a chargeback does not pause the account. The app cannot refund to a card at all: admin credit notes go to the wallet	`adyen_webhooks.rs:1035-1140`; `api-server/src/routes/billing.rs:4936-4945`	V3
MON-5	Low	The customer "PDF" invoice is an HTML page. `generate_invoice_pdf` has no production caller, although its doc comment says it runs after every invoice, and its upload target defaults to AWS S3 in Frankfurt with no `S3_*` settings in production	`api-server/src/routes/billing.rs:73, 3658`; `invoices.rs:43, 64-66, 782-784`	V4
MON-6	Low	A webhook key that is not hex is silently used as raw bytes. In production a mistyped key should stop startup, not fail every webhook	`adyen_webhooks.rs:292-295`	V1
MON-7	To verify	The first checkout payment is classified as a renewal if Adyen echoes `recurringProcessingModel` in its notification, and that handler refuses the `checkout:` reference. Tokens arrive only if the `RECURRING_CONTRACT` event code is switched on in the Customer Area	`adyen_webhooks.rs:456-477, 629-640`; `api-server/src/routes/billing.rs:3276, 3284`	V1

billing-common

Role. VAT rates, proration, audit ids and CSV escaping shared by billing-service and api-server. 732 lines, 81 tests (36 on VAT).

What is solid. Integer VAT rounding, a fail-closed map-miss policy you can switch on (`VAT_MAP_MISS_POLICY=error`), and VAT-number checks that never authorise a reverse charge by themselves (`vat_rates.rs:262-300`).

Findings

ID	Severity	Finding	Evidence	Fix
MON-3	Medium	Romania is still 19%. Its standard rate has been 21% since 1 August 2025 (Law 141/2025), so Romanian consumers are under-charged. The table has no effective dates, so every future change needs a code release and an alert someone notices	`vat_rates.rs:59`	V2

The other 26 standard rates match the published 2026 rates, including Estonia 24% and Finland 25.5%.

platform-catalog and billing-entitlements

Role. `platform-catalog` (272 lines, 8 tests) is the single source of plan names, prices and limits in EUR and USD cents. `billing-entitlements` (605 lines, 17 tests) maps plan features to allow-or-deny decisions for every customer handler.

What is solid. Consumers pin equality with drift tests, `tools/validate_pricing_drift.py` checks the site against the catalog, and `tools/check_feature_entitlements.py` audits feature classes.

Gaps. Neither crate has property tests. The catalog's own invariants (yearly equals ten months, both currencies present, limits rise with price) are checked only by example. No findings beyond test depth.

accounting-core

Role. The statutory ledger (migration 220): chart of accounts, journal postings from invoices, payroll and bank statements, period close, trial balance and VAT derivation for the Estonian returns. 3,968 lines, 51 tests (12.9 per 1,000 lines), the lowest density in the workspace.

What is solid. A deferred constraint trigger refuses any unbalanced posted entry at commit, whoever writes it (`migrations/220_accounting_core.sql:578-640`). Closing a period is final, and the integration tests check that (`tests/accounting_invariants.rs:667-690`).

Gaps. `derive.rs` (trial balance, VAT totals, period result) and `periods.rs` have no unit tests and rely on three integration files. There are no property tests over random postings, and refunds never reach the ledger (MON-4).

Tests to add for money code

- Assert that every stored-card charge body carries `shopperInteraction: "ContAuth"` , `recurringProcessingModel` and the token's `shopperReference` (MON-2).
- A gate test that accepts only `https://<prefix>-checkout-live.adyenpayments.com/checkout/v71` in production config and refuses `checkout-live.adyen.com` (MON-1).
- Replay fixtures captured from the Adyen test account: the first checkout, a renewal, a refund, a chargeback and a token event. Each must reach the intended handler (MON-7).

- A dated VAT-rate test: each country's rate on a given date, and a monthly scheduled comparison with the European Commission's VAT rates database (MON-3).
- Property tests: proration is symmetric for upgrade then downgrade; VAT allocated across lines sums to the invoice VAT; postings from any invoice balance (I1, I3).
- Refund and chargeback flows end to end once V3 exists: credit note, ledger reversal, VAT adjustment, account state.

Mail delivery

Checked at `61e3db3`. Sizes are non-test code lines; density is tests per 1,000 of those lines.

Inbound MTA (mta)

Role. Port 25 inbound, customer SMTP submission (587/465), bounce and feedback-loop (ARF) listeners, SPF, DKIM, DMARC, ARC and BIMI checks, and durable delivery into mailboxes. 14,025 lines, 763 tests (54.4 per 1,000).

How it works. RCPT resolves each recipient against the mailbox directory. DATA runs authentication (`mail-auth`), the IDS payload scan, spam scoring and the attachment scan, then writes the message and one delivery job per recipient in a single transaction before answering 250 (`servers/inbound.rs:1656-1880`). A sweeper delivers jobs to mailstore over gRPC, retries, and sends at most one DSN per failed recipient (`servers/inbound_delivery.rs`).

What is solid

- Unknown mailboxes get 550 5.1.1 at RCPT and directory outages get 451, so the server never accepts mail it then drops (`inbound.rs:60-68, 246-255`).
- No 250 before the commit, and a fenced HA node refuses MAIL with 421 when it cannot prove it is unfenced (`inbound.rs:257-270, 375`).
- Protocol hardening is tested on the wire: bare LF, overlong lines, pipelining order, the 20-error cap, a 30-minute deadline for unauthenticated sessions, and no AUTH on port 25.
- DMARC lookups that fail transiently return 451 instead of accepting possibly spoofed mail.

Findings

ID	Severity	Finding	Evidence	Fix
DEL-2	Medium	A message addressed to two tenants in one SMTP transaction is filed under the first recipient's tenant. That tenant's `message.inbound` webhook lists every envelope recipient, including the other tenant's Bcc addresses. The second tenant gets no webhook and no row for its reply pipeline	`inbound.rs:1717-1727` (tenant from the first recipient); `inbound.rs:2018-2050` (payload `recipients: rcpt_to`)	Split by tenant at DATA: one row per tenant holding only that tenant's recipients (V13)
DEL-3	Medium	Spam never reaches Junk. Production runs the spam filter and IDS tag-only, delivery sends only DMARC `quarantine` to the Spam folder, and there is no Sieve. A message the filter scores as spam lands in INBOX with an `X-` header. No antivirus engine runs: `ClamAvSocketAnalyzer` is never constructed, and attachments are only flagged	`docker-compose.prod.yml:1336-1337`; `.env.production.example:695-699`; `inbound_delivery.rs:1128-1134`; `sandbox/src/dynamic_analyzers.rs:419`	File spam verdicts above a threshold into Junk, add a ClamAV container on the Finland host, learn from IMAP moves into Junk (V14)

Outbound relay and EU-only routing (outbound-mta, routing)

Role. The recipient-facing MTA for dedicated IPs and every EU-only send. It binds the requested source IP, resolves MX, speaks SMTP, classifies replies, retries, writes RFC 3464 DSNs and records each acceptance once per `send_unit`. 5,203 lines, 199 tests (38.2 per 1,000).

How it works. The worker plans a route per message: a dedicated IP if the tenant has one, otherwise the shared route, which is Amazon SES in `eu-west-1` (Ireland) by default (`docker-compose.prod.yml:517-518`). For an EU-only tenant without a dedicated IP the message is held, and a second guard re-checks the route the reservation produced (`worker-processors/src/email/processor.rs:1722-1750`). The relay strips every `X-ApexMail-*` header before the recipient sees it.

What is solid

- EU-only fails closed twice, before and after reservation.
- Null MX (RFC 7505) is refused, a peer's advertised SIZE is honoured before MAIL FROM, and STARTTLS that is advertised but fails moves to the next MX instead of downgrading (`relay.rs:1102–1125`).
- Only 5.1.x codes or explicit mailbox phrases suppress an address, so one receiver's spam policy cannot silence a recipient tenant-wide (`processor.rs:2014–2060`).

Findings

ID	Severity	Finding	Evidence	Fix
DEL-1	Medium	Port 25 TLS is opportunistic only. There is no outbound MTA-STS (RFC 8461) or DANE (RFC 7672) enforcement, so an attacker on the path can strip STARTTLS and the relay continues in cleartext. The 2,408-line DANE module has no caller anywhere in the workspace, and if wired as written its TLSA lookups would go to Cloudflare and Google DNS-over-HTTPS	`outbound-mta/src/tls.rs:28–45` ; `relay.rs:1119–1125` ; `mta/src/auth/dane.rs:30–33, 103`	Enforce MTA-STS and DANE in outbound-mta through a local validating resolver (Unbound) on the Finland host, with TLS-RPT (B2)

ID	Severity	Finding	Evidence	Fix
DEL-4	Low	Messages give up after about 25 hours: 12 attempts, 5 minutes doubling to a 4-hour cap. RFC 5321 §4.5.4.1 says the give-up time generally needs to be at least 4–5 days. A recipient server down over a weekend bounces everything	`retry.rs:186-197`; `main.rs:78`	A retry budget per message category: short for one-time codes, 4–5 days for the rest, and a delay notice at 4 hours (V15)
DEL-5	Low	A domain with no MX record is refused permanently, although RFC 5321 §5.1 says to use its A/AAAA record as an implicit MX. Domain-level failures are reported as `5.1.1` (bad mailbox); the right codes are `5.1.2` and, for a null MX, `5.1.10`	`mx.rs:9-10, 50-54`; `relay.rs:1809`	Follow §5.1 or document the deviation; correct the DSN codes (V15)

Worker pipeline (worker-processors, queue-provider)

Role. `worker-processors` sends queued mail (DKIM-signed, RSA 2048), and runs analytics roll-ups, campaigns, automations, reply classification and webhook delivery. 19,155 lines, 832 tests (43.4 per 1,000); `email/processor.rs` alone is 22,724 lines with its tests.

How it works. Workers claim rows from `email_queue` with `FOR UPDATE SKIP LOCKED`, take a lease with a fresh token, and reclaim rows whose lease expired, so a crashed worker cannot complete a row it lost (`processor.rs:573-596`).

What is solid. Lease fencing; RFC 8058 one-click unsubscribe headers with the literal `List-Unsubscribe=One-Click` value; a dedicated SSRF guard for customer webhooks (`webhook/ssrf.rs` , 1,041 lines).

Findings

ID	Severity	Finding	Evidence	Fix
DEL-7	Medium	`queue-provider` (a signed, priority-aging Postgres queue) has no production user. Only `smoke-tests` and `load-tests` depend on it, so the load-test numbers describe a queue production never runs	`smoke-tests/Cargo.toml:30` ; `load-tests/Cargo.toml:18` ; the real claim is `processor.rs:573-596`	Point the load tests at the real `email_queue` claim, then delete the crate (V16)

Gaps. `email/processor.rs` mixes planning, transport, receipts, suppression and analytics in one file; split it along those seams before adding more.

Routing receipts and mail-common

Role. `mail-common` (1,496 lines, 53 tests) holds the Ed25519 routing receipts, routing modes, SSRF checks, PII masking, hot config and the internal bearer-token middleware.

How it works. After an accepted send, the worker signs a fixed text payload. The api-server publishes the public key unauthenticated and offers a stateless verify endpoint. A send without a signer is refused rather than stored unsigned (`routing_receipt.rs:37-45`).

What is solid. A plain, unambiguous payload any Ed25519 library can check; fields containing CR or LF are refused; production refuses to boot without a key.

Findings

ID	Severity	Finding	Evidence	Fix
DEL-8	Medium	The receipt does not prove the route the sales pitch promises. It signs message id, tenant, transport label, time and source IP, but not the routing mode, the receiving MX host or a digest of the message. Only the current public key is published, so after a rotation nobody can check older receipts against a published key	`routing_receipt.rs:24-33`; `api-server/src/routes/routing.rs:79, 124-160`	Receipt v2 with `routing_mode`, `relay_host`, `recipient_mx` and `sha256(message)`; a key-history endpoint with validity dates; the key fingerprint in DNS and on the site (V17)

The shared internal token is covered under Security (SEC page).

Tracking service

Role. Open pixel, click redirect, RFC 8058 unsubscribe and preference pages, live event stream, custom tracking hosts. 5,148 lines, 253 tests (49.1 per 1,000), plus large adversarial test files.

What is solid. Tokens are AES-128-GCM sealed, so a click URL cannot be rewritten into an open redirect. A token used on a custom host must belong to that host's workspace. IPs are cut to /24 or /48 before storage (`analytics/src/ip_mask.rs:24-53`). Open recording runs under a concurrency cap.

Findings

ID	Severity	Finding	Evidence	Fix
DEL-6	Medium	Open rates will be wrong in both directions. `GoogleImageProxy`, the Yahoo proxies, "Microsoft Office" user agents and Google's proxy ranges are classed as bots and never recorded. Gmail loads images through that proxy when a message is opened, so Gmail and Outlook desktop opens are lost. Apple Mail Privacy Protection prefetches are counted as human opens	`tracking-service/src/bot.rs:27-30, 67-68, 112-116`; `routes/pixel.rs:131-135`	Record every open with a class (human, mailbox proxy, privacy prefetch, security scanner) and report them separately (V18)

The sales engine already ignores opens (`sales-autopilot/src/scoring.rs:1517-1520`), so this affects customers' reports, not lead scoring.

IMAP and mail storage

Role. `imap-server` (4,891 lines, 297 tests; one 9,855-line `main.rs`) serves IMAP4rev1 on 993 and 143 with MOVE, UIDPLUS and IDLE, and proxies to `mailstore-core` (3,582 lines, 93 tests, 26.0 per 1,000) over gRPC. Mailstore encrypts message bodies with AES-256-

GCM, keys derived by HKDF and bound to tenant, account and mailbox. `imap-proto-patched` is a vendored `imap-proto` 0.10.2 for `inbox-placement`'s IMAP client; the server has its own parser.

What is solid. LOGINDISABLED before TLS on 143, quota enforced inside the store transaction, a 0600 key file check at boot, and a mailstore container with no network egress.

Findings

ID	Severity	Finding	Evidence	Fix
DEL-9	High	Every received message is also kept as plaintext in Postgres, forever. `inbound_messages` stores the raw MIME, text and HTML bodies and headers. Nothing purges it: the retention sweep covers only `events` and `messages`, and its out-of-scope list does not name this table. Mailstore's body encryption is therefore bypassed by a second copy	`inbound.rs:1842-1880`; `compliance/src/retention_sweep.rs:130-176`	Encrypt or drop `raw_message` and bodies once delivery succeeds; give the table a retention window in the sweep (V19, see DP page)
DEL-10	Low	The server's own IMAP and SMTP command parsers are not fuzzed. The two fuzz targets cover `mail-proto` and the vendored IMAP client parser, and CI does not run them	`fuzz-tests/fuzz/fuzz_targets/`; `ci/pipeline.conf` has no fuzz stage	Fuzz targets for the IMAP command parser and SMTP command and DATA handling, run nightly (T7)

Gaps. No CONDSTORE or QRESYNC, so phones resync whole folders; IMAP4rev2 (RFC 9051) is not offered.

Supporting crates

Crate	Lines	Tests	Role	Notes
`dns-resolver`	985	64	Cached MX, SPF, DKIM, DMARC, TLSA lookups	Built on `hickory-resolver` 0.26 under its old name `trust-dns-resolver` (`Cargo.toml:139`)
`template-renderer`	2,269	151	Customer templates: transpile, sandbox, render, plain text	Allow-listed tags and attributes, `on*` attributes refused, size caps (`sandbox.rs:39–98`). Its `bin/server.rs` is not deployed; api-server links it as a library
`inbox-placement`	2,743	103	Seed-mailbox placement tests over IMAP	Needs real seed accounts at Gmail, Microsoft and others; uses `imap` 2.4 with OpenSSL `native-tls` , the only OpenSSL user among the mail crates
`email-grader`	2,597	96	Public domain grader: MX, SPF, DMARC, BIMI, MTA-STS, TLS-RPT, blocklists	Bounded MTA-STS policy fetch
`mail-proto`	137	7	gRPC definitions shared by mta, imap-server and mailstore	Fuzzed

Tests to add for delivery

- A two-tenant inbound test: one transaction with a recipient in each tenant and a Bcc. Each tenant sees only its own recipients and gets its own webhook (DEL-2).
- A delivery test that a message scored as spam lands in Junk, and an EICAR attachment is caught once ClamAV runs (DEL-3).
- A downgrade test: a peer that publishes MTA-STS `enforce` but strips STARTTLS must be refused, never sent in cleartext (DEL-1).
- A table test of the retry schedule: total window per category and the delay-notice time (DEL-4).

- Load tests against the real `email_queue` claim, including lease expiry under load (DEL-7).
- Receipt v2 vectors: a fixed key, payload and signature that any Ed25519 library must verify, plus a rotated-key case (DEL-8).
- Open-classification fixtures: Gmail proxy, Apple privacy prefetch, Outlook desktop, a Defender scanner (DEL-6).
- A retention test: an `inbound_messages` row past its window is purged or stripped of content (DEL-9).
- Fuzz targets for the IMAP and SMTP command parsers in the nightly run (DEL-10).
- Property tests: `plan_delivery_route` never returns the shared route for `eu_only`; the relay never sends to a Null MX.

API and console

Checked at `61e3db3`. `api-server` is the largest crate: 82,259 non-test lines, 2,412 tests (29.3 per 1,000), 308 distinct route paths. The biggest files are `routes/web.rs` (9,082 lines), `routes/web/data.rs` (5,525), `routes/billing.rs` (4,455) and `routes/auth.rs` (3,862).

Router and authentication model

How it works. One Axum 0.7 router (`app.rs`, 9,105 lines) mounts public routes, the `/v1` API, the provider-compatible routes, the web console and the operator control plane, each on its own middleware stack (DDoS shedding, auth, rate limit, handler). Three credentials are accepted (`middleware/auth.rs:1-6`): an API key in `X-API-Key`, an RS256 bearer JWT (verified against a list of keys, so signing keys can rotate, `:1521-1546`), and the `am_session` cookie with CSRF checks on unsafe methods.

What is solid

- Session cookies are `HttpOnly; SameSite=Strict; Secure` (`routes/auth.rs:2266-2271`). Revocation lives in Redis, which runs with AOF and `noeviction`, so a revoked session cannot come back through eviction (`docker-compose.prod.yml:286-298`).
- Passwords use Argon2id at the OWASP parameters (m=19456, t=2, p=1), with a global cap on concurrent memory-hard checks (`apexmail-lib/src/crypto.rs:228`).
- Idempotency keys are bound to tenant, principal, method, route and a SHA-256 of the raw body; reuse with another payload gets 409, and the in-flight claim is fenced by an owner token (`middleware/idempotency.rs:1-40`).
- CORS refuses credentials when an origin wildcard is configured (`app.rs:371-421`).

Findings

ID	Severity	Finding	Evidence	Fix
API-1	Low	Three API-key hash formats are still accepted: HMAC-SHA256 with the server secret, bare SHA-256, and a bounded scan over Argon2id rows. Every unknown key pays for the fallbacks	`middleware/auth.rs:490-491, 556, 641-690`	Re-hash a legacy key on its next successful use, report how many remain, then remove the fallbacks (V22)
API-2	Low	Redis is a hard dependency of every authenticated request. Rate limits fail closed with 503 in production and session revocation lookups return 503 when Redis is unreachable, so a Redis restart stops sending and the console together	`middleware/rate_limiter.rs:1-4`; `middleware/auth.rs:1026-1040`	Keep fail-closed for revocation, but add a bounded in-process limiter for the Redis-down window; alert on it (V9)
API-7	Low	No passkeys (WebAuthn). The only second factor is TOTP, which phishing kits relay	no WebAuthn code in the workspace	Passkeys for console login, required for operator accounts (V22)

Route inventory and tenant scoping

Method. A scan written for this review (not part of the repo) found 219 SQL strings outside tests in api-server that touch a table with a `tenant_id` column without naming `tenant_id`. Spot checks of the riskiest found an ownership check first in every case: campaign recipients are counted only after `campaigns WHERE id = $1 AND tenant_id = $2` (`routes/campaigns.rs:1535-1560`); SCIM group updates load the group by `scim_id` and tenant first (`routes/scim.rs:1552-1592`). The `cp.*` queries on `gdpr_requests` are cross-tenant on purpose: they serve the operator control plane (`routes/web/data.rs:5300-5335`).

What is solid. `enforce_tenant_header_binding` refuses an `X-Tenant-Id` that differs from the credential's tenant (`middleware/auth.rs:1702`).

Gaps. The ownership check is a convention, not a guarantee: all 659 SQL strings in this crate are checked only at run time (no `sqlx::query!`), and Postgres has no row-level security policy (see Security, V9 and V10).

Provider-compatible endpoints and SDK surface

Role. Send routes shaped like SendGrid, Mailgun, Postmark and Resend (3,539 lines, 27 tests), and importers for each provider's suppressions, contacts, templates and DNS (3,349 lines, 17 tests).

What is solid. Both layers only translate: every compat send calls the canonical `send_message` handler, and every import writes through the canonical writers, so no gate can be bypassed (`routes/compat/mod.rs:1-15`; `routes/provider_import/mod.rs:1-20`). Imports default to `dry_run`. Errors come back in each provider's own shape.

Findings

ID	Severity	Finding	Evidence	Fix
API-3	Medium	The published OpenAPI spec describes endpoints that do not exist. `/specs/openapi.yaml` (22 paths, linked from the API docs page) lists `/team`, `/team/invite`, `/analytics/summary`, `/ips`, `/ips/pools` and `GET /account`, none of which is routed; API keys live at `/v1/auth/api-keys`, not `/v1/api-keys`, and suppressions are deleted by id, not recipient. A second spec, `docs/api/openapi.yaml`, has 203 paths and differs. No CI check compares either with the router	`apps/marketing-zola/static/specs/openapi.yaml`; `docs/api/openapi.yaml`; `routes/account.rs:16-22`; `routes/auth.rs:2085-2086`; `routes/suppressions.rs:17-20`	Generate one spec from the router (`utoipa` or `aide`), publish it, and fail CI when a route and the spec disagree (V20)

ID	Severity	Finding	Evidence	Fix
API-4	Medium	Switching providers still means rewriting webhook consumers. Sends are drop-in, but events arrive only in ApexMail's own shape; the migration page offers "payload mapping documentation"	`worker-processors/src/webhook/processor.rs:705-712`; `apps/marketing-zola/content/solutions/migration.md:32`	A per-endpoint payload format: `apexmail`, `sendgrid`, `postmark`, `mailgun`, `resend` (V21)

Gaps. Compat tests are hand-written requests. Golden fixtures captured from each provider's official SDK would catch mapping drift.

Webhooks and outbound HTTP

How it works. The api-server validates a webhook URL at creation; the worker delivers. Both resolve the host, refuse private and reserved addresses, pin the resolved IPs into the client, and never follow redirects (`api-server/src/routes/webhooks.rs:183-272`; `worker-processors/src/webhook/processor.rs:183, 753`). Each delivery is signed with HMAC-SHA256 over `timestamp.payload`, and stored secrets are encrypted envelopes that fail closed when tampered with (`processor.rs:675-700, 842-852`).

Findings

ID	Severity	Finding	Evidence	Fix
API-5	Low	No stable event id in the headers. `X-ApexMail-Delivery-Id` is new on every attempt and `X-ApexMail-Webhook-Id` names the endpoint, so a receiver cannot dedupe a retry without parsing the body	`processor.rs:673, 705-711`	Send the queue row id as a stable event id, and offer the Standard Webhooks headers (`webhook-id`, `webhook-timestamp`, `webhook-signature`) (V21)

Web console: sessions, CSRF, headers

How it works. Server-rendered pages from `routes/web.rs` and `routes/web/data.rs`, with views from `ui-foundation` (17,511 lines, 584 tests). Forms carry HMAC-signed CSRF tokens (`routes/csrf.rs`), and a bridge middleware checks them on form posts (`middleware/auth.rs:221`).

What is solid. Strict per-response Content-Security-Policy with script nonces, `frame-ancestors 'none'`, `object-src 'none'` and `form-action 'self'` (`app.rs:1235, 1329`), HSTS and `X-Frame-Options` on every response (`app.rs:1009–1052`), and an hour-long hard cap on impersonation sessions (`routes/session.rs:294–299`).

Gaps. `web.rs` holds the router, forms and handlers for the whole console in one 9,082-line file; split it by area (domains, team, billing, settings) to keep reviews tractable. No findings.

devex-service

Role. API versioning, an SDK manager, a webhook tester, OpenAPI serving and onboarding. 2,417 lines, 58 tests.

Findings

ID	Severity	Finding	Evidence	Fix
API-6	Low	Not deployed and not used by any production crate. Only `integration-tests`, `perf-tests` and `smoke-tests` depend on it, and it is absent from `docker-compose.prod.yml`. Its OpenAPI module is a third description of the API	`integration-tests/Cargo.toml`; `perf-tests/Cargo.toml`; `smoke-tests/Cargo.toml`	Delete it, or fold the webhook tester into api-server, once V20 publishes the one spec (V20)

`auth-server` (848 lines) is in the same position for its auth handlers: the binary serves only the status page, and its login, MFA and API-key handlers are kept but not routed (`auth-server/src/main.rs:1–13`). See Platform and operations for where the status page runs.

Tests to add for the API

- A spec gate: every route in the router appears in the published OpenAPI spec and every spec path is routed (API-3).

- Golden requests captured from the official SendGrid, Mailgun, Postmark and Resend SDKs, sent through the compat routes and compared with the canonical request they must produce.
- A webhook retry test: two attempts of one event carry the same event id and a valid signature each (API-5).
- A Redis-down test in production mode: the bounded local limiter engages, revocation still fails closed (API-2).
- A tenant-isolation suite generated from the route table: for each tenant-owned resource, tenant B's credential gets 404 on tenant A's id, for read, update and delete.
- A legacy-key test: a key stored as bare SHA-256 is re-hashed on use and the fallback counter drops (API-1).

Data protection

Checked at `61e3db3`. Hosting is one host in Finland; the findings below are about what the code, the configuration and the published register say.

compliance crate: structure and what runs

Role. 46,589 non-test lines, 1,139 tests (24.4 per 1,000). It holds far more than data protection: GDPR request automation, consent, retention, the audit log, document signing, breach notification, the governance register, the trust portal, and the Estonian statutory work (annual report in XBRL, TSD payroll, VAT OSS, filing transport). Programs the site says are not offered also live here: HIPAA (1,204 lines) and SOC 2 (1,332).

What runs. The `compliance` container (`docker-compose.prod.yml:893`) runs ten idempotent jobs: DSR processing every 30 seconds, the verification outbox every 60 seconds, token expiry, secret rotation, audit archival, retention, the retention sweep, ledger sweeps into `accounting-core`, statutory obligation sync and consent expiry (`bin/server.rs:35-50`). It boots with a DML-only database role, which a release test proves.

Gaps. No tests cover `xbrl_taxonomy.rs` (2,066 lines), `xbrl_taxonomy/instance.rs` (1,141), `tsd_ledger.rs` (646) or `statutory_routes.rs` (391). These produce filings sent to the Estonian authorities, so a schema error is a filing error; validate each output against the official XBRL taxonomy and the e-MTA schemas in CI.

Data subject requests and erasure

How it works. Requests arrive through the API or by email: the reply pipeline detects a request in an inbound message and writes it into the same tables (`worker-processors/src/reply_handler/dsr.rs`). Verification is a hashed token sent by email; the deadline is one calendar month with a justified, notified extension (`gdpr_automation.rs`). Access and erasure use one store map, and the erasure certificate lists every store as deleted, anonymised, retained (with the legal basis) or skipped.

What is solid. Suppressions survive erasure so an erased address cannot be mailed again; invoices are anonymised, not deleted; audit entries are retained as records of processing; skipped stores are reported, never counted as deleted.

Findings

ID	Severity	Finding	Evidence	Fix
DP-1	High	The sales engine's data is outside both access and erasure. A prospect who asks for a copy or for deletion gets neither from `sales_leads`, `sales_accounts`, `sales_contacts`, `sales_contact_points`, the evidence and signal tables, their reply emails in `inbound_messages`, or the emails sent to them in `email_queue`. Prospects are the people the autonomous sales engine processes most, and `gdpr_automation.rs` never mentions a sales table	`compliance/src/gdpr_automation.rs:2820-2900` (store map; no "sales" anywhere in the file); `migrations/200_sales_autopilot_v2_unification.sql:59, 212, 250`	Add every sales store and the mail tables to both maps; on erasure keep only a keyed hash in suppressions and set the contact to `do_not_contact` (V23)
DP-2	Medium	Erasure skips ClickHouse in production. `GDPR_CLICKHOUSE_ERASURE_ENABLED` is `false`, and `apexmail.events` keeps the recipient address, IP and user agent for 730 days. The certificate records the gap and the request ends as `partial`	`docker-compose.prod.yml:942`; `.env.production.example:347`; `deploy/clickhouse/initdb/001_schema.sql:12-36`	Enable it and confirm completion in `system.mutations`, or store a keyed hash instead of the address (V23)

Retention and the mail journal

How it works. The daily sweep purges `events` and `messages` per tenant, using the tenant's window clamped to its plan ceiling, skips tenants on legal hold, deletes in batches with a lock timeout, and writes a report per run that names the stores it cannot reach (`compliance/src/retention_sweep.rs:1-60`).

Findings

ID	Severity	Finding	Evidence	Fix
DEL-9	High	`inbound_messages` (raw MIME, bodies, headers, in plaintext) has no retention window and is not named in the sweep's out-of-scope list. Covered on the Mail delivery page	`retention_sweep.rs:130-176`; `mta/src/servers/inbound.rs:1842`	V19
DP-3	Low	The mail journal is kept forever by default (`MAIL_JOURNAL_RETENTION_DAYS=0`). It is the customer's legal record, but an unlimited default leaves storage limitation to chance	`.env.production.example:344`; `docker-compose.prod.yml:940`	Ask for a retention period when a tenant enables journaling, and show it on the journal page (T11)

Governance register and subprocessors

How it works. The public subprocessor page is generated from compose and the env example by `tools/generate_subprocessors.py`, with a `--check` gate that fails on drift and a zero-US check (`apps/marketing-zola/content/subprocessors/index.md:9–10`). It lists Hetzner, AWS SES in Ireland (the shared route, not used under EU-only routing) and Adyen.

Findings

ID	Severity	Finding	Evidence	Fix
DP-4	High	The configuration says Germany, not Finland. `HETZNER_DEFAULT_LOCATION` defaults to `fsn1` (Falkenstein) in code, compose and the env example, so dedicated IPs are created in Germany. The generator's default region is also `fsn1`, and the published register states "Germany / Germany / Germany … the active default is fsn1"	`api-server/src/ip_provider.rs:1525`; `docker-compose.prod.yml:454`; `.env.production.example:456`; `tools/generate_subprocessors.py:129–135`; `subprocessors/index.md:24`	Set `hel1` everywhere, make the generator read the production location, and add a gate that refuses any non-Finland location (V24)
DP-5	Medium	The governance register seeds AWS SES in `us-east-1` with transfer record `TIA-AWS-SES-US`. No such transfer happens; the seed is false and a buyer's DPIA would read it	`compliance/src/governance.rs:733–760`; called from `bootstrap.rs:127`	Derive the register from configuration and gate it (T12)
DP-6	Low	The register gate cannot see the AI endpoint. When `AI_MODEL_ENABLED` is switched on, message content goes to whatever `AI_MODEL_ENDPOINT` names, and the generator has no entry for it	`docker-compose.prod.yml:836–840`; no `AI_MODEL` key in `tools/generate_subprocessors.py`	Add the endpoint to the generator and require an EU endpoint under EU-only routing (V24)

Not a transfer by ApexMail, but worth fixing. Enterprise log streaming to Datadog is hard-coded to Datadog's US intake (`enterprise/src/log_streaming.rs:673, 950`). It runs only when a customer configures it, but a customer with a Datadog EU account cannot select `datadoghq.eu`. Add a site setting with the EU site as default (V24).

enterprise: SSO and field encryption

Role. SAML and OIDC single sign-on, SCIM, sub-accounts, white-label, contracts, QBR reports, log streaming, dedicated tenants and private deployment. 16,342 lines, 445 tests (27.2 per 1,000); `sso.rs` is 6,306 lines with tests.

SSO. OIDC issuers must be HTTPS or allow-listed, and tenant client secrets are encrypted and fail closed without a key. The SAML verifier rejects every standard IdP response; see SEC-1 on the Security page.

Field encryption. Envelope encryption: a fresh data key per value, wrapped by a tenant key, with the tenant bound as additional data (`field_encryption.rs`). In production it protects log-stream credentials and backs one API route (`routes.rs:824`); message storage does not use it. Its doc comment cites HIPAA, which the site correctly says is not offered.

isolation service

Role. Per-tenant quotas, per-tenant data keys, a SQL guard that requires a tenant predicate per table reference, and RLS policy generation. 5,385 lines, 166 tests.

Findings

ID	Severity	Finding	Evidence	Fix
DP-7	Low	Deployed and unused. The container runs with its own secrets, but no service calls it, and the database has no RLS policy at all (0 `CREATE POLICY` in 268 migrations)	`docker-compose.prod.yml:1084-1130`; no caller of `isolation:4500` in the workspace	Use its policy generator to ship RLS on tenant tables (V10), or remove the container until then

Data residency: every outbound endpoint

Every external host named in production Rust code or in the production configuration, and what it receives.

Endpoint	Where it runs	Receives personal data	Active in production config
Amazon SES, `eu-west-1`	Ireland (AWS, a US company)	Mail content and recipients on the shared route only	Yes (`EMAIL_TRANSPORT_TYPE=ses`); never under EU-only routing
Adyen	Netherlands	Billing contact, tokenised card	Yes
Hetzner Cloud API	Germany	No (server and IP management)	Only for dedicated IPs; location set to `fsn1` (DP-4)

Endpoint	Where it runs	Receives personal data	Active in production config
Google and GitHub OAuth	US	Sign-in identity, if a user chooses it	No (`GOOGLE_CLIENT_ID` unset)
Google and Microsoft calendar APIs	US	Meeting invitees for the sales calendar	No
Datadog log intake	US	Customer logs, if the customer configures it	No (customer-configured)
AI model endpoint	Whatever is configured	Message content	No (`AI_MODEL_ENABLED=false`)
Gmail Postmaster Tools, Microsoft SNDS	US	Domain and IP reputation only	Optional
Spamhaus, SURBL, URIBL, abuse.ch	EU and CH	Sender IPs and URLs in DNSBL queries	Yes
e-MTA X-Road, Äriregister	Estonia	Statutory filings	Yes
Cloudflare and Google DNS-over-HTTPS	US	Recipient MX names	No (the DANE code has no caller, DEL-1)
AWS S3, `eu-central-1` default	Germany	Invoice PDFs	No (no production caller, MON-5)

Nothing in this table moves personal data to the US in the production configuration. The two items to fix are configuration drift (DP-4) and gaps in what the register gate can see (DP-6).

Tests to add for data protection

- A DSR end-to-end test for a sales prospect: seed a lead, contact points, evidence, a reply and a sent email; an access request returns all of it, and erasure removes it and leaves a suppression hash (DP-1).

- A store-map completeness gate: every table with an email, name or IP column is in the access and erasure maps, or carries a written legal basis for retention. It fails when a migration adds such a table without one.
- A ClickHouse erasure test that waits for the mutation and checks the address is gone (DP-2).
- A location gate: every Hetzner location in code, compose, the env example and the generated register is `hel1` (DP-4).
- A register test: switching on an optional processor (SES region, AI endpoint, OAuth) changes the generated page (DP-6).
- Schema validation of the XBRL annual report, TSD and KMD outputs against the official schemas.

Security

Checked at `61e3db3`. No crate uses `unsafe` code.

Attack surface and threat model

What faces the internet. One host publishes six ports: 80 and 443 (nginx, in front of the API, console, site, tracking and status page), 25, 587 and 465 (mta), and 993 (imap-server) (`docker-compose.prod.yml:124–125, 1263–1265, 1438`). Everything else sits on internal Docker networks; Postgres and Redis publish no ports.

Who the attacker is. Four inputs carry hostile data: email arriving on port 25, API and console requests, customer-supplied content (templates, webhook URLs, imports), and pages the sales engine fetches. The highest-value targets are mailstore (every mailbox), the DKIM keys (sending as any customer domain), and the Adyen and receipt signing keys.

Findings

ID	Severity	Finding	Evidence	Fix
SEC-2	Medium	One bearer token guards every internal API. Eleven services mount the same `internal_service_token`, including ai-service and pdf-renderer, which process untrusted content. Code running in any of them can call mailstore, billing or sales as a trusted peer	`mail-common/src/internal_auth.rs:62–66` (falls back to `INTERNAL_SERVICE_TOKEN`); 23 references in `docker-compose.prod.yml`	One token per caller, and an allow-list per service: mailstore accepts only mta and imap-server (V25)

Edge protection: WAF, DDoS, rate limits

Crate	Lines	Tests	Used by	Production mode
`waf-engine`	3,901	286	api-server (`middleware/waf.rs`)	Enforcing (`WAF_ENFORCE=true`), headers, path and query only
`ddos-protection`	5,274	592	api-server	On, with trusted-proxy ranges from config (`docker-compose.prod.yml:424–430`)

Crate	Lines	Tests	Used by	Production mode
`fingerprint`	760	44	ddos-protection	Client fingerprinting
`rate-limiter`	1,134	87	auth-server only	api-server has its own Redis limiter, fail-closed
`pattern-matcher`	715	44	nothing	Not linked into any production binary

What is solid. The WAF has no body inspection by design and handlers validate bodies, so a WAF false positive cannot reject a valid send; the DDoS layer trusts `X-Forwarded-For` only from configured proxy ranges.

Gaps. `pattern-matcher` ships nothing; delete it or give it a user.

Account protection and auth-server

What is solid. Login lockouts escalate from 15 minutes to 24 hours and count distinct IPs (`api-server/src/routes/auth.rs:39-41, 1242-1258`); comparisons of secrets use a timing-safe helper; `ato-protection` (1,782 lines) scores logins and can require MFA (`ATO_PROTECTION_ENABLED=true`). `auth-server` serves only the status page; its retained login handlers are not routed.

Findings

ID	Severity	Finding	Evidence	Fix
SEC-1	High	SAML single sign-on rejects standard identity providers. The verifier accepts a signature only if its Reference is `URI=""` (the whole document). SAML Core §5.4.2 requires the Reference to name the signed element's `ID` (`URI="#_abc"`), which is how Entra ID, Okta, Google Workspace and ADFS sign, so every real login fails	`enterprise/src/sso.rs:194-252`	Accept `URI="#ID"` only when it names the Response or the single Assertion, refuse duplicate IDs, and read claims only from the signed element; test with captured responses from each major IdP (V5)

Mail security: IDS, DLP, sandbox, threat intel, spam filter

Crate	Lines	Tests	Wired into	Production mode
`spam-filter`	3,189	82	mta, email-grader	Tag only (`MTA_SPAM_REJECT_ENABLED=false`)
`ids-engine`	2,009	114	mta	Tag only (`MTA_IDS_REFUSE=false`)
`sandbox`	2,629	103	mta	Static checks, `flag` mode; no antivirus engine
`dlp-engine`	1,818	102	worker (outbound)	On (`WORKER_DLP_ENABLED` required)
`threat-intel`	1,920	92	api-server, email-grader	No feeds configured (`THREAT_INTEL_FEED_URLS` empty)

Findings

ID	Severity	Finding	Evidence	Fix
SEC-3	Medium	The spam filter's Bayesian layer is empty in production. The mta builds the engine from default config, nothing calls `train_spam` or `train_ham`, and per-tenant models live only in memory, so scoring rests on header, content and URL rules alone. Together with DEL-3, inbound spam protection is weaker than the crate list suggests	`mta/src/servers/content_security.rs:105-113`; `spam-filter/src/engine.rs:161-165`	Ship a trained base model, persist per-tenant models, and train from Junk moves (V14)
SEC-6	Low	Threat-intel feeds are empty, so the crate runs with no data	`docker-compose.prod.yml:444`; `.env.production.example:168`	Configure the abuse.ch URLhaus and ThreatFox feeds, or switch the lookups off until feeds exist (V14)

Cryptography and secrets

What is solid. 43 Docker secrets, read from files, never from plain environment values; services refuse to boot in production without their keys. AES-256-GCM with scope-bound additional data for mailbox bodies, DKIM keys, webhook secrets and field encryption; HKDF key derivation in mailstore v2; Ed25519 for routing receipts; RS256 JWTs with key rotation; Argon2id passwords; RSA 2048 DKIM keys (`apexmail-lib/src/dkim.rs:22`). Backups are verified restorable (decrypt plus `pg_restore --list`) before old copies are pruned.

Findings

ID	Severity	Finding	Evidence	Fix
SEC-7	Low	Backups use AES-256-CBC without authentication (`openssl enc` has no AEAD mode), so a tampered offsite copy decrypts without an error. Without a key, the script stores the dump unencrypted with a warning	`deploy/hardening/scripts/postgres-backup-encrypt.sh:7-22, 106`	Encrypt with `age` (authenticated), and refuse to run without a key in production (V6)
SEC-4	Low	Container hardening has gaps. Most services run read-only with `no-new-privileges`, but mailstore, the public status-server, migrator and the four backup containers do not, and no service drops Linux capabilities	merged `docker-compose.yml` + `docker-compose.prod.yml`	`read_only`, `no-new-privileges` and `cap_drop: [ALL]` on every service, with a compose gate (V8)

SQL and injection

Method. Every SQL string in non-test code was counted: 2,226 `sqlx` queries, all checked only at run time (no `query!` macros), 227 built with `format!`, 27 with `QueryBuilder`. The `format!` cases in api-server were sampled: dynamic columns come from allow-lists (`routes/helpers.rs:70-96`, `validate_sort_column` in `routes/messages.rs:3385`, a `match` in `routes/web/data.rs:1455-1476`), and values are bound parameters. No injection was found.

Gaps. Safety depends on every future `format!` keeping that discipline, and a renamed column fails only in production. Check queries against the migrated schema in CI (`sqlx prepare --check` with `SQLX_OFFLINE`, or a test that runs each query with `EXPLAIN`), and add a lint that allows `format!` SQL only with an allow-listed identifier (V9).

Panic and resource-exhaustion surface

Counts in non-test code. 102 `unwrap()`, 294 `expect()`, 32 `panic!`, 557 integer `as` casts, 323 `let _ =` discards. The largest shares are in compliance (80 unwrap, expect or panic), api-server (65) and billing-service (36).

What is solid. Body-size limits and a 30-second timeout on the API, a 2 MiB and cell-count cap on spreadsheet imports (`routes/contacts.rs:1072–1086`), bounded webhook responses, and a concurrency cap on Argon2 checks.

Findings

ID	Severity	Finding	Evidence	Fix
SEC-5	Low	No `CatchPanicLayer` anywhere. A panic in a handler drops the connection without a 500 or a request-log line, so the failure is invisible to the customer and to alerts	no match in the workspace; `Cargo.toml:242` sets `panic = "unwind"`	Add `CatchPanicLayer` with a metric; deny `clippy::unwrap_used` and `expect_used` in handler modules (V9)

Tests to add for security

- SAML: captured, signed responses from Entra ID, Okta, Google Workspace and Keycloak log in; wrapping attacks (a second unsigned Assertion, a duplicated ID, a moved signature) are refused (SEC-1).
- A token-scope test: a call to mailstore with a token minted for ai-service is refused (SEC-2).
- A spam corpus test: a public spam and ham corpus scores above the configured accuracy floor with the shipped model (SEC-3).
- A compose gate: every service has `read_only`, `no-new-privileges` and `cap_drop: [ALL]`, or a written exception (SEC-4).
- A panic test: a handler that panics returns 500 and increments the panic metric (SEC-5).
- A backup tamper test: flipping a byte in an encrypted backup makes restore fail loudly (SEC-7).

- Fuzz targets for SMTP and IMAP command parsing, MIME parsing in the inbound path, and the SAML verifier (T7).

Sales and AI

Checked at `61e3db3`. This page is about the code. How to make the engine sell better is on the Sales engine tab.

sales-autopilot: code structure and quality

Role. The outbound engine: canonical accounts and contacts, evidence and scoring, next-best action, sender identities, sequences, dispatch, replies, meetings and attribution. 33,314 non-test lines, 1,053 tests (31.6 per 1,000), 40 routes, 321 runtime-checked SQL strings. The largest files are `routes.rs` (6,666 lines with tests), `sequence_worker.rs` (6,069), `experiments.rs` (5,254), `dispatcher.rs` (4,647), `campaigns.rs` (4,032) and `decision_engine.rs` (4,003).

What is solid

- Opens can never raise a score or win an experiment; release-gate tests pin both (`scoring.rs:1517-1520`; `experiments.rs:2680`).
- One fetch path for every public page, with `robots.txt` that fails closed and cannot be switched off, per-host pacing, persistent per-host backoff, size and content-type caps, same-host redirects only, and a fixed decision table that turns a challenge page into a typed block, never data (`discovery/fetch.rs:1-60`). The public-page source fetches only operator-listed URLs and reads only schema.org `Organization` nodes and `mailto:` links (`discovery/public_web.rs:1-30`).
- Experiment outcomes are idempotent by primary key, and there is one Beta sampler in the codebase.
- A data-subject request sent by email is detected and routed into the statutory flow (`worker-processors/src/reply_handler/dsr.rs`).

Findings

ID	Severity	Finding	Evidence	Fix
SAI-1	High	The CAPTCHA-solver hook is still in the code: an env-configured solving service, a per-host opt-in route, an audit table and one retry after a solve. It contradicts the plan's rule that the engine never solves or outsources a CAPTCHA	`discovery/blocked.rs:18-60, 595-625, 765`; `routes.rs:199`; `migrations/258_scrape_challenge_readiness.sql`	Remove it with a forward migration and keep it out with a gate (S10)
SAI-2	High	The bandit posterior is not a rate estimate. Only reward events move it, so a silent delivery, the most common outcome, changes nothing; one contact's successive outcomes stack (click, reply, meeting, trial, payment add up to 5.35 to `alpha`). An arm with 1 reply in 1,000 sends and one with 1 reply in 10 get the same posterior, and the arm with more traffic accumulates more `alpha`	`experiments.rs:407-437, 171-185`	One terminal outcome per exposure, with silence as a failure after a fixed window (S1; invariant I13)

ID	Severity	Finding	Evidence	Fix
SAI-3	High	Prospects' data is outside access and erasure requests	see DP-1 on the Data protection page	V23
SAI-4	Medium	Autonomous replies carry no AI notice	`reply_autosend.rs`	S19

Gaps. `routes.rs`, `sequence_worker.rs` and `experiments.rs` each mix several responsibilities; split them along the pipeline stages named in the crate docs before the S-series work lands in them.

ai-service and ai-embeddings

Role. `ai-service` (8,533 lines, 466 tests, 54.6 per 1,000) runs the site chat, the mailbot (`email_agent.rs`), reply classification, a claim verifier (`verifier.rs`, 2,610 lines with tests), prompt-injection defences (`defense.rs`) and 18 read-only tools behind a role matrix (`tools.rs`). Generation goes to an OpenAI-compatible endpoint and fails closed when the model is off (`inference.rs:1-10`); in the production config it is off (`AI_MODEL_ENABLED=false`).

What is solid. Every tool call carries tenant and role and is checked before execution; tools only read; the site chat discloses that it is an AI (`chat.rs:44`); the provider key is redacted from debug output.

Findings

ID	Severity	Finding	Evidence	Fix
SAI-5	Low	`ai-embeddings` (1,498 lines, 101 tests) has no production user and is not deployed	no crate depends on it; absent from `docker-compose.prod.yml`	Delete it, or wire retrieval into `verifier.rs` when the model is switched on (V12)

ID	Severity	Finding	Evidence	Fix
SAI-6	Low	`Role::from_plan` maps plan names to tool roles (`enterprise` to Owner) but nothing calls it. Dead code that grants roles by plan is a trap for the next caller	`tools.rs:38-49`	Delete it (V12)

Gaps. `apps/ai/training` holds 89 MB of tokenizer copies and training arguments for local models that nothing deploys; keep training outside this repo.

sales-knowledge

Role. The one claim validator shared by the sales engine and the mailbot. The agent may state only a fact this crate can back with an in-date, externally allowed source; roadmap items, competitor comparisons, unapproved case studies and certifications come back `Unsupported` (`src/lib.rs:1-15`). 502 lines, 12 tests (23.9 per 1,000). Prices come from `platform-catalog`.

Findings

ID	Severity	Finding	Evidence	Fix
SAI-7	Medium	Twelve tests guard the only gate between generated text and a prospect. There are no adversarial or property tests: paraphrased roadmap claims, numbers that differ from the catalog, expired facts, claims in German or French	`sales-knowledge/src/lib.rs`	Property and corpus tests: any number not in the catalog is refused, any roadmap feature in any locale is refused (T15)

Its module doc still names `billing-service/src/plans.rs` as the plan source, while the code reads `platform-catalog` (`lib.rs:19` versus `:304-339`).

Tests to add for sales and AI

- A simulation with known true reply rates per arm: posterior means converge to them, and `alpha + beta - 2` equals exposures (SAI-2, I13).
- A gate that fails on solver or proxy-rotation vocabulary in the sales crate, env files, compose and new migrations, and a fixture site that serves a CAPTCHA and must end up permanently excluded (SAI-1).
- A claim corpus for `sales-knowledge`: 200 true and false statements in four languages with the expected verdict (SAI-7).
- A prompt-injection corpus for the mailbot: instructions hidden in inbound mail never change the tool set, the tenant or the recipient.
- An AI-notice test: every message that `reply_autosend` sends without human review carries the notice (SAI-4).
- A DSR test for a prospect, shared with DP-1 (SAI-3).

Platform and operations

Checked at `61e3db3`. Production is one host in Finland running 20 application images plus Postgres 16.8, Redis, ClickHouse, nginx, the monitoring stack and four backup containers.

apexmail-db and migrator

Role. `apexmail-db` (2,787 lines, 98 tests) is the pool, repositories and transactions for api-server and auth-server; every pool has an acquire timeout. `migrator` (1,362 lines, 37 tests) embeds the migration chain at build time and runs as a one-shot job before `docker compose up`; tests bootstrap from the same embedded set, so tests and production see one schema.

What is solid. `tools/migration_lint.py` requires guards on every DDL, refuses `CREATE INDEX CONCURRENTLY` inside the migrator's transaction and refuses unbounded `DELETE`; applied files are checksum-frozen.

Findings

ID	Severity	Finding	Evidence	Fix
OPS-6	Low	Applied migrations were rewritten once ("shape-reconciled") and the live checksums overwritten, so nothing proves the production schema equals a fresh run of the chain	`deploy/sync-migration-checksums.sh:1-20`; `tools/migration_lint.py:33-47`	A scheduled check that diffs `pg_dump --schema-only` of production against a fresh chain (T14)
OPS-7	Low	The migrator's docs name `.github/workflows/deploy-hetzner.yml` as a deploy path; `.github` no longer exists	`migrator/src/main.rs:3-5`; `migrator/src/lib.rs:3-5`	Correct the docs (V12)

Database schema across 268 migrations

Shape. 240 files numbered up to 268 (next free: 269), 373 tables, 221 of them with a `tenant_id` column. The early files (001–015 and some later ones) carry `_down.sql` twins; most later ones do not. Migration 268 drops orphan tables.

Findings

ID	Severity	Finding	Evidence	Fix
OPS-8	Medium	The four services that set a pool size ask for 50 connections each (tracking, api-server, mta, enterprise: 200 in total), and Postgres runs with its default `max_connections` of 100. Under load new connections fail; the alert at 90% fires only after it starts	`docker-compose.yml:270, 406`; `docker-compose.prod.yml:1304, 1603`; `postgres:16.8-alpine` with no `-c max_connections`; `deploy/prometheus/alerts/infrastructure-alerts.yml:138`	A connection budget per service that sums below the limit, or PgBouncer in transaction mode in front of Postgres (V12)

Tenant isolation in the schema rests on application queries alone: no table has a row-level security policy (DP-7, V10).

ha: health, failover and backups

Role. `ha` (5,434 lines, 222 tests) does health checks, failover coordination, replication checks, circuit breakers and the STONITH fence that mta, worker and api-server honour. On one host it has nothing to fail over to: `DB_REPLICA_HOSTS` is empty and fencing is off (`docker-compose.prod.yml:1040–1052`).

Backups. Daily `pg_dump`, encrypted, test-restored before old copies are pruned, kept 14 days, 8 weeks and 6 months; separate jobs for ClickHouse and Redis.

Findings

ID	Severity	Finding	Evidence	Fix
OPS-1	High	Every backup lives on the machine it protects. `BACKUP_TARGET` is empty, and the env file itself says so: "the only copy of every backup lives on the machine that can die". There is no WAL archiving either, so the best case is a 24-hour data loss and the worst case is total	`.env.production.example:533-539`; no `archive_mode` anywhere	Offsite copies to a Hetzner Storage Box in Helsinki, plus WAL archiving (WAL-G or pgBackRest) for point-in-time recovery; a monthly restore drill (V6, T13)
OPS-2	Medium	When the host fails, nobody hears about it. The status page (`status-server`), the synthetic monitor and Alertmanager all run on the same host, and every alert destination is empty in the env file (PagerDuty, Opsgenie, Slack, alert email)	`deploy/nginx/nginx.conf:242`; `docker-compose.yml:2073-2079`; `.env.production.example:234-243`; `deploy/alertmanager.yml.tmpl:24-118`	A small second VM in Hetzner Helsinki for the status page, external probes and alert delivery, plus one configured alert channel (V11)

observability-service and analytics

Role. `observability-service` (2,726 lines, 123 tests) is linked into 17 crates for tracing, metrics and logging, and runs as a service for alert intake. `analytics` (4,984 lines, 256 tests) writes delivery and engagement events to ClickHouse and runs as `analytics-worker`. Prometheus, Grafana, Loki and Tempo are self-hosted.

What is solid. Alert rules exist for the failure modes that matter (Redis memory, Postgres connections, disk space), and the subprocessor page correctly lists the monitoring stack as self-hosted software.

Gaps. Open-rate data written here inherits DEL-6. ClickHouse events keep recipient addresses for 730 days, outside erasure in production (DP-2).

Deployment: compose, nginx, containers

How it works. `ci/pipeline.sh` runs on the production host: it builds the workspace and every image locally, tags each `:<sha>` and `:latest`, scans every runtime image with Trivy, writes SBOMs and a signed digest manifest, and deploys through a generated digest override; rollback re-tags the previous `:<sha>` (`docker-compose.prod.yml:14-40`; `ci/stages/images.sh:1-30`).

What is solid. Digest-pinned deploys, a refusal to start any service whose image digest changed after the build, automatic rollback on failed probes, and secrets only through Docker secret files.

Findings

ID	Severity	Finding	Evidence	Fix
OPS-3	Medium	Production builds itself. A release build of 55 crates (`lto = "thin"`, `codegen-units = 1`) and about 20 images runs on the host that is delivering mail, and the full source and toolchain live there	`ci/stages/images.sh:3-10`; `Cargo.toml:234-242`	Build on the second Helsinki VM (or any build machine), push to a private registry there, deploy by digest (A1, V11)

ID	Severity	Finding	Evidence	Fix
OPS-4	Low	Five crates ship nothing to production: `devex-service`, `edge-cases`, `ai-embeddings`, `pattern-matcher` and `queue-provider` have no production user and no container, 8,253 lines between them; `isolation` runs but has no caller	dependency scan of every `Cargo.toml`; `docker-compose.prod.yml` image list	Delete them or give each a user; keep a gate that every workspace crate is either deployed, linked into a deployed binary, or test-only by name (V12)

Container hardening gaps are on the Security page (SEC-4).

Configuration and environment wiring

Method. Every `env::var` and env helper call in non-test code was collected and compared with `docker-compose.yml`, `docker-compose.prod.yml` and `.env.production.example`.

Findings

ID	Severity	Finding	Evidence	Fix
OPS-5	Medium	380 variables are read; 252 of them appear in neither compose nor the env example, so their production value is whatever the code default is, and nobody reviewing the deployment sees them. The location default (DP-4) is one example of a default that contradicts policy	scan of all crates at `61e3db3`	One generated config manifest (name, crate, default, production value, owner) and a gate that fails when a new variable is read without an entry (V12)

Tests to add for platform and operations

- A monthly restore drill: restore the latest offsite backup to a scratch database and run the smoke suite against it; record the time it took (OPS-1, T13).
- An external probe test: stopping the main host's nginx raises an alert on the second VM within five minutes (OPS-2).
- A connection-budget gate: the sum of pool sizes in the merged compose stays below Postgres `max_connections` minus a reserve (OPS-8).
- A schema-equality check between production and a fresh chain (OPS-6).
- A crate-reachability gate (OPS-4) and a config-manifest gate (OPS-5).
- A load test of the real send path on a staging copy, replacing the `queue-provider` load tests (DEL-7).

Dependencies

Checked at `61e3db3` against the RustSec advisory database cloned on 22 October 2026 (commit `640bf5a`). Package registries (crates.io, npm, PyPI) are not reachable from this workspace, so newer versions were not looked up.

Rust dependency inventory

`services/mail-server/Cargo.lock` resolves 804 external crates in 941 versions; 105 crates appear in more than one version. The toolchain is pinned by the build image (`rust:1.97.1-slim-bookworm`, `services/mail-server/Dockerfile:18`), not by a `rust-toolchain.toml`, so a developer machine can build with a different compiler than production.

Family	Versions in the lockfile	Where the old one comes from
`axum`	0.7.9, 0.8.9	`auth-server` alone is on 0.8
`hyper`, `http`, `h2`	0.14 / 1.9, 0.2 / 1.4, 0.3 / 0.4	the AWS SDK's legacy HTTPS client
`rustls`, `tokio-rustls`, `rustls-webpki`	0.21 / 0.23, 0.24 / 0.26, 0.101 / 0.103	the AWS SDK client and `hickory-resolver` 0.24 inside `mail-auth`
`hickory-resolver`	0.24.4, 0.26.1	`mail-auth` 0.4 and 0.5 (via `mail-send` and `mta`)
`quick-xml`	six versions, 0.31 to 0.42	`calamine`, `mail-auth`, the typst stack in `pdf-renderer`
`rand`, `base64`, `nom`	three or four versions each	spread across the tree

Known advisories against Cargo.lock

34 advisory matches. CI runs `cargo audit` with 27 reviewed ignores (`ci/pipeline.conf:156`); the review notes are sound for those. Two matches are new since that review and are not ignored, so the audit stage fails on a fresh advisory database.

Advisory	Package	Kind	Reaches production through	Status	Action
RUSTSEC-2026-0381	`webpki-roots` 1.0.7	Distrusted emSign intermediates still trusted	`reqwest` and `sqlx` in about 30 crates	**New, not ignored**	`cargo update -p webpki-roots` to 1.0.10 or later
RUSTSEC-2026-0382	`rustls-webpki` 0.103.15 and 0.101.7	Distrusted intermediates may verify	`rustls` 0.23 everywhere; 0.101 via the AWS client and `hickory` 0.24	**New, not ignored**	Update 0.103 to 0.103.16; review and ignore 0.101 until its parents move
RUSTSEC-2026-0346, -0349	`rustls` 0.21.12	Secrets in `Debug`; ServerHello downgrade	AWS SDK client; `mail-auth` DNS	Ignored, reviewed	Retire 0.21 with the AWS client and `mail-auth` upgrades
RUSTSEC-2026-0098, -0099, -0104	`rustls-webpki` 0.101.7	Name constraints; CRL panic	same as above	Ignored, reviewed	same
RUSTSEC-2026-0119	`hickory-proto` 0.24.4	Quadratic name compression	`mail-auth` in mta and worker	Ignored, reviewed	Move `mail-auth` / `mail-send` to a release on `hickory` 0.26
RUSTSEC-2026-0258	`h2` 0.3.27	Unbounded empty DATA frames	AWS SES client only (we are the client)	Ignored, reviewed	AWS SDK's current HTTPS client
RUSTSEC-2026-0194, -0195	`quick-xml` below 0.41 (four versions)	Quadratic attribute check; namespace memory	`calamine` (customer XLSX imports), `mail-auth` (DMARC reports), typst	Ignored, reviewed	`calamine` parses customer files, so this one is reachable with input an attacker controls; bound it with the 2 MiB import cap and upgrade first
RUSTSEC-2026-0367, -0368, -0369	`zip` 2.4.2	`extract()` permission and symlink issues	`calamine`, `mail-auth`	Ignored, reviewed	Not reachable: nothing calls `extract`
RUSTSEC-2026-0187	`lopdf` 0.34	Stack overflow on nested objects	`pdf-extract`, a dev-dependency of `pdf-renderer`	Ignored, reviewed	Not shipped

Advisory	Package	Kind	Reaches production through	Status	Action
RUSTSEC-2023-0071	`rsa` 0.9.10	Marvin timing side channel	DKIM key generation and signing	Ignored, reviewed	Low exposure (no attacker-timed decryption); watch for `rsa` 0.10
RUSTSEC-2026-0205	`scc` 2.4.0	Unsound `insert` on panic	test tooling	Ignored, reviewed	None needed
RUSTSEC-2023-0086	`lexical-core` 0.7.6	Unsound	`nom` 5 under the vendored `imap-proto` (inbox-placement)	Ignored, reviewed	Replace `imap` 2.4 with a maintained IMAP client
Unmaintained (11)	`bincode` 1, `fxhash`, `paste`, `rustls-pemfile` 1 and 2, `unsafe-libyaml`, `yaml-rust`, `ttf-parser`, `rustybuzz` and others	No fixes coming	mostly the typst stack in `pdf-renderer`, `scraper`	Ignored, reviewed	Track with the typst upgrade

Fix: V7 (bump the two new ones now; plan the AWS client and `mail-auth` upgrades that retire most of the rest).

Duplicates, unmaintained crates and toolchain

Findings

ID	Severity	Finding	Evidence	Fix
DEP-1	Medium	Two advisories published after the last review are unignored, so `cargo audit` fails on a fresh database	table above	`cargo update -p webpki-roots -p rustls-webpki`; add the 0.101 case to the reviewed list (V7)

ID	Severity	Finding	Evidence	Fix
DEP-2	Medium	Two old TLS and HTTP stacks ship alongside the current ones, and they are behind 7 of the 27 ignores. They come from two parents: the AWS SDK's legacy HTTPS client and `mail-auth`'s `hickory` 0.24	`revdeps` traces above	Switch the AWS SDK to its current HTTPS client; upgrade `mail-auth` and `mail-send` together (V7)
DEP-3	Low	`inbox-placement` pulls a vendored `imap-proto` 0.10.2 (2020, `nom` 5) through `imap` 2.4 and is the only mail crate on OpenSSL `native-tls`	`Cargo.toml:224-227`; `inbox-placement/Cargo.toml:36`	A maintained async IMAP client on rustls; drop the vendored crate (V7)
DEP-4	Low	No `rust-toolchain.toml`	repo root	Pin the same 1.97.1 the image uses (V7)
DEP-5	Low	`auth-server` alone is on Axum 0.8	`Cargo.lock`	Move the workspace to 0.8 in one change, or keep auth-server on 0.7 (V7)

`deny.toml` lists the same 27 advisories in lockstep with the CI list, which keeps the two tools honest with each other.

Non-Rust dependencies

Component	Manifest	Notes
TypeScript SDK `@apexmail/node` 1.0.1	`packages/sdk-typescript/package.json` with lockfile	No runtime dependencies; dev-only `typescript` and `@types/node`
Python SDK 1.0.1	`packages/sdk-python/pyproject.toml`	`pydantic` with `email-validator`; Python 3.9 and later
Go, PHP, Ruby SDKs	`go.mod`, `composer.json`, `Gemfile`	Go SDK has live and shape contract tests
Browser tests, contrast audit	`tests/browser/package.json`, `tools/contrast-audit/package.json`	Development only
Python tools	`tools/*.py`	55 tools, standard library mostly; several CI gates still lack a self-test (T10)

The SDKs call the routes that exist (for example `/v1/auth/api-keys` in `packages/sdk-go/apexmail.go`), so they are right where the published OpenAPI spec is wrong (API-3). Five hand-written SDKs are a lot for one person to keep in step; generate them from the one router-derived spec once V20 exists.

The npm, PyPI, Go and RubyGems advisories could not be checked from here. Run `npm audit`, `pip-audit`, `govulncheck` and `bundler-audit` in CI next to `cargo audit` (V7).

Website and claims

Checked at `61e3db3` from the Zola sources in `apps/marketing-zola`; the built site was not rendered (Zola is not installed here).

Site structure and locales

English is the default, with German, French and Spanish (`config.toml:8, 127–135`). English has 60 content pages and each other locale 47; the developer docs and API pages are English only. Shared copy lives in `data/i18n.json`, with English as the template fallback. Prices, the subprocessor register and several FAQs are generated from data files rather than typed.

What is solid. The site makes no third-party requests and sets no tracking cookies; a former "testimonials" block that attributed product copy to invented personas has been rewritten as plain capability text and is no longer included anywhere (`templates/partials/generated/testimonials-island.html:1–14`); HIPAA is stated as not offered on every page that mentions it.

Public claims checked against code

Findings

ID	Severity	Claim	Where	What the code and config show	Fix
WEB-1	High	"Germany primary, Finland backup"; data "replicated inside the EEA"	home `partials/home/sovereignty.html:35`; `eu-sovereign/index.md:13, 25, 71`; `data-locations.md:16–18`; `privacy/_index.md:41–44`; `dpa/index.md:48`	One host in Finland; backups stay on that host (OPS-1); the config defaults to Falkenstein (DP-4)	Say "hosted in Finland (Hetzner, Helsinki)" everywhere, and claim replication only once offsite backups exist (V24)
WEB-2	High	"DKIM, SPF, DMARC, DANE, and MTA-STS built in"	home `partials/home/features.html:20` (English); `data/i18n.json:461` (German)	Outbound DANE and MTA-STS are not enforced (DEL-1); the site's own architecture page labels both as roadmap (`architecture.md:152–158`)	Drop DANE and MTA-STS from the home card until B2 ships (V26)

ID	Severity	Claim	Where	What the code and config show	Fix
WEB-3	Medium	"All data encrypted at rest and in transit via TLS 1.2+"; "Message content encrypted at rest"; "AES-256-GCM encryption at rest"	`partials/home/security.html:32` (English), `data/i18n.json:885, 1646` (French, Spanish); `solutions/transactional-email.md:81`; `dpa/index.md:67`	Port 25 continues in cleartext when a receiver offers no STARTTLS; received mail is also stored as plaintext in `inbound_messages` (DEL-9). The German copy is already accurate: "SMTP delivery encrypted when the receiver supports it" (`i18n.json:124`)	Use the German wording in every language; claim content encryption once V19 lands (V26)
WEB-4	High	"SAML SSO" included on Business and Enterprise	`enterprise/index.md:24`; `solutions/regulated-industries.md:18`; `solutions/saas-platforms.md:31`; `compare/amazon-ses/index.md:48`	The verifier rejects standard IdP responses (SEC-1)	Fix V5 first; until then say "OIDC SSO; SAML on request" (V26)
WEB-6	Medium	The published OpenAPI 1.0.0	`static/specs/openapi.yaml`, linked from `docs/api/openapi/index.md:17`	Seven of its 22 paths are not routed (API-3)	Publish the router-derived spec (V20)

`tools/check_capability_claims.py` already blocks some claims; add each claim above to its registry with its true stage so the gate catches the next one.

Pricing consistency

`data/pricing.json` matches `platform-catalog` on every field compared, for all six self-serve plans: monthly price, included volume, retention, team size and overage per 1,000 (Free €0, Developer €20, Pro €89, Growth €229, Business €699, Enterprise Cloud €1,750). `tools/validate_pricing_drift.py` checks the built site; it needs a Zola build, so it was not run here.

ID	Severity	Finding	Evidence	Fix
WEB-7	Low	The pricing FAQ promises an "Adyen billing portal". Adyen offers none, as the billing code itself notes, and the drift gate requires the sentence to be present	`templates/partials/generated/pricing-faq-island.html:31`; `tools/validate_pricing_drift.py:880`; `api-server/src/routes/billing.rs:3376`	Invert the gate and fix the sentence (T10)

Legal pages

ID	Severity	Finding	Evidence	Fix
WEB-5	High	The privacy policy describes prospects' data as "provided via contact forms or email". The sales engine also collects names and addresses from business registers, operator-listed company pages (including `mailto:` links) and enrichment providers. Where data is not collected from the person, Article 14 requires the policy to name the source categories, and the right to object to direct marketing (Article 21(2) and (3)) is absolute; the policy lists only the general right to object to legitimate-interest processing. It was last updated on 2 May 2026	`privacy/_index.md:8, 22, 73`; `sales-autopilot/src/discovery/public_web.rs:20-25`	A prospects section: sources, purpose, legal basis, retention, and the unconditional right to object, linked from every first-touch email (V27, S14)

ID	Severity	Finding	Evidence	Fix
WEB-8	Low	"We will respond within 30 days." GDPR allows one month, and the request automation computes exactly that; the two disagree in February and in 31-day months	`privacy/_index.md:75`; `compliance/src/gdpr_automation.rs` (statutory deadline)	Say "within one month" (V27)

The DPA lists Hetzner as "Germany and Finland" (`dpa/index.md:48`), covered by WEB-1. Autonomous replies still need the AI notice (S19).

Third-party requests from the site

None. Templates load no external scripts, fonts, styles or images, and the privacy policy says the same (`privacy/_index.md:21`). Keep it that way with a CSP of `default-src 'self'` on the marketing vhost and a gate that fails on any absolute `http(s)://` asset URL in `templates/` .

ApexMail — Business Model & Tech Plan

Oct 13, 2026 · @Aaron

For agents: how to apply this doc

This doc is written so an AI agent can execute it end to end. Read this section first, every session. Then read the latest audit of the repo against this plan (Audit · 22 Oct) and the test rules in Tests & enforcement before choosing a work package. A package is done only when its tests run in a required lane and the signed gate blessing records that lane.

What each tab is for

- **Plan** (this tab): the strategy, pricing and MRR model. It explains why; it does not tell you what to change.
- Sales engine : the sales autopilot specification. Work package group F implements it.
- Work packages : the authoritative list of changes. Every change to the repo or to production comes from a work package (WP) there.
- Verification ledger : the evidence for every factual claim. Each row names the commit it was checked at; the latest audit checked `61e3db3` (22 Oct 2026).
- Tests & enforcement : the test rules, the critical invariants, what each package must prove, and the gates that enforce it. Work package group T implements it.
- **Audit tabs**: dated checks of the repo against this plan. Only the newest is current; older ones are kept as history.

Procedure, every session

1. Read the invariants below.
2. Open the index in Work packages. Take the first WP whose status is Not started and whose dependencies are all Done.
3. Before writing code, re-check the WP's "Current state" lines against the repo at HEAD. If a cited file or line has moved, update the ledger row first.
4. Do the WP. Meet every acceptance criterion and run every verification command listed.
5. Set the WP's status in the index, and record the commit SHA and test names in its Evidence line.
6. If a WP needs a human decision (marked **Owner**), stop at that step, write what you prepared, and move on to another WP.

Invariants (never break these, in any WP)

1. **EU-only mail fails closed.** A message on EU-only routing is held, never sent through SES or any non-EU transport.
2. **Sales sending is isolated.** It never shares a transport account, IP, sending domain or suppression list with customer mail.
3. **No claim without evidence.** Never publish a number, capability or comparison that has no ledger row. Computed numbers come from production data, never from typed constants.
4. **Prices change only at the source.** Edit `crates/platform-catalog/src/lib.rs`, then regenerate what derives from it. Never hand-edit derived pricing files. `tools/validate_pricing_drift.py` and `tools/check_knowledge_consistency.py` must pass.
5. **Agents draft legal rows; only the owner approves them.** Never set `approved_by` / `approved_at` on `sales_jurisdiction_policies`, `objection_library` or sequence versions.
6. **Autonomy moves only through the gates in WP F12 and S20.** A class promotes itself only when its evidence clears the bar and a 48-hour owner veto window has passed; any guardrail breach demotes it at once.
7. **BYOC stays frozen** (WP G1).
8. **Never delete a test.** Move it to another CI lane if needed.
9. **Every machine-written message says so.** A message sent without a human approving its exact text carries the AI disclosure line and an audit row (WP S19; EU AI Act Art. 50).
10. **Approve rules, not messages.** The engine acts only inside an active, owner-approved policy pack; anything outside it is held (WP S21).
11. **A gate counts only if it can fail.** Every gate that CI runs has a self-test on a known-bad fixture, and only a signed, lane-complete blessing deploys (WP T1, T10).
12. **After WP A1, no CI or test workload runs on the production host.**
13. **Migrations ship forward only.** Never edit an applied migration. Migrations run to 268 at commit `61e3db3`; new files start at `269`, with the header form `-- Migration NNN: ...` that the validate stage checks.
14. **Lawful sourcing only.** Discovery uses approved APIs, official registers, first-party data, or the operator-listed public pages of `discovery/public_web.rs`. It never solves, outsources or evades a CAPTCHA, never rotates proxies after a block, and never circumvents a robots.txt refusal or site terms. A refusal permanently excludes that host (WP S10).

Owner-only decisions. These are never made by an agent:

- approving legal policy rows, the objection library and sequences
- final prices

- signing contracts
- buying domains or IPs
- approving each policy pack and each new action class, vetoing a scheduled promotion, and re-promoting a class after a demotion
- anything sent under the owner's name for the first time

Generic definition of done. Every WP must meet these on top of its own criteria:

- `cargo fmt --check` passes.
- `cargo clippy --workspace --all-targets -- -D warnings` passes.
- New tests are proven to fail before the change and pass after.
- The touched crates' tests pass.
- The validate-stage gates in `ci/stages/validate.sh` are green, including `python3 tools/generate_repo_map.py --check`.
- The change lands on `main` and deploys through the normal pipeline.

Thesis

ApexMail is **the email platform built in Europe for anyone who does business in Europe**. EU companies are the core market; US companies are welcome and actively won. Most MRR comes from about 100–150 accounts on contract tiers, while self-serve plans and mailbox seats run without the founder.

Why this position works:

- **Volume pricing is a race to the bottom.** AWS SES sells sending at $0.10 per 1,000 emails, and Resend sells 50,000 emails for $20. An unknown brand cannot win on price per email alone.
- **European buyers lean toward local vendors.** 61% of Western European CIOs expect geopolitics to deepen their reliance on local or regional cloud providers (Gartner, 2025).
- **EU regulation creates budgets.** Financial entities under DORA must report every ICT provider in an annual register of information. They pay for vendors who make that easy.
- **US companies selling into Europe hit the same questions.** Their EU customers ask about residency, the DPA and sub-processors. An EU-based provider with ready answers shortens their sales cycles.
- **EU-sovereign buyers get something US-first rivals cannot offer.** Their mail never touches a US provider, the proof is signed per message, and the contract sits under EU law with an EU company. One setting turns this on, inside the same product the rest of the world uses.

Segment	Why they buy ApexMail	Lead product line	Where they come from
EU regulated firms (finance, insurance, health, public sector)	EU residency, DORA/NIS2 evidence, audit logs, EU contract and language	Compliance, Enterprise Cloud, Dedicated Tenant	Outbound from regulator registers
EU SaaS and SMEs	European vendor, EU support hours, local language, fair price	Self-serve, Platform, Mailboxes	Self-serve, comparison pages
US SaaS selling into Europe	Passing EU customers' procurement: EU residency, DPA, SCCs, evidence pack	Compliance, Platform	Outbound to US companies with EU customers
US developers and startups	Price, drop-in compatibility with their current provider, developer experience	Self-serve	Comparison pages, compatibility layer, SDKs
Platforms worldwide	Subaccount isolation, white-label domains, usage pricing	Platform	Outbound and partners

ApexMail already has what US-first rivals lack in Europe: an EU legal entity, DSR and audit automation, private-cloud packaging and four EU languages. It also has what EU rivals lack for larger deals: platform subaccounts, dedicated tenants and mailboxes in one account. What is missing is switching ease, SDK reach, provable claims and the evidence pack.

One rule governs every product line, because there is one founder: **each line is either fully self-serve, or worth at least €500 a month per account.**

This plan has no dates. Work is ordered by dependency, and MRR is modelled as customer mixes, not months.

Product lines and pricing

There are six revenue lines plus add-ons, each priced in both EUR and USD. Self-serve stays cheap and works as the funnel worldwide. Compliance, Platform and Dedicated Tenant carry the MRR, and mailbox seats grow inside those same accounts.

Line	EUR (excl. VAT)	USD	What's included	Main buyers
Self-serve API	Free €0 · Developer **€20** (was €29) · Pro €89 · Growth €229 · Business €699	$0 · $20 · $99 · $249 · $749	Today's volumes (3k / 50k / 150k / 500k / 2M). EU data residency by default, sending through AWS SES in an EU region	Developers, startups and SMEs worldwide
Compliance	€990/mo, annual	$1,090/mo	1M emails, EU-only routing included, dedicated IP, DORA/NIS2 evidence pack, GDPR processor pack (DPA, SCCs, sub-processor list), signed routing receipts, 1-year audit log, SSO	EU regulated firms; US SaaS selling into Europe
Enterprise Cloud	€1,750/mo, annual (today's plan)	$1,950/mo	5M emails, 3 dedicated IPs, legal hold and archive, quarterly evidence refresh, EU-only routing included. 99.9% SLA once the second host is live	Larger regulated senders
Platform	€990/mo base. €0.30 per 1,000 above 1M. €1 per active subaccount above 100	$1,090 base, $0.35 per 1,000, $1 per subaccount	Subaccounts with isolated reputation, white-label tracking and bounce domains, provisioning API	SaaS companies sending for their own customers, anywhere

Line	EUR (excl. VAT)	USD	What's included	Main buyers
Dedicated Tenant	From €4,000/mo, 12-month minimum, €10k–40k setup (already in the catalog)	From $4,500/mo	Single-tenant stack on dedicated hardware, EU region by default, 5M recipients, 2 managed IPs, named owner, monthly review	Banks, government, large platforms
Mailboxes	€6 per seat/mo, 10-seat minimum. Archive and journaling +€2 per seat	$7 per seat, +$2 archive	EU-hosted IMAP/SMTP mailboxes on the existing stack, autoconfig, spam and AV filtering, self-serve import	Staff of existing accounts first
Add-ons	Dedicated IP €49 first, €69 each extra (existing). Inbox placement monitoring €99/mo. EU-only routing on self-serve Pro and up €149/mo	$55, $75, $109, $165	EU-only routing sends through ApexMail's own EU MTAs, with no third-party transport	Any paid tenant

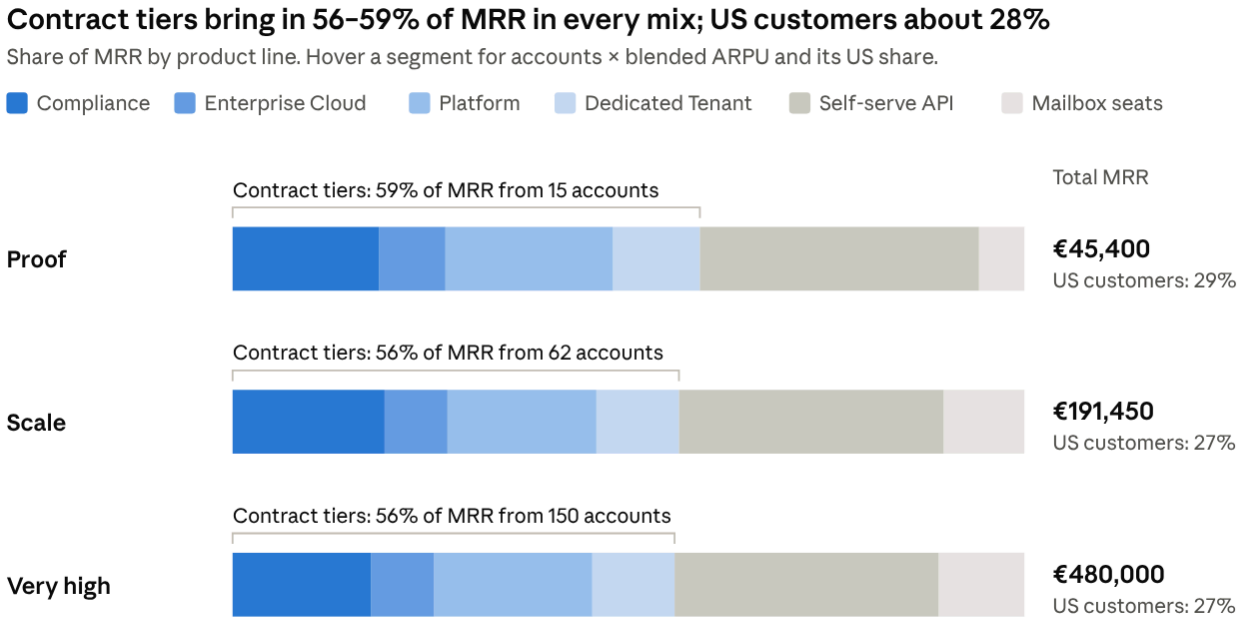
Price anchors: Resend charges $20 for 50,000 emails, so the $20 Developer plan meets it head-on. mailbox.org charges €4 (Standard) and €12 (Premium) per user, and €6 sits between them.

Since 14 Oct all payments run through Adyen, an EU company: cards in either currency, and SEPA Direct Debit for EU customers. Contract tiers can also pay by bank-transfer invoice through the accounting automation you already have.

MRR model

The three customer mixes produce €45,400, €191,450 and €480,000 MRR. Contract tiers bring in more than half in each one. EU customers carry roughly 70%, and US customers bring the rest. Moving from one mix to the next means adding accounts, not changing the

model.



modelled in this doc · 3 customer mixes, no dates · MRR = accounts (or seats) × blended ARPU; US share from the table below

Line	Blended ARPU (basis)	US share	Proof	Scale	Very high
Compliance	€1,050 (€990 plus overage and add-ons)	25%	8	35	80
Enterprise Cloud	€1,900 (€1,750 plus overage and extra IPs)	15%	2	8	20
Platform	€2,400 (€990 base, usage and subaccount fees)	40%	4	15	40
Dedicated Tenant	€5,000 (from €4,000; larger tenants pay more)	0%	1	4	10
Self-serve API	€80 (60% Developer, 28% Pro, 9% Growth, 3% Business, plus add-ons)	40%	200	800	2,000
Mailbox seats	€6.50 per seat (some with archive)	5%	400 seats	3,000 seats	8,000 seats

The US shares are assumptions. Self-serve and Platform lean toward the US developer market. Compliance includes US SaaS companies that sell into Europe. Dedicated Tenant and mailboxes are EU-led.

The mixes are steady states, not dates. Reaching one depends on win rate and churn. Transactional email churns little once integrated, and contract tiers are annual. The Very high mix (150 contract accounts) needs the contracted help described in the operating model.

Unit economics

Every line clears roughly 80% gross margin, so infrastructure cost does not cap MRR. The binding cost is founder hours (see the operating model). Figures are approximate, except the SES rate, which comes from AWS's price page.

Line	Main cost drivers	Approx. cost per account / month	Approx. gross margin
Self-serve	SES at $0.10 per 1,000 emails, Adyen fees ($0.13 per transaction plus the payment-method fee), share of hosting	Developer (50k emails): about €7	65% (Developer) to 85% (Pro and up)
Compliance	Dedicated IP, SES or own-MTA volume, evidence pack (generated, not hand-made)	€80–150	85–90%
Enterprise Cloud	5M emails, 3 IPs, archive storage, own EU MTAs for EU-only routing	€150–300	83–90%
Platform	Volume: cost per 1,000 is a fraction of the €0.30 / $0.35 charged	Scales with volume	80–85%
Dedicated Tenant	2–3 dedicated servers, offsite backups, IPs. Setup fee covers onboarding hours	€400–800	80–90%
Mailboxes	Storage, spam and AV compute	€0.50–1 per seat	About 85%

Fixed costs the plan requires:

- Two production hosts in different Hetzner locations, one CI/build host, offsite backup storage
- ISO/IEC 27001 certification and its yearly surveillance audit, for EU buyers (Lettermint already has it)
- A SOC 2 Type II report once US mid-market deals stall without it; US security reviews expect SOC 2 the way EU ones expect ISO 27001
- Cyber and professional liability insurance that covers US customers

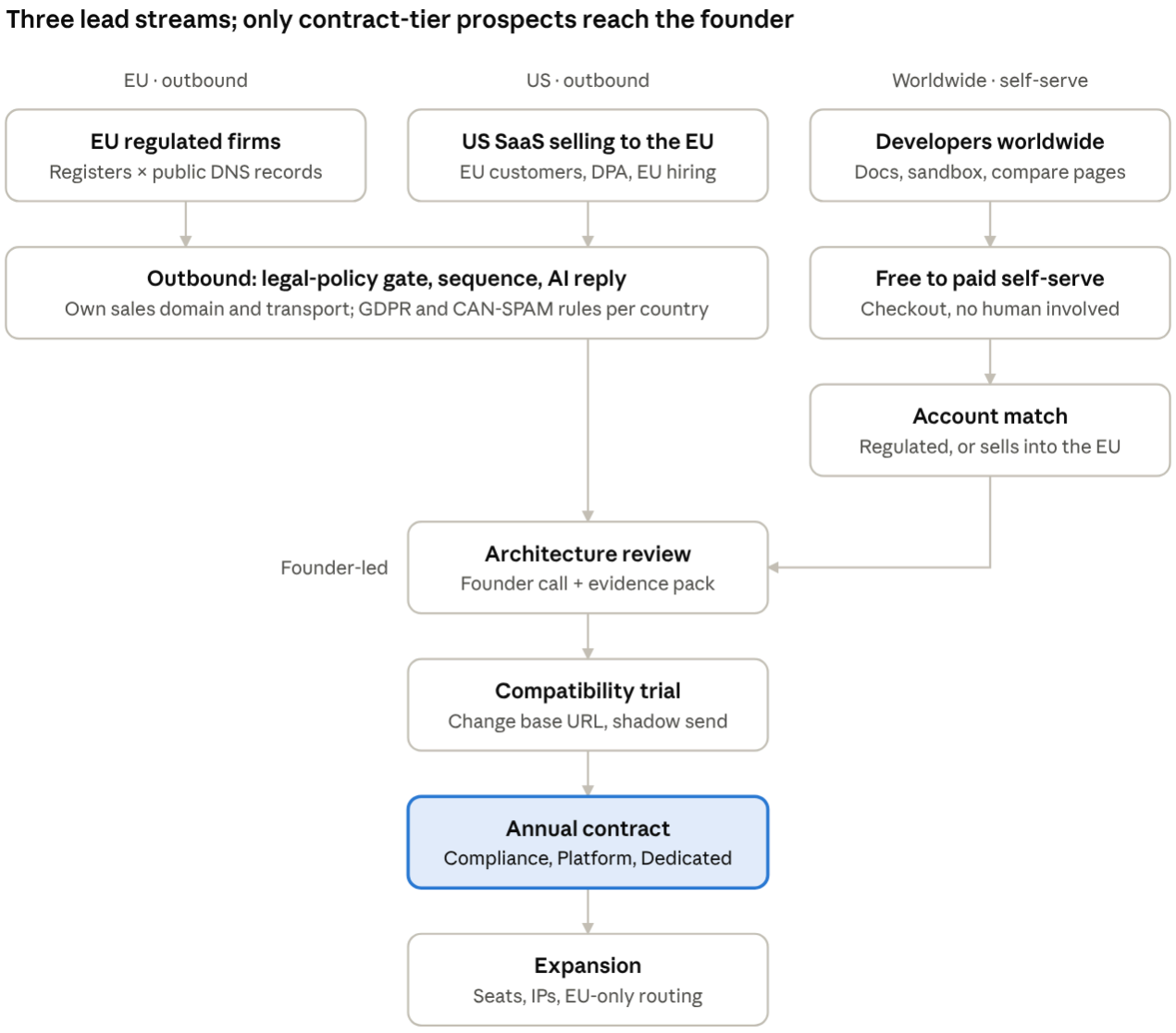
- The Estonian accounting service you already use; ask it to watch US state sales-tax thresholds as US revenue grows
- From the Scale mix on: a contracted on-call engineer and a part-time support contractor

The price cut on Developer (€29 to €20, and $20 in USD) costs little MRR. Self-serve's job is to feed upgrades and to put ApexMail in front of developers on both continents, not to carry the revenue.

Go-to-market engine

Three streams feed one founder-led review:

- outbound to EU regulated firms
- outbound to US SaaS companies that sell into Europe
- developers worldwide who find the product on their own



go-to-market flow · 3 lead streams, 1 founder-led review, 4 stages to expansion

Most self-serve accounts never reach the founder. Only those matched as regulated, or as selling into the EU, do.

- **EU targets.** Take the national registers of licensed payment, e-money, investment and insurance firms. Join them with each firm's public SPF and DKIM records, which name its current email provider. The offer: "Your DORA register lists a US email processor. Switch to EU-only routing by changing one base URL. We supply your register entry and exit plan."
- **US targets.** Look for US SaaS companies with EU customers: an EU residency or DPA page, EU customer logos, EU job postings, an EU subsidiary. The offer: "Pass your European customers' security reviews. Route their mail EU-only from the same account, and hand them our evidence pack."
- **Developers worldwide.**

  - Migration pages for SendGrid, Mailgun, Postmark and Resend; the comparison pages already exist.
  - The compatibility layer, so switching is a base-URL change.
  - The TypeScript SDK and the $20 Developer plan.
- **Proof before outbound starts.**
  - Five design partners, at least one of them in the US, at a discount in exchange for a logo and a case study.
  - Real status history.
  - One published deliverability report for each routing mode.
- **Partners.** EU DORA and GDPR consultancies, and US advisers who help SaaS companies sell into Europe. Both need the evidence pack more than the email itself.

The full specification is in `Sales engine` : segments, scoring, hooks, sequences, legal rules per country, infrastructure and guardrails.

Solo-founder operating model

The founder only does work that closes or keeps a contract-tier account. Everything else runs on what the repo already has, or is contracted out.

Function	Handled by	Founder involvement
Prospecting, EU and US	Sales autopilot (discovery, enrichment, legal-policy gate, sequences) on its own domain and transport	Approves target lists and sequences
First response to leads	Instant response already exists: lead, grounded draft, approval, priority-100 send. WP F9 lets low-risk reply classes send without approval	Spot-checks
Demos	Server-driven demo sessions with viewer links (/cp/demos), plus the live API sandbox and grader	Joins only contract-tier calls
Onboarding	Compatibility layer, importer, DNS auto-verify	None on self-serve; one call for contract tiers
Level 1 support, around the clock	Grounded AI chat in console and docs	Reviews escalations

Function	Handled by	Founder involvement
Level 2 support	Founder in CET hours, then a part-time contractor from the Scale mix	Hours per week tracked as a ceiling signal
On-call	Alerting, observability and auto-rollback	Founder first; contracted on-call from the Scale mix
Compliance and security reviews	Evidence packs, routing receipts, SIG/CAIQ answers generated from the claims registry	Signs and does the final review
Accounting, VAT and US sales tax	Accounting automation, the Estonian accounting service, and US sales-tax calculation once WP C2 adds it	None
Dedicated Tenant operations	Same pipeline and images, one host group per tenant	Monthly review per tenant

US time zones. From Tunis (UTC+1), US Eastern business mornings overlap your afternoons. Promise US contract customers support from 9:00 to 13:00 Eastern (15:00 to 19:00 your time). Self-serve users get AI support around the clock, plus next-business-day human replies. Contracted on-call covers nights once the Scale mix is reached.

The realistic solo ceiling is around 60 contract-tier accounts before contracted help is needed. Past that, the business stays founder-owned with contractors, not employees. Top-tier contracts should include source-code escrow and a named backup operator. Both EU and US buyers ask what happens if a single founder is unavailable.

Tech changes

The changes are specified as 41 work packages in `Work packages`, which is the only authoritative list. This table shows what each group is for.

Group	Purpose	Work packages
A — Risk fixes	Stop CI from endangering production; isolate sales sending; add a second host; make every public claim provable	A1–A6

Group	Purpose	Work packages
B — EU-sovereign offer	Routing modes, a hardened EU-only relay, signed receipts, a zero-US subprocessor chain, customer-held keys, the evidence pack	B1–B6
C — US customers	USD prices, US sales tax, a US DPA addendum, SOC 2	C1–C4
D — Switching	Compatibility endpoints for four providers, importer, SDKs, migration guides	D1–D4
E — Product lines	Catalog price changes, Platform, Dedicated Tenant provisioning, Mailboxes, archive, self-serve signals	E1–E6
F — Sales engine	Legal reach, discovery, signals, hooks, sequences, sending infrastructure, reply automation, contracts, experiments, autonomy	F1–F12
G — Kept surfaces	BYOC freeze, test-only security crates, locale build gate	G1–G3

Everything except BYOC stays and gets a job: IMAP and mailstore power Mailboxes (E4), the AI service powers support and reply automation (F9), ClickHouse feeds the provable public numbers (A4), and the security crates back security-review answers (G2).

Risks and signals

The biggest risk is deliverability on your own IPs. EU-only routing is worthless if Gmail and Microsoft put it in spam. The second is trust: EU-sovereign buyers will doubt a provider that also sends through SES, unless the separation is provable.

Risk	Signal to watch	What changes
Own-IP deliverability	Inbox placement on EU-only routing falls below Global routing on the same content	Slow the warmup, move to cleaner EU IP ranges or a second EU host, keep Global routing as the default for others

Risk	Signal to watch	What changes
Sovereign buyers doubt the separation	Security reviews ask how EU-only and SES traffic are kept apart	Separate IP pools and hosts for EU-only, signed receipts per message, the generated subprocessor list, an exit right in the contract
Hetzner port 25 or IP reputation limits	Unblock request refused, or a range listed on major blocklists	Run the relay on a second EU provider; it already binds source IPs
US deals stall on paperwork	Lost or stuck US deals that cite SOC 2 or the DPA	Bring SOC 2 forward; offer the US-ready DPA addendum
US state sales tax	US revenue crosses state thresholds	Register with the accounting service; compute the tax with WP C2
An EU rival copies the pitch (Lettermint, Scaleway, Brevo)	Lost EU deals naming them	Compete on what they lack: receipts, evidence pack, routing modes per subaccount, mailboxes, Dedicated Tenant, the compatibility layer
US rivals already offer EU regions (Resend, SendGrid, Mailgun; Postmark has none)	Lost deals where "EU region" was enough	Sell what a region cannot give: an EU company, EU law, no US processor, customer-held keys
Founder overload	Level 2 support and on-call together exceed the hours you can sustain	Bring in the contracted on-call and support help earlier
Outreach breaks a country's rules	Complaint or regulator letter	Tighten `legal_policy.rs` per country (Germany effectively requires prior consent even for B2B email; the US runs on opt-out under CAN-SPAM) and pause that country
Self-serve abuse hurts shared IP reputation	Complaint rate on shared pools rises	Stricter signup scoring, KYC on higher self-serve tiers

The plan holds while contract tiers bring in more than half of MRR. If self-serve ends up carrying most revenue, support load grows faster than one founder can absorb, and prices should move back up.

Sources

- Amazon SES pricing: $0.10 per 1,000 outbound emails
- Resend pricing: Pro $20 for 50,000 emails
- Lettermint pricing: built in the Netherlands, ISO/IEC 27001:2022, from €10/mo
- mailbox.org business plans: €4 and €12 per user
- Gartner survey via ChannelWeb: 61% of Western European CIOs
- AFM: DORA register of information: annual, xBRL-CSV, EBA taxonomy
- The ApexMail repository (sbelakho2/ApexMail): `docs/pricing.md`, `platform-catalog`, `compliance/src/deployment_products.rs`, `outbound-mta`, `enterprise/src/field_encryption.rs`, `api-server/src/config.rs`, `sales-autopilot/src/sender_pool.rs`, `partials/home/hero.html`, the commit log, and `docs/audit/`

Every factual claim in all tabs, with its file and line or its source page, is listed in Verification ledger.

Sales engine

The sales autopilot finds, contacts and converts contract-tier prospects in the EU and the US without the founder, until a qualified call. This tab is its specification; work package group F builds it.

Goal and scoreboard

The engine's job is to deliver qualified architecture-review calls for contract tiers, in the EU and the US, while keeping complaints below 0.1%.

Today it cannot send on its own. The default autonomy mode is `shadow` or `disabled` (migration `200_sales_autopilot_v2_unification.sql:985`). The only seeded EU policy row says `approval_required` for every send (`:1059`). No US policy row exists, so US sends fail closed. The engine itself is strong: decision gates, legal fail-closed, evidence-grounded copy, Thompson-sampling experiments, sender-health breakers and revenue attribution. Making it effective is mostly about feeding it: legal rows, data sources, signals, hooks and approved sequences.

Pipeline math (assumptions until measured). Rates per contacted account. Replace each with the measured value from `sales_outcomes` once 1,000 accounts per segment have been contacted.

Stage	EU regulated	US SaaS selling into the EU	Measured by
Any reply	6%	5%	`attribution.rs` outcome `reply`
Positive reply	2%	2%	`positive_reply`
Meeting booked	1.2%	1.0%	`meeting_booked`
Contract signed	0.3%	0.25%	`paid_subscription`

At these rates, reaching the Scale mix's 62 contract accounts takes about 21,000 contacted accounts. That is why discovery breadth (F2) and legal reach (F1) matter more than copy.

Guardrail metrics. Each one pauses the affected sender or segment automatically when breached.

Metric	Limit	Why this number
Spam complaint rate, per sender and per segment	Below 0.1%	Gmail recommends staying below 0.10% and enforces 0.30%. SES puts accounts under review at 0.1%
Hard bounce rate	Below 2%	SES recommends below 2% and reviews at 5%
Unsubscribe processing	Immediate	CAN-SPAM allows 10 business days. The engine stops instantly
Human replies that get another automated touch	0	Release gate in `decision_engine.rs`

Weekly scoreboard. The control plane shows these by segment, country and experiment arm:

- accounts contacted
- positive replies
- meetings booked and attended
- trials
- contracts signed
- MRR added
- complaint and bounce rates
- MRR by discovery source (from `attribution.rs`)

Autonomous loop

Target: the engine finds, contacts, answers, demos, closes and onboards without the owner, who handles only exceptions defined in advance. It gets there one action class at a time, on evidence (F12, S20), never by flipping a switch. Redesigned 22 Oct; CAPTCHA bypass is out of the design entirely (S10).

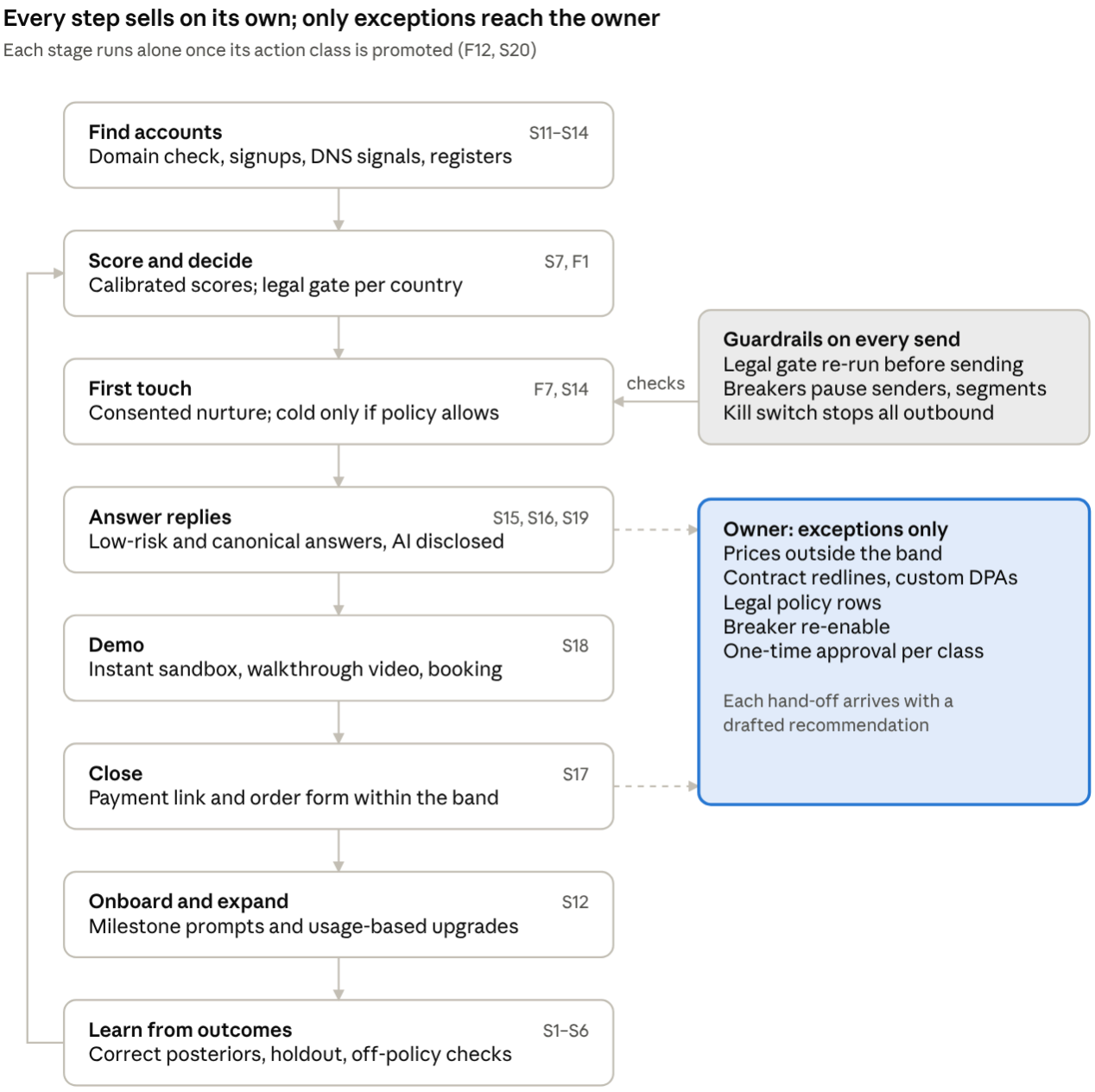
Runs alone once promoted:

- finding accounts and reading their sending stack (S13);
- first touches and follow-ups where the country's policy row allows them, and consented or product-led nurture everywhere (S11, S12);
- replies in the five existing low-risk classes, plus canonical pricing and legal-fact answers (S15);
- security questionnaires answered from the evidence bank (S16);

- instant sandbox demos and call booking (S18);
- payment links and offers inside the owner's price band (S17);
- onboarding (S22); expansion offers, renewals and churn rescue inside the price bands (S12, S23); and referral credits and partner payouts, prepared for one monthly approval (S24).

Stays with the owner: legal policy rows; approving each policy pack version (S21); re-enabling a tripped breaker; any price outside the band; contract redlines and non-standard DPAs; the one-time approval of each new action class; and, optionally, vetoing a scheduled promotion. The kill switch (`autonomy = disabled`) stops all outbound actions at once.

Every autonomous message carries a one-line AI disclosure (EU AI Act Art. 50(1), in force since 2 Aug 2026). Its audit row keeps the draft, the classifier verdict, the cited evidence or canonical-answer ids and the model version (S19).



autonomous selling loop · 8 stages, guardrails, owner hand-offs

Solid arrows are the automated path. Dashed arrows hand an exception to the owner. Outcomes from every stage feed the learning step, which updates scores and experiment arms.

Sources, strongest intent first. The first two need no cold email at all, which is what makes Germany reachable.

Rank	Source	Yields	Legal basis and limits	WP
1	Public domain check on the website	A domain, its sending stack and a contact who asked for the report	Consent on the form, with a separate unticked box for news; lawful in every target country	S11
2	Signups, trials and sandbox use	Product-qualified accounts with usage milestones	Contract with the signed-up user; only that user gets lifecycle email; colleagues never enter cold sequences	S12
3	Sending-stack signals on a domain universe	Accounts on SendGrid, Mailgun, SES or Postmark, their DMARC posture and US-processor exposure	Company-level DNS data. Domains come from Certificate Transparency logs, the Tranco top-sites list and website fields in open business registers, each used under its licence	S13
4	Trigger events	Competitor outages and price changes (public status pages, changelogs), hiring posts naming an email provider or DORA work (official public job-board APIs), register filings	Public company information. A trigger raises a score and never proves a claim alone (S8)	F5, S13
5	Contacts for scored accounts	Role addresses from public pages; named people from a licensed EU data provider or the person's own professional publication	The country's policy row decides. Article 14 notice in the first message. Germany: consent only. No SMTP probing to test addresses	S14, F1
6	Operator-listed public pages	Role addresses and company facts	robots.txt and CAPTCHAs honoured; a refusal excludes the host	S10

Answers without the owner (S15, S16). A pricing or legal question gets an automatic answer only from a canonical answer: a versioned text the owner approved once, rendered from its source of truth. Prices come from `platform-catalog`; subprocessors

and data locations from the generated subprocessor register; terms from the published legal pages, pinned by content hash. A draft that mentions price or a legal term may send itself only when every such sentence cites a canonical-answer id; otherwise `PRICING_MARKERS` and `LEGAL_MARKERS` still route it to the owner. When a source changes, its answers stop sending until re-approved. Security questionnaires (CAIQ first, which the Cloud Security Alliance publishes free) are filled from the B6 evidence bank, and unanswered questions reach the owner as one batch.

Closing without the owner (S17). The owner sets price bands once: plan, term, maximum discount, minimum commitment. Inside a band the engine sends an Adyen payment link for a catalog plan, plus an order form and the standard DPA rendered by `pdf-renderer` and accepted by click in the console. Annual invoices come from accounting-core. Anything outside a band, any redline and any non-standard DPA goes to the owner with a drafted recommendation and its evidence.

Demos without the owner (S18). A demo request gets three options in one reply: an instant sandbox tenant (test domain, sample templates, a key that sends only to a sink), a three-minute recorded walkthrough per segment, and a booking link for a live call with a generated brief. Sandbox activity feeds the product-qualified score.

Speed. Inbound leads get a first reply within 5 minutes at p95, day or night (S9). A buyer who asks a price question at 23:00 gets the answer and a payment link at 23:05, not the next morning.

Approve rules once (S21). A policy pack bundles, for one segment, the legal bases, sequence versions, canonical answers, price bands, daily caps and complaint ceiling the owner approved. The engine acts only inside an active pack and holds everything else with reason `outside_pack`. When anything a pack references changes, the pack suspends until it is re-approved. This turns "approve every message" into "approve a few pages a quarter".

After the sale (S22–S24). Onboarding is tracked per tenant from domain added to the first 10,000 sends, and stalls are nudged automatically. Usage triggers in-band add-on offers; renewal notices go out at 60, 30 and 7 days; a churn-risk score triggers a rescue offer, never a block on cancelling. Referral credits and partner revenue share are computed per paid invoice, and the owner approves one payout batch a month.

Autonomy ladder (S20). Each action class climbs on its own evidence and falls back automatically. A class that clears its bar is promoted after a 48-hour veto window, announced in the daily digest (S20). "F9 bar" means the existing promotion gate in `reply_autosend.rs`: 20 owner approvals (10 at minimum) inside a 30-day window (7–90), and zero complaints or opt-outs for the tenant in that window. Guardrail metrics are the ones in the table above.

Action class	Today	Target	Promotion evidence	Falls back when
Discovery and stack reading	Shadow	Autonomous	Signal precision measured on 200 labelled domains (S8)	Weekly sample precision drops below the S8 threshold
Consented and product-led nurture	Not built	Autonomous	A stored consent or contract basis per contact; F9 bar	Opt-out or complaint rate breaches its guardrail
Cold first touch where policy allows	Approval required	Autonomous, guarded	F9 bar per segment and language; drafts approved without content edits	Any guardrail breach in the segment, or a policy-row change
Follow-ups in a running sequence	Approval required	Autonomous	F9 bar on the sequence	Same as first touch
Five existing low-risk reply classes	Approval required	Autonomous per class	F9 bar	Complaint or opt-out attributed to the class
Canonical pricing and legal answers	Owner	Autonomous per class	F9 bar; every source hash current	A source hash changes, or a buyer disputes an answer
Security questionnaire answers	Owner	Autonomous per question family	F9 bar; every answer cites evidence	A cited evidence item expires
Sandbox demos and call booking	Scheduling class only	Autonomous	F9 bar; sandbox isolation test green (T5)	The isolation test fails

Action class	Today	Target	Promotion evidence	Falls back when
Payment links inside the band	Not built	Autonomous	Owner has set the band; F9 bar	Any chargeback or a refund request on an autonomous deal
Onboarding nudges	Not built	Autonomous	F9 bar; S22 state-machine test green	A nudge draws a complaint
Expansion, renewal and rescue offers	Not built	Autonomous	Owner has set the band; F9 bar	A refund request or complaint on an offer
Out-of-band prices, redlines, policy rows, breaker re-enable	Owner	Owner	—	—

Segments and signal sources

Six segments, each with a public or first-party source for its account list and a measurable buying signal.

ID	Segment	Where the account list comes from	Lead offer
S1	EU payment and e-money institutions	EBA central register under PSD2: free search, full download, JSON specification, updated at least daily by national authorities	DORA evidence pack + EU-only routing
S2	Other EU regulated firms (banks, insurers, investment firms)	National supervisors' public registers, only where their reuse terms allow it	Same as S1
S3	EU SaaS and SMEs on US email providers	First-party data (signups, sandbox runs, grader checks) plus an approved data provider	EU company, fair price, switching in one line

ID	Segment	Where the account list comes from	Lead offer
S4	US SaaS selling into the EU	Approved data provider, filtered on public EU signals: an EU DPA or residency page, an EU entity, EU job postings	EU-only routing for their EU customers
S5	Platforms sending for their own customers	Approved data provider plus DNS evidence of many customer domains	Platform tier, per-subaccount routing
S6	Existing free and self-serve tenants	First-party product events	Upgrade, or Compliance tier when regulated

The EBA register's own disclaimer says it has no legal effect and that national authorities own its accuracy. Treat it as discovery input, not proof of a firm's status. Discovery code must keep refusing scraping (`discovery/mod.rs`), and every source must declare the jurisdictions it may return data for. The job runner already enforces that declaration.

Signals, and which scoring dimension each feeds

Signal	Source	Feeds	Decay
Current email provider	SPF includes, DKIM selectors and MX records (`signals/email_stack.rs`)	`email_stack_fit`	None while DNS is unchanged
Deliverability gaps: no or weak DMARC, no MTA-STS, no TLS-RPT, blocklisting	`email-grader` crate	`need_fit`	Re-check every 30 days
Incident at the detected provider	The provider's public status page feed	`timing`	Half-life 7 days
New authorisation or register change	Daily EBA register delta	`timing`	Half-life 30 days
Sells into the EU (S4)	Public DPA or residency page, EU entity	`eu_residency_fit`	Re-check every 90 days

Signal	Source	Feeds	Decay
Product activity: signup from a target domain, quota above 80%, grader run	First-party events	`intent`	Half-life 14 days

Provider detection gaps to close (WP F3). `email_stack.rs` already recognises SendGrid, Mailgun, Postmark, SES, SparkPost, Mandrill, Mailchimp, HubSpot, Microsoft 365, Google Workspace and Zoho. Add these patterns, each taken from the vendor's own setup docs:

- **Resend:** a DKIM TXT at `resend._domainkey`, plus a `send` subdomain whose SPF includes `amazonses.com` and whose MX is `feedback-smtp.<region>.amazonses.com`. Today Resend customers are misread as plain SES.
- **Mailjet:** an SPF include of `spf.mailjet.com` and a DKIM record at `mailjet._domainkey`.
- **Brevo:** no SPF include is needed. Detect it from a DMARC `rua` of `rua@dmarc.brevo.com` and from DKIM CNAMEs that point at Brevo.

The module's own confidence rules still apply. One hint yields "may use", two independent hints yield "likely uses", and confidence never exceeds 0.95. Copy must say "your DNS points to X", never "you use X".

Scoring

Keep the existing explainable score in `scoring.rs`, and shift weight toward the signals ApexMail sees and generic CRMs do not. The formula stays as implemented:

```
\text{total} = \operatorname{clamp}\Big(\sum_{d} \operatorname{round}(w_d \cdot s_d) - \operatorname{round}(0.20 \cdot \text{risk}),\ 0,\ 100\Big), \quad s_d \in [0,100]
```

Dimension	Weight today	Proposed weight	What changes
`account_fit`	0.18	0.16	—
`persona_fit`	0.12	0.10	—
`need_fit`	0.13	0.15	Adds grader gaps (F4)
`intent`	0.08	0.08	Adds product events (F5)

Dimension	Weight today	Proposed weight	What changes
`timing`	0.11	0.12	Adds provider incidents and register changes (F5)
`email_stack_fit`	0.10	0.12	Adds Resend, Mailjet and Brevo detection (F3)
`eu_residency_fit`	0.05	0.08	Feeds S1, S2 and S4 directly
`reachability`	0.10	0.08	—
`evidence_quality`	0.05	0.05	—
`legal_contactability`	0.08	0.06	The legal gate stays a hard gate whatever the score
`risk` (penalty)	0.20	0.20	—

Both weight sets sum to 1.00 across the ten positive dimensions. The reason-code identity in `scoring.rs` (reason-code points sum exactly to the total) must keep holding.

Action thresholds

- **Score 70 or more:** enrol in the segment's sequence.
- **50 to 69:** product-led touch only (report link, newsletter opt-in). No cold sequence.
- **Below 50:** no outreach. Re-score when a new signal arrives.

How to change the weights safely (WP F6)

1. Implement the new weights as a challenger policy.
2. Run `simulation.rs` replay and champion/challenger shadowing on at least 500 historical decision points.
3. Promote only if the challenger's agreement with realised positive outcomes is at least as good as the champion's, and its expected complaint exposure is not higher.
4. Record the promotion in the promotion registry.

Until 500 real outcomes exist, the change ships in shadow mode only.

Offers and hooks

Every first email leads with something useful about the prospect's own domain, computed by ApexMail. Generic cold email gets ignored; a correct finding about someone's DMARC does not.

ID	Hook	Built from	Fires when	Segments
H1	Free domain audit: "we checked your domain, here are 2 findings" plus a report link	`email-grader`: SPF, DKIM, DMARC, BIMI, MTA-STS, TLS-RPT, blocklist checks	At least one real gap was found	All
H2	Provider incident: "your DNS points to X; X reported an incident on [date]" plus a link to X's own status page	Provider status feed plus `email_stack.rs` evidence at "likely uses" level	Within 72 hours of an incident that affected sending	S1–S5
H3	DORA register entry: ApexMail's pre-filled entry for their register of information, plus an exit plan	Evidence pack generator (WP B6)	The account is in the EBA or a national financial register	S1, S2
H4	EU-only routing for your EU customers, from the same account	Routing modes (WP B1)	A sells-into-EU signal exists	S4, S5
H5	Switch by changing one base URL	Compatibility layer (WP D1)	Provider detected and listed in D1	S3–S5
H6	In-product upgrade or Compliance offer	First-party events	Quota above 80%, or a regulated-domain match	S6

Rules for every hook

- Each fact in the email must exist as a `sales_evidence` row. `personalization.rs` already drops unevidenced claims; never bypass `validate_strategy`.
- H1 report pages use an unguessable signed link, expire after 30 days, and show only what public DNS returned. No signup is needed to read them.
- H2 states only what the vendor's own status page said, links to it, and never claims the prospect was affected.
- H3 and H4 are only used once their WP is Done; until then, those arms stay disabled in the experiment registry.

- Use the recipient's country language for EU recipients (EN, DE, FR or ES) and English for everyone else. Content is generated from approved templates, never free-written per prospect.

Sequences

One sequence per segment, four email touches, email only.

Automating LinkedIn or other platforms is out of scope: it breaks their terms and the decision engine cannot gate it. Sequences are versioned and immutable once active. They only run after the owner approves them (`sequences.rs`).

Step	Day	Content	Must contain
1	0	The hook (H1–H5) with 2 evidence-backed facts and one link. Under 120 words, plain text	Sender identity, data source line, opt-out
2	3	One new fact (a second grader finding, or the H5 switching line). Under 80 words	Same footer
3	8	Proof: a signed routing-receipt sample or a case study. Under 80 words	Same footer
4	16	Close the loop: "should I stop here?" Under 50 words	Same footer

Stop rules, enforced by the decision engine and account coordination:

- Any human reply stops the sequence.
- An unsubscribe or complaint stops the whole account (rule R1).
- A "not interested" reply starts the cooldown (R2).
- A hard bounce stops that contact.
- Only one active contact per account, unless the account is at a multi-thread tier (R4, R5).

Send windows. Tuesday to Thursday, 08:30–11:00 in the recipient's local time zone. `calendar/timezone.rs` already resolves zones.

Step 1 template, segment S1, English master (DE, FR and ES versions are translated from this and approved separately):

```
Subject: {domain}: 2 findings from a public DNS check

Hi {first_name},

We ran a public DNS check on {domain}:
- {finding_1}
- {finding_2}
Full report, no signup: {report_link}

Your DNS also points to {vendor_hint}. If that service is in your DORA
register of information, we can provide an EU-only alternative, with a pre-
filled register entry and an exit plan.

Worth a 20-minute review? {booking_link}

{sender_name}, ApexMail
—
ApexMail is a brand of Bel Consulting OÜ, Sakala 7-2, 10141 Tallinn, Estonia.
We found your work address via {data_source}. One click stops all our emails:
{unsubscribe_link}
```

For US recipients the footer also states that this is a commercial message, as CAN-SPAM requires. It keeps the postal address and the one-click opt-out.

The placeholders `{finding_*}`, `{vendor_hint}` and `{data_source}` may only be filled from evidence rows. A missing value removes the line; it is never filled with a guess.

Legal rules per jurisdiction

The rules differ sharply by country, and the code does not yet model that.

`legal_policy.rs:40` maps every EU and EEA country to one `EU` key. Its rule table cites the Estonian Electronic Communications Act §103[1]. But Germany requires prior consent for B2B email, while France and the UK do not for company recipients. WP F1 adds per-country keys that take precedence over the `EU` fallback. This is not legal advice: each row below is a draft for counsel. **The owner approves every row** (invariant 5).

Key	Rule for email to a named employee at a company	Source	Draft row
FR	No prior consent needed if the message relates to the recipient's profession, names the sender, and offers a simple opt-out. Generic addresses (contact@, info@) fall outside these rules	CNIL	`allowed`, basis `legitimate_interest`, condition: offer matches the recipient's role
DE	Email advertising without prior express consent is an unreasonable nuisance (UWG §7(2) Nr. 2). Exception only for existing customers buying similar products (§7(3))	UWG text	`not_permitted` unless consent evidence exists. Germany is reached through inbound and product-led channels only
GB	Corporate subscribers may be emailed without consent. Sole traders and some partnerships count as individuals and need consent. Identity and an opt-out are always required	ICO	`allowed` only when the subscriber type is evidenced as a corporate body, never inferred from the domain
US	CAN-SPAM applies to B2B, without a consent requirement. It requires accurate headers, a non-deceptive subject, disclosure that the message is an ad, a postal address, and opt-out honoured within 10 business days. Penalty: up to $53,088 per email	FTC	`allowed` with the CAN-SPAM footer variant

Key	Rule for email to a named employee at a company	Source	Draft row
EE	Legal persons may be contacted on legitimate interest with a free, easy refusal (the repo's current basis)	Estonian ECA §103[1], as cited in `legal_policy.rs`	Keep, with counsel confirming the wording
All others	No row → the engine fails closed to `approval_required`	`legal_policy.rs`	Draft per country from that country's regulator page before enabling

Two rules apply everywhere in the EU and UK. Business contact data is personal data under GDPR, so:

- keep a written legitimate-interest assessment per segment
- name the data source in the first email (the template's `{data_source}` line)

The engine already refuses to infer `LegalPerson` from a work email address (`legal_policy.rs:61`). Keep it that way: subscriber type must come from evidence such as register data.

Outbound sending infrastructure

Sales mail runs on infrastructure that shares nothing with customer mail. Pool separation already exists in the database (`sender_pool.rs`: pools `sales_outbound` and `sales_warmup`, enforced by a CHECK constraint). What is still shared is the transport, which is deployment-wide. WP A2 removes that.

Layer	Setup	Owner or agent
Domains	Two or three separately registered domains, clearly branded ApexMail. Each has a one-page site with the company imprint. Never `apexmail.ee` itself	**Owner** buys; agent configures DNS
Transport	The `outbound-mta` relay, with a dedicated sales IP range that no customer pool uses. Not the customer SES account	Agent (A2, F8)
Authentication	SPF and DKIM on every domain, DMARC from `p=none` to `p=quarantine` once reports are clean, valid PTR, TLS	Agent

Layer	Setup	Owner or agent
Unsubscribe	`List-Unsubscribe` plus `List-Unsubscribe-Post: List-Unsubscribe=One-Click` (already set in `dispatcher.rs:1348`) and a visible link in the body	Already done; keep it
Address checks	Verify reachability before the first send. Drop role addresses where the country's row requires it	Agent (F2)
Volume caps	Per sender identity: start at 20 a day, raise 20% a day while complaints stay below 0.1% and hard bounces below 2%, cap at 150 a day. The cap is enforced through `sales_sender_daily_usage` reservations	Agent (F8)
Health breaker	Lower the sales-pool complaint quarantine from 0.3% to 0.1%. Keep 0.3% for customer pools	Agent (F8)

Gmail's rules for any sender include SPF or DKIM, valid PTR, TLS, RFC 5322 formatting and a spam rate below 0.30%. Above 5,000 messages a day to Gmail it also needs SPF and DKIM together, DMARC with alignment, and one-click unsubscribe. Microsoft applies similar requirements to high-volume senders to Outlook.com and rejects failures with `550 5.7.515`. Sales domains meet the bulk-sender rules from day one, whatever their volume.

After a reply

Most of the reply machinery already exists. The gap is that every answer waits for a human, and the objection library is empty.

What exists (verified)

- The MTA fills the reply-pipeline columns on inbound mail (commit `f22381b`).
- A reply classifier with 11 dispositions (positive, meeting_request, question, referral, not_interested, unsubscribe, complaint, ooo, bounce_hard, bounce_soft, unknown), six objection sub-labels (price, timing, competitor, authority, trust, need) and a 0.7 confidence gate (`POST /reply/classify` on ai-service).
- A draft-only mailbot grounded in the canonical facts (`0cace0d`).
- Instant response: each lead gets a first-response request; the approved draft is sent at queue priority 100 (migration 241, `4c3e60d`).

- An objection taxonomy and library, approved like legal rows; **nothing is seeded yet** (migration 242, `0b962ed`).
- Server-driven demo sessions with expiring viewer links (`/cp/demos`, migration 243, `2bc19bd`).
- Calendar availability for Google and Microsoft (`calendar/`).

Routing by classification

Classification	Action	Human needed?
Meeting request or positive	Send 3 slots in the prospect's time zone plus a booking link; create a demo session	No, after F9 promotion
Question answerable from canonical facts	Grounded answer	No, if every F9 condition holds; otherwise draft for approval
Objection with an approved library entry	Library-grounded answer	Yes, until that objection class passes F9 promotion
Pricing negotiation, contract terms, legal or security questions	Draft, and alert the founder	Always
Not interested	Cooldown (R2), no reply	No
Unsubscribe or complaint	Stop the account (R1), confirm the opt-out once if the country requires it	No
Out of office	Reschedule the next step after the return date	No
Referral	Enrol the referred contact (R6)	No

F9 auto-send conditions (all must hold)

- The classifier's confidence is at least 0.9.
- The verifier marks every factual sentence as supported by canonical facts.
- The draft contains no price other than catalog list prices, no discount, and no contract or legal term.
- The class has passed shadow promotion: 200 or more drafts, with the owner editing fewer than 5%.

From call to contract

1. Before the call, the founder gets a one-page packet: evidence, the score with its reason codes, the thread, and the classified objections.
2. After the call, one click generates the order form, DPA and evidence pack as Typst PDFs, priced from the catalog.
3. The customer accepts by click on an audited page. A qualified e-signature is optional, never required.
4. The invoice is created automatically and charged through Adyen (card or SEPA Direct Debit), or sent as a bank-transfer invoice.
5. Security questionnaires are pre-answered from the procurement package (`compliance/src/procurement_package.rs`, `security_questionnaires.rs`), and the owner reviews them.

Experiments and learning loop

Superseded in part (16 Oct audit). Work packages S1–S6 in `Work packages` replace this section where they conflict:

- one binary primary outcome per contact, instead of the reward ladder in the posterior
- planned sample sizes, instead of "400 sends per arm"
- a randomized holdout
- off-policy evaluation
- partial pooling

The guardrails below still apply.

The optimizer already sits in the send path. `ExperimentEngine::select_variant` picks an arm before dispatch, and each outcome feeds the posterior through the reward ladder in `experiments.rs`:

Outcome	Reward
Click	0.05
Reply	0.2
Positive reply	0.5
Meeting booked	0.7
Meeting attended	0.8
Trial	0.9

Outcome	Reward
Paid subscription	1.0
Retained MRR	1.2

Opens score zero, so no arm can win on opens alone.

What to test, in this order (one dimension at a time per segment):

1. Hook: H1 vs H2 vs H3/H4 vs H5.
2. Call to action: "20-minute review" vs "reply 'report' for the full audit".
3. Length: under 80 words vs under 120.
4. Language for non-native EU markets: English vs the local language.

Promotion and kill rules

- Use the exploration budgets in `sales_experiments.budgets`. Never leave exploration unbounded.
- Pause any arm whose complaint rate is above 0.2% after 300 sends.
- Keep an arm in the running until 400 sends per arm and segment. Then promote the arm with the highest posterior mean reward.
- Re-test the champion against one new challenger at a time.
- Objection classes are already an experiment dimension (`d66c7bf`). Use them to test library answers once entries exist.

Every promotion, of weights, arms or autonomy, is recorded in the simulation promotion registry, with the replay result that justified it.

Guardrails

The engine is aggressive about coverage and speed, never about the rules below. Each one maps to an existing gate or a WP that adds it.

1. **No send without a fresh legal verdict.** `revalidate_execution` re-runs every hard gate right before sending. Keep that path; never add a second send route.
2. **No unevidenced claim.** Every fact traces to a `sales_evidence` row, and `validate_strategy` drops the rest.
3. **No deception.**
   - Subjects describe the content.
   - The sender is ApexMail, with Bel Consulting OÜ's postal address.
   - No fake replies ("Re:"), no false familiarity, no invented urgency.

4. **One person per account at a time**, unless the account is at a multi-thread tier (R4, R5).
5. **Instant stop.** Unsubscribes, complaints and human replies stop sending immediately, and an unsubscribe stops the whole account.
6. **Shared kill switch.** Setting autonomy to `disabled` stops all new outbound actions at once; inbound reply handling continues (`autonomy.rs`).
7. **No customer data in sales.** Product telemetry of paying tenants may trigger only in-product messages (H6), never cold sequences to their colleagues.
8. **Breaker first.** A sender or segment breaching a guardrail metric pauses automatically. A human re-enables it, after the cause is written down.

Work packages

Each work package is a unit an agent can take, finish and prove. They are ordered by dependency, never by date.

How to run a work package

Every WP below has the same five parts. Do them in order, and stop at any **Owner** step.

- **Now:** what the repo does today, with file and line at commit `1987043`. Re-check this at HEAD before starting. If it differs, fix the ledger row first.
- **Do:** the changes, in order.
- **Done when:** acceptance criteria. Each must be provable by a test, a command output or a production check.
- **Verify:** the commands to run, on top of the generic definition of done in the Plan tab.
- **Owner:** decisions or purchases the agent prepares but never makes.

Status values in the index:

- **Not started**
- **In progress**
- **Blocked (owner):** waiting on an Owner step; the prepared material is linked in the WP
- **Done:** all criteria met, with evidence

When a WP is Done, add a line under it: `Evidence: <commit SHA> · <test names> · <production check>`.

Paths are relative to the repo root. `crates/` means `services/mail-server/crates/` and `migrations/` means `services/mail-server/migrations/`. Migrations run to 268 at commit `a2f3b08` (22 Oct); new migrations start at `269`.

Index

112 work packages in eleven groups. Statuses below are from the 22 Oct audit at `61e3db3`, except group F, which was not assessed and is left blank; group V comes from the Deep review tab. Do H2, S10, S19, T1, V1, V6 and V24 first, plus the owner steps in H3, V1 and V6; then follow the dependencies.

ID	Work package	Depends on	Unlocks	Status
H1	Restore self-service cancellation under Adyen	—	Any paid customer	Done
H2	Correct Adyen's facts on legal pages, and gate them	—	B4, outreach	In progress
H3	Wire Adyen into production; live account	—	Paid checkout, C1, E1	Blocked (owner)
A1	Move CI and tests off the production host	—	A3, C4	In progress
A2	Separate sales sending from customer transport	—	F8, S9	Done
A3	Second production host and failover	A1	99.9% SLA, E3	Not started
A4	Make every public claim provable	—	Outreach, D4	In progress
A5	Automated restore drills	—	C4	Not started
A6	Re-verify September-audit fixes on production	—	Security reviews	Not started
B1	Routing policy per tenant, subaccount and domain	—	B2, B3, B4, E2, hook H4	In progress
B2	Production-harden the EU-only relay	B1	EU-only routing for customers	In progress
B3	Signed routing receipts	B1	B6	Done
B4	EU-only subprocessor chain and generated list	B1, H2	B6	In progress
B5	Customer-held encryption keys	—	Compliance tier	Not started

ID	Work package	Depends on	Unlocks	Status
B6	Evidence pack generator	B3, B4	Hook H3, F10	In progress
C1	Multi-currency catalog (USD)	H3	C2, E1	Done
C2	US sales tax calculation	C1	US checkout	Blocked (owner)
C3	US DPA addendum	—	US contracts	Blocked (owner)
C4	SOC 2 readiness	A1, A5	US mid-market deals	Not started
D1	Compatibility endpoints for four providers	—	D2, hook H5	In progress
D2	Importer and shadow-send verifier	D1	D4	In progress
D3	SDKs generated from OpenAPI, published	—	Developer adoption	In progress
D4	Migration guides per provider	D1, D2, A4	Self-serve switching	Done
E1	Catalog price changes and new plans	C1, H3	E2, E4, F10	Done
E2	Platform tier features	B1, E1	Platform line	In progress
E3	Dedicated Tenant one-command provisioning	A3	Dedicated line	In progress
E4	Mailboxes as a product	E1	E5	In progress
E5	Archive and journaling	E4	Archive add-on	In progress
E6	Self-serve match signals	F2	Hook H6	Not started
F1	Per-country legal policy keys and draft rows	—	F7, F12	▾
F2	Discovery sources	—	F4, F5, E6	▾
F3	Provider detection additions	—	F5, F6	▾
F4	Domain-audit hook	F2	F6, hook H1	▾

ID	Work package	Depends on	Unlocks	Status
F5	Trigger signals	F2, F3	F6, hook H2	▾
F6	Scoring weights challenger	F3, F4, F5	Better targeting	▾
F7	Sequences, templates, objection library	F1	F9, F11, F12	▾
F8	Sales sending infrastructure	A2	F12	▾
F9	Reply auto-send promotion	F7	F12	▾
F10	Call-to-contract automation	E1, B6	Closing without delay	▾
F11	Experiment program and scoreboard	F7	Learning loop	▾
F12	Autonomy promotion gates	F1, F7, F8, F9	Autonomous outbound	▾
G1	BYOC freeze	—	—	Not started
G2	Decide on test-only security crates	—	Accurate claims	Not started
G3	Locale build gate	—	Clean EU sites	Done
S1	Exposure-correct bandit posterior	S2	S4, S6	Not started
S2	One primary metric with fixed windows	—	S1, S5, S7	Not started
S3	Randomized account-level holdout	—	S7 uplift, causal lift	Not started
S4	Logged propensities and off-policy evaluation	S1	S6, S7, F6, F9	Not started
S5	Experiment registry, power and sequential tests	S2	Every conclusion	Not started

ID	Work package	Depends on	Unlocks	Status
S6	Hierarchical partial pooling for contexts	S1, S4	Faster small-segment learning	Not started
S7	Learned, calibrated scores, then uplift	S2, S4 (S3 for uplift)	Better targeting	Not started
S8	Truth measurement for inferences and copy	—	Trusted hooks	Not started
S9	Speed and throughput targets	A2, S2	Coverage and speed	Not started
S10	Remove the CAPTCHA-solver hook; lawful sourcing	—	Legal exposure removed	Not started
S11	Public domain check as the consented lead source	—	Leads in Germany, S12	Not started
S12	Product-qualified leads and lifecycle	S7	Expansion revenue, S17	Not started
S13	Domain universe, registers and trigger feeds	F2, F3	F5, F6, S14	Not started
S14	Lawful contact sourcing	F1, S10	F7, cold outreach	Not started
S15	Canonical answers for price, legal and location	E1, B4, F9	S17, S20, T17	Not started
S16	Security questionnaires from the evidence bank	B6	Mid-market deals	Not started
S17	Deal desk: price bands, payment links, order forms	H3, E1, F10	Closing without the owner	Not started
S18	Instant demo: a sandbox in the reply	T5	Demos without the owner, S12	Not started
S19	AI disclosure and audit for autonomous messages	—	S20, T17	Not started

ID	Work package	Depends on	Unlocks	Status
S20	Autonomy ladder with automatic demotion	F12, S2, S4	Autonomous selling	Not started
S21	Policy packs: approve rules once, not messages	F1, F7, S15, S17	S20, S24, selling without per-message approval	Not started
S22	Onboarding autopilot	D2, D4, S12	Activation without the owner, S23	Not started
S23	Expansion, renewal and churn rescue	S7, S12, S17	Net revenue retention	Not started
S24	Referral and partner engine	E1, S17, S21	Partner-sourced pipeline	Not started
T1	Lane-level, signed gate blessing	A1	Every T package	Not started
T2	Required per-crate coverage floors	T1	T3, T16	Not started
T3	Mutation testing that binds	T2, T6	Trustworthy tests	Not started
T4	Property tests for money, routing, receipts, limits	—	T14	Not started
T5	All-routes auth and tenant-isolation matrix	—	T8, S18	Not started
T6	Live end-to-end lane: dogfood and journeys	T1	T3, T9, T13	Not started
T7	Coverage-guided fuzzing for every parser	—	T14	Not started
T8	OpenAPI and router drift gate	T5	T9, D3	Not started
T9	SDKs against a live API, then published	T6, D3	Developer adoption	Not started
T10	Every gate proves it can fail	—	H2, T14	Not started

ID	Work package	Depends on	Unlocks	Status
T11	Personal-data map and erasure completeness	—	DSR answers, E5	Not started
T12	Claims match infrastructure and records	A4	Accurate claims, B6	Not started
T13	Restore, failover and load as scheduled tests	A3, A5, T6	99.9% SLA, C4	Not started
T14	Invariant and expectations registry	T4, T10	Traceable tests	Not started
T15	Statistics tests for the sales engine	S1–S5	S20	Not started
T16	smtp-auth-proxy and AI training tests	T2	No untested satellite code	Not started
T17	AI answer evaluation set	S15, S19	S20	Not started
V1	Adyen live charges that work	—	V3, paid checkout	Not started
V2	Dated VAT rates	—	Correct EU invoices	Not started
V3	Refunds and chargebacks that reach the books	V1	Clean books	Not started
V4	Real invoice PDFs, stored in Finland	V24	Invoice delivery	Not started
V5	SAML that works with real identity providers	—	V26, enterprise deals	Not started
V6	Offsite backups and point-in-time recovery in Finland	—	A5, T13	Not started
V7	Advisories and the old TLS stacks	—	Green cargo audit	Not started
V8	Container hardening for every service	—	Security reviews	Not started

ID	Work package	Depends on	Unlocks	Status
V9	Checked queries, caught panics, no silent test skips	—	V10	Not started
V10	Row-level security on tenant tables	V9	Tenant isolation by the database	Not started
V11	A second, small Helsinki VM for status, alerts and builds	—	A1, A3	Not started
V12	Config manifest, connection budget, dead crates and docs	—	Reviewable deployment	Not started
V13	Inbound mail filed per tenant	—	E4	Not started
V14	Inbound filtering that protects mailboxes	—	E4	Not started
V15	Retry budgets, implicit MX and DSN codes	—	Fewer false bounces	Not started
V16	Load tests on the real send path	T6	T13	Not started
V17	Routing receipt v2 and key history	B3	B6	Not started
V18	Honest open tracking	—	Trusted analytics	Not started
V19	Encrypt and expire the inbound copy	—	V23, V26	Not started
V20	One published API spec, generated from the router	—	T8, T9, D3	Not started
V21	Webhooks that are easy to switch to	—	D4, self-serve switching	Not started
V22	Credential cleanup and passkeys	—	Security reviews	Not started
V23	Data subject requests that cover every store	V19, T11	DSR answers	Not started

ID	Work package	Depends on	Unlocks	Status
V24	Finland in the configuration and the register	—	V4, T12	Not started
V25	One internal credential per service	—	Security reviews	Not started
V26	Public claims that match the product	—	A4, outreach	Not started
V27	A privacy notice for prospects	—	S14, cold outreach	Not started

Work package IDs H1–H3 are separate from the sales hooks H1–H6 in the Sales engine tab; the Unlocks column writes the hooks as "hook Hn". S1–S6 replace the "Experiments and learning loop" rules in the Sales engine tab where they conflict.

A — Risk fixes

A1 · Move CI and tests off the production host

- **Now:** `ci/pipeline.sh` runs on the production host from a systemd timer installed by `ci/install.sh`. It builds every image there (`ci/stages/images.sh:169`, `deploy/scripts/deploy.sh --build-only`) and runs the ~12.6k-test suite there (commit `bbb16ce`). A coverage pass filled the host's 436 GB disk and failed 164 tests with ENOSPC (`0cb9855`). 49 of the last 50 commits are CI, test or dependency fixes.
- **Do:**
  1. Provision a separate EU build host. Run the Woodpecker executor there (`.woodpecker.yml`, `ci/woodpecker/`) for validate, ui, test and security.
  2. Run a self-hosted container registry on that host. Do not use GHCR: it adds a US processor.
  3. Build images on the build host. Push them by digest and sign `image-digests.txt`.
  4. Change the production pipeline to fetch, pull by digest, migrate, deploy and verify. It must no longer build or test.
  5. Split tests into lanes. A fast lane on every push: `cargo fmt --check`, clippy, unit tests, contract tests. The full suite nightly, coverage weekly, all on the build host.

- **Done when:** a push deploys to production without any `cargo` process or test container ever starting on the production host; the fast lane finishes in under 20 minutes; the nightly full suite runs green on the build host.
- **Verify:** on production, `ps` history and the pipeline log show no `cargo` / `nextest` during a deploy. `docker images` on production lists only digests from the registry manifest.
- **Owner:** approves the build host's cost.

A2 · Separate sales sending from customer transport

- **Now:** sales pools are separated in the database (`crates/sales-autopilot/src/sender_pool.rs` , CHECK on `sales_sender_identities.pool`). The transport, though, is deployment-wide (`README.md:286` , `EMAIL_TRANSPORT_TYPE=ses` at `.env.production.example:349`). The dispatcher's transport gate reads the same global setting (`dispatcher.rs:811-815`).
- **Do:**
  1. Add a sales transport configuration: the `outbound-mta` relay with a sales-only source-IP range, and its own credentials.
  2. Route `sales_outbound` and `sales_warmup` pools only to it.
  3. At startup, refuse to run if the sales transport shares a credential, IP or SES account with any customer route.
  4. Keep separate suppression lists for sales and customers.
- **Done when:** a test proves that no sales-pool message can resolve to `DeliveryRoute::SesShared` or to a customer dedicated pool, and that the service refuses to start with a shared configuration.
- **Verify:** `cargo test -p sales-autopilot -p worker-processors` , plus `python3 tools/check_outbound_delivery_contract.py` .

A3 · Second production host and failover

- **Now:** one Hetzner host in Finland runs everything (`ARCHITECTURE.md` §1). The public pages advertise a 99.9% SLA (`templates/partials/home/cta.html:53` , `partials/pricing/plans.html` , `content/sla/index.md`).
- **Do:**
  1. Add a second Hetzner host in Finland, physically separate from the first where Hetzner offers it. Hosting stays Finland-only.
  2. Set up Postgres streaming replication.
  3. Run a secondary MX that accepts and queues inbound mail.
  4. Make the outbound relay ledger survive a host loss.
  5. Lower the DNS TTLs and write an automated failover runbook.

6. Until a failover drill passes, remove the 99.9% SLA wording from every page above and from the catalog SLA flags.

- **Done when:** a recorded drill fails the primary and serves API and SMTP from the second host, with measured RTO and RPO written into `deploy/rollback-plan.md`.
- **Verify:** drill log; `python3 tools/check_capability_claims.py` passes with the SLA claim tied to the drill.
- **Owner:** approves the second host's cost and the target RTO/RPO.

A4 · Make every public claim provable

- **Now:**
  - The homepage hard-codes "99.9% uptime · 12mo", "1.8 s" and "5.2m deliveries · Aug 2026" (`apps/marketing-zola/templates/partials/home/hero.html:95, 100, 105`). The repo's history begins in early 2026, so 12 months of uptime cannot be backed.
  - `content/data-locations.md:35` says the SES region defaults to the EU, but the code defaults to `us-east-1` (`crates/api-server/src/config.rs:1064`).
- **Do:**
  1. Add a daily job that exports real 30-day volume, latency and uptime from ClickHouse and status-server history into a dated data file read by the marketing build.
  2. Make the build fail if a stat is older than 48 hours, or has no source.
  3. Until then, remove the three numbers.
  4. Fix the SES default (done inside B1).
- **Done when:** every number on the homepage reads from the generated file, and a test proves the build fails on a stale or missing value.
- **Verify:** `zola --root apps/marketing-zola build`, `tools/check-forbidden-patterns.sh --require-build`, `python3 tools/check_capability_claims.py`.

A5 · Automated restore drills

- **Now:** nightly encrypted backups exist (`deploy/hardening/scripts/postgres-backup-encrypt.sh` and the ClickHouse, Redis and analytics siblings). No restore is proven automatically.
- **Do:** weekly on the build host, restore the latest Postgres and ClickHouse backups into throwaway containers. Check the migration ledger (`_sqlx_migrations`) and row counts for key tables. Store a signed result file and alert on failure.
- **Done when:** three consecutive weekly drills pass and are recorded.
- **Verify:** the drill result files.

A6 · Re-verify September-audit fixes on production

- **Now:** the code now has fixes for the audit's P0 items:
  - KiwiCaptcha verification on SSR forms (`crates/api-server/src/routes/web.rs:2425`)
  - GitHub SSO requiring a verified address (`routes/sso.rs:328-354`)
  - security crates wired into `api-server` and `mta` (their `Cargo.toml` files)
  - None of these have been probed against production.
- **Do:** probe production. Submit SSR login without a captcha token and expect refusal. Run the GitHub SSO path with an unverified email and expect refusal. Confirm that production refuses the `dev` KiwiCaptcha key. Confirm the DDoS reputation decay no longer blocks a steady legitimate client.
- **Done when:** each probe is recorded with its command and output in `docs/audit/` .
- **Verify:** the recorded probe outputs.

B — Routing modes and the EU-sovereign offer

B1 · Routing policy per tenant, subaccount and domain

- **Now:** `DeliveryRoute` has two variants, `SesShared` and `Dedicated` (`crates/worker-processors/src/email/types.rs:310`). The transport type is chosen once for the whole deployment. `AWS_REGION` defaults to `us-east-1` (`crates/api-server/src/config.rs:1064`); production sets `eu-west-1` (`.env.production.example:339`).
- **Do:**
  1. Add the next migration (253 at commit 9d8cef4): a `routing_policies` table with scope (`tenant` , `subaccount` , `domain`) and mode (`global_eu` , `global_us` , `eu_only` , `dedicated`). Precedence: domain over subaccount over tenant. The default is `global_eu` .
  2. Add a `DeliveryRoute::EuOnly` variant that resolves only to EU source IPs of the `outbound-mta` relay. When no healthy EU route exists, the message goes to a held state with an alert. It never falls back to SES.
  3. Support two SES clients (an EU region and `us-east-1`) for the Global modes.
  4. Change the region default to `eu-west-1` , and refuse to start in production when it is unset.
  5. Add API and console controls for the policy, and record the resolved mode on every message.

- **Done when:** tests prove that `eu_only` never reaches an SES client under any failure; precedence works; an unset region refuses to start in production; the delivery contract gate covers the new route.
- **Verify:** `cargo test -p worker-processors -p api-server`, `python3 tools/check_outbound_delivery_contract.py`, `python3 tools/migration_lint.py`.

B2 · Production-harden the EU-only relay

- **Now:** `crates/outbound-mta` (about 13k lines) binds dedicated source IPs, resolves MX, retries with backoff, writes DSNs and has a warmup module. It runs as the `outbound-mta` service in `docker-compose.prod.yml:1251`. Hetzner Cloud blocks outbound ports 25 and 465 by default. Unblocking needs at least one month as a customer, a paid first invoice and an approved request.
- **Do:**
  1. Add per-provider throttling for Gmail, Microsoft, Yahoo and the large EU mailbox providers.
  2. Enforce MTA-STS and DANE on outbound delivery. The inbound verifiers in `crates/mta/src/auth/mta_sts.rs` and `dane.rs` can be reused.
  3. Route bounces and feedback loops for this path into the existing VERP and FBL receivers.
  4. Set PTR records for every source IP.
  5. Run warmup per IP from `warmup.rs`.
  6. Run the `inbox-placement` crate's seed tests on every IP pool.
- **Done when:** on the same content, the EU-only pool's inbox placement at Gmail and Microsoft is within 5 percentage points of Global routing, for two consecutive weeks.
- **Verify:** inbox-placement reports; per-pool complaint rate below 0.1% and hard bounces below 2%.
- **Owner:** requests the port 25 unblock from Hetzner, or approves dedicated servers instead; buys or allocates the EU IP range.

B3 · Signed routing receipts

- **Now:** none. The September audit removed unbacked "proof" claims and deferred an Ed25519 receipt spec: `/v1/messages/{id}/proof`, public keys, rotation, canonicalization (`docs/audit/full-repo-audit-2026-09-05.md:418, 438`).
- **Do:** for every message, sign a canonical JSON receipt with an Ed25519 key held in the EU. It contains:
  - message ID and tenant
  - resolved routing mode

  - country of each processing hop
  - relay host
  - recipient MX host
  - accept time and the SMTP reply code
  - a hash of the submitted message headers

  Serve receipts at `/v1/messages/{id}/proof`, and publish public keys with rotation at a well-known URL. Add a verification function to every SDK.
- **Done when:** receipts verify with the published key; a changed field fails verification; key rotation keeps old receipts verifiable.
- **Verify:** `cargo test` for the new module; SDK verification tests.

B4 · EU-only subprocessor chain and generated list

- **Now:** the published subprocessors include Adyen (since 14 Oct, still carrying Stripe's old US/India locations; see H2), Google, GitHub and AWS (`content/data-locations.md:34-35`, plus the subprocessor page). The AI service calls any OpenAI-compatible endpoint (`crates/ai-service/src/config.rs:13`).
- **Do:** for tenants whose mode is `eu_only`:
  1. Bill through Adyen (an EU company: cards and SEPA Direct Debit) or by bank-transfer invoice through the accounting automation. No US payment processor.
  2. Disable Google and GitHub login; use the customer's own SAML/OIDC.
  3. Store telemetry in Hetzner Object Storage instead of AWS S3.
  4. Pull images only from the self-hosted registry (A1).
  5. Serve all fonts and scripts from ApexMail hosts.
  6. Point AI calls at a self-hosted EU model.

  Generate each tenant's subprocessor list from its configuration through the compliance claims registry.
- **Done when:** for an `eu_only` test tenant, the generated list contains no US-headquartered company, and an egress-capture test shows no connection to non-EU endpoints for that tenant's message path.
- **Verify:** the egress test; `python3 tools/check_capability_claims.py`.

B5 · Customer-held encryption keys

- **Now:** envelope encryption with a per-tenant key-encryption key exists for field-level data (`crates/enterprise/src/field_encryption.rs`). It is not applied to stored message content.

- **Do:** apply the same envelope scheme to stored message bodies and attachments for opted-in tenants. The customer supplies or rotates the key-encryption key through the API, or points to their own EU KMS. Revoking the key makes the content unreadable to ApexMail.
- **Done when:** after revocation, stored content cannot be decrypted, and sending still works for new messages under a new key.
- **Verify:** `cargo test -p enterprise` plus the new storage tests.

B6 · Evidence pack generator

- **Now:** Typst templates exist for the DPA, invoices, compliance reports and QBRs (`crates/pdf-renderer/src/templates/`). The procurement package and security questionnaires exist in `crates/compliance/src/`.
- **Do:** generate, per tenant, one signed bundle:
  - ApexMail's row for the customer's DORA register of information, as CSV fields aligned to the EBA taxonomy (download the EBA templates first; do not guess field names)
  - the exit plan
  - location attestations
  - the generated subprocessor list (B4)
  - the incident-notification commitment
  - an audit-log export
  - sample signed receipts (B3)

  Refresh on demand for Compliance and quarterly for Enterprise Cloud.
- **Done when:** the bundle regenerates identically from the same inputs and validates against the EBA field list.
- **Verify:** golden tests in `pdf-renderer`; a field-list check against the downloaded EBA templates.
- **Owner:** obtains a Legal Entity Identifier (LEI) for Bel Consulting OÜ if the EBA templates identify providers by LEI.

C — Winning US customers

C1 · Multi-currency catalog (USD)

- **Now:** the canonical catalog stores one price per plan, in EUR cents (`crates/platform-catalog/src/lib.rs:19`, `price_monthly_cents`). Since 14 Oct, checkout sends Adyen the catalog amount in minor units (commit 033d04c), so there are no provider

price objects; Adyen plan codes are stored in the database rows (`docs/pricing-authority.md`).

- **Do:**
  1. Add a currency dimension to the catalog: EUR and USD prices per plan and add-on.
  2. Send the plan's catalog amount in the chosen currency to Adyen checkout, and store one Adyen plan code per plan and currency.
  3. Choose the currency at checkout from the billing country, with a manual override.
  4. Update `tools/validate_pricing_drift.py` , `tools/check_knowledge_consistency.py` and the marketing calculator data so that both currencies are gated.
- **Done when:** a US test customer checks out every self-serve plan in USD in Adyen's test environment, and both drift gates fail on a deliberately mismatched USD price.
- **Verify:** `python3 tools/validate_pricing_drift.py` , `python3 tools/check_knowledge_consistency.py --self-test` , `cargo test -p platform-catalog -p billing-service` .

C2 · US sales tax handling

- **Do:** collect billing addresses for US customers, and add US sales-tax calculation to the local tax code, which covers EU VAT only today (crates/billing-common/src/vat_rates.rs). Use either a tax provider's API or a rate table the accountant maintains. Show the tax on invoices. Add a monthly report of US revenue by state for the accountant.
- **Done when:** a test invoice for a US address shows the calculated tax line, and the monthly report generates.
- **Owner:** decides with the Estonian accounting service when and where to register for US sales tax.

C3 · US DPA addendum

- **Now:** the contact-sales form has a CCPA option (`content/contact/sales.md:117–118`). No US-specific terms are published.
- **Do:** draft a DPA addendum covering CCPA/CPRA service-provider terms, linked from the DPA and the subprocessor page in all locales.
- **Done when:** counsel has approved it and it is published.
- **Owner:** counsel approval.

C4 · SOC 2 readiness

- **Do:**

1. Map existing controls (audit logs with hash chain, access control, backups and restore drills from A5, change management through the pipeline from A1) to SOC 2 criteria.
2. Automate evidence collection where possible.
3. Fix the gaps.
4. Then a Type I report, then Type II.

- **Done when:** a readiness assessment shows no open critical gap.
- **Owner:** chooses the auditor and the start date of the observation period.

D — Switching: compatibility, import, SDKs

D1 · Compatibility endpoints for four providers

- **Do:**
  1. Before writing code, read each provider's current API reference and record the URLs in the ledger.
  2. Implement request-shape adapters on `api.apexmail.ee` that map to the internal send path:
     - SendGrid v3 mail send (`POST /v3/mail/send` , bearer key)
     - Postmark (`POST /email` and `/email/batch` , server-token header)
     - Resend (`POST /emails` , bearer key)
     - Mailgun (`POST /v3/{domain}/messages` , basic auth, multipart form)
  3. Map ApexMail webhook events back into each provider's event shape, per webhook subscription.
  4. Return each provider's error shape for validation failures.
- **Done when:** each provider's official SDK, pointed at ApexMail's base URL, sends a message, a batch and an attachment in integration tests. Only providers whose SDK documents a base-URL override may be advertised as "change one line"; the ledger records which do.
- **Verify:** new contract tests in `crates/integration-tests` ; `python3 tools/check_capability_claims.py` .

D2 · Importer and shadow-send verifier

- **Do:**
  1. With the customer's old API key (read-only scopes where the provider offers them), import suppressions, templates and domain list into ApexMail.
  2. Generate DNS records for each imported domain.

3. Offer shadow sending: copy a chosen share of traffic to ApexMail's sandbox, and compare acceptance and latency per message before cut-over.

- **Done when:** an import from each provider's sandbox account round-trips suppressions and templates, and the shadow report matches messages one to one.
- **Verify:** integration tests against provider sandboxes or recorded fixtures.

D3 · SDKs generated from OpenAPI, published

- **Now:** five hand-written SDKs (Go, Ruby, Java, Python, PHP) at 1.0.1, and no TypeScript SDK (`packages/README.md`). The September audit found none published to a registry (`docs/audit/full-repo-audit-2026-09-05.md:85`). The OpenAPI 3.1 spec is at `docs/api/openapi.yaml` .
- **Do:**
  1. Generate a TypeScript SDK from the spec first, with hand-written ergonomic wrappers.
  2. Regenerate the other five from the same spec.
  3. Add receipt verification (B3) to each.
  4. Publish from CI to npm, PyPI, RubyGems, Packagist, Maven Central and Go modules.
  5. Keep `python3 packages/check_versions.py` in lockstep.
- **Done when:** each package installs from its public registry, and its quickstart sends a sandbox message.
- **Verify:** install and quickstart on a clean machine for each language.
- **Owner:** creates the registry accounts and grants CI publish tokens.

D4 · Migration guides per provider

- **Now:** comparison pages exist for Amazon SES, Mailgun, Postmark, Resend and SendGrid (`apps/marketing-zola/content/compare/`), backed by `docs/marketing/comparison-evidence.json` and a freshness checker.
- **Do:**
  1. Add a migration guide per provider: the one-line switch (D1), the import (D2) and the shadow send.
  2. Update each comparison with verified EU facts:
     - Resend offers an EU region (Ireland, `eu-west-1`) chosen per domain.
     - SendGrid offers EU data residency through EU subusers with EU IPs.
     - Mailgun offers an EU region chosen per domain.
     - Postmark hosts in the US and has no plans for EU servers.

3. State ApexMail's difference as fact: an EU company under EU law, EU-only routing with signed receipts, and no US subprocessor on that path.

- **Done when:** every comparison claim has an evidence entry with a source URL and check date, and the freshness checker passes.
- **Verify:** `python3 docs/marketing/check_comparison_freshness.py`, `python3 docs/marketing/check_pricing_parity.py`, and the marketing build.

E — Product lines and pricing

E1 · Catalog price changes and new plans

- **Now:** Developer is €29 (`crates/platform-catalog/src/lib.rs:78`, `price_monthly_cents: 2_900`). The €29 figure also appears in UI goldens and baselines under `crates/ui-foundation/`, in `crates/billing-service/src/plans.rs` and in several tools.
- **Do:** in `platform-catalog` only, change or add:
  - Developer: €20 (yearly €200), $20 in USD
  - Compliance: €990 / $1,090 a month, annual, 1M emails, EU-only routing included
  - Platform: €990 / $1,090 base, €0.30 / $0.35 per 1,000 above 1M, €1 / $1 per active subaccount above 100
  - EU-only routing add-on: €149 / $165, on Pro and above
  - Mailbox seat: €6 / $7, with archive +€2 / $2
  - Inbox placement monitoring: €99 / $109

  Then regenerate everything derived from the catalog:
  - billing seeds
  - `apps/marketing-zola/data/pricing.json` and the pricing partials
  - `docs/pricing.md`
  - the AI canon
  - UI fixtures, with `APEX_EXPORT_ALL_UI_ROUTES=1 cargo run -p ui-foundation --bin export_visual_fixtures`, and goldens through their own update path

  Adyen needs no product or price objects: verify each plan's checkout amount in Adyen's test environment, then live.
- **Done when:** `rg -n "2_900|€29\b"` finds only history and audit files, and checkout works for every plan in Adyen's test environment.
- **Verify:** `python3 tools/validate_pricing_drift.py`, `python3 tools/check_knowledge_consistency.py`, `python3 tools/check-compare-pricing-parity.py`, `python3 docs/marketing/check_pricing_parity.py`, the ui stage.

- **Owner:** approves the final prices before they go live.

E2 · Platform tier features

- **Now:** subaccounts with plan limits exist (`max_subaccounts` in the catalog), and custom tracking domains shipped in `3508c3c`.
- **Do:**
  1. Routing mode per subaccount (from B1).
  2. Reputation isolation: one IP pool per risk band, and automatic pause of a subaccount on a complaint spike.
  3. Abuse scoring when a subaccount is created.
  4. White-label tracking, bounce and DKIM domains.
  5. A provisioning API.
  6. Metering of active subaccounts in billing-service.
- **Done when:** one subaccount's complaint spike pauses only that subaccount; a platform test tenant provisions 100 subaccounts through the API and is billed for the excess.
- **Verify:** `cargo test -p enterprise -p billing-service -p worker-processors`.

E3 · Dedicated Tenant one-command provisioning

- **Now:** the catalog defines Dedicated Tenant at €4,000/mo, a 12-month minimum, €10k–40k setup, 5M recipients and 2 managed IPs (`crates/compliance/src/deployment_products.rs:51-72`). There is no provisioning tooling.
- **Do:** add a script under `deploy/scripts/` that creates a tenant host group from the same images and compose files, in the region the customer chooses (EU by default). Fleet updates go through the same pipeline and digest manifest. Use the existing per-tenant monitoring views.
- **Done when:** a staging tenant is provisioned from zero with one command and receives a normal pipeline update.
- **Verify:** the provisioning log and the post-update health checks.

E4 · Mailboxes as a product

- **Now:** IMAP, mailstore and autoconfig run in production for internal mailboxes (`ARCHITECTURE.md` §6). Spam filter and sandbox are wired into the MTA's inbound path. There is no seat billing.
- **Do:**
  1. Seat billing.

2. Self-serve domain onboarding with generated DNS records.
3. An IMAP import tool for Google Workspace and Microsoft 365 mailboxes.
4. Per-seat quotas, app passwords and MFA for IMAP and SMTP.
5. Admin pages for seats.

- **Done when:** a test organisation onboards a domain, imports one mailbox from a test Google account, and is billed per seat.
- **Verify:** `cargo test -p imap-server -p mailstore-core -p billing-service`, plus an IMAPS session test.

E5 · Archive and journaling

- **Now:** legal hold and retention sweep exist (`crates/compliance/src/legal_hold.rs`, `retention_sweep.rs`), and audit logs use a hash chain.
- **Do:** journal every message of an opted-in organisation into an append-only, hash-chained store, with legal hold, search and export.
- **Done when:** a tampered journal entry is detected by chain verification, and an export reproduces the original messages.
- **Verify:** `cargo test -p compliance` plus the new journaling tests.

E6 · Self-serve match signals

- **Do:** when a tenant verifies a domain, match it against the S1 and S2 register data and the S4 signals (F2). On a match, show the Compliance offer in the console and alert the founder.
- **Done when:** a test tenant on a domain from the register sees the offer, and the alert is recorded.
- **Verify:** `cargo test -p api-server` for the match path.

F — Sales engine build

Implements the Sales engine tab. All F work stays inside `crates/sales-autopilot`, `crates/ai-service`, `crates/email-grader` and `crates/worker-processors`, and every external send still goes through `decision_engine::decide`.

F1 · Per-country legal policy keys and draft rows

- **Now:** `resolve_jurisdiction` maps all EU and EEA countries to `EU` (`crates/sales-autopilot/src/legal_policy.rs:40-52`). Migration 200 seeds only `EU` (`approval_required`) and `UNKNOWN` (`migrations/200_sales_autopilot_v2_unification.sql:1055-1065`).

- **Do:**
  1. Resolve the country's own key first (e.g. `DE`, `FR`), and fall back to `EU` only when no authoritative country row exists.
  2. Add a migration with **unapproved** draft rows for FR, DE, GB, US and EE. Follow the Sales engine tab's legal table, and put the source URL in `notes`.
  3. Add a CAN-SPAM footer variant for `US`: ad disclosure, postal address, one-click opt-out.
- **Done when:**
  - Tests prove that a DE contact without consent evidence is never `Allowed`.
  - An approved FR row allows a `b2b_professional` contact.
  - Unapproved rows behave as absent.
  - The US footer renders every CAN-SPAM element.
- **Verify:** `cargo test -p sales-autopilot legal_policy`, `python3 tools/migration_lint.py`.
- **Owner:** reviews each row with counsel and sets `approved_by` / `approved_at`. Agents never do.

F2 · Discovery sources

- **Now:** the provider abstraction, leased job runner and first-party source exist (`discovery/provider.rs`, `job.rs`, `first_party.rs`). Enrichment is a Clearbit-shaped HTTP provider (`enrichment/providers/http.rs`). No register source exists.
- **Do:**
  1. Add an `EbaRegisterSource`: download the full EBA PSD2 register, parse it per the EBA's JSON specification, and declare EU/EEA jurisdictions. Store the disclaimer and the download date with each run.
  2. Add national register sources one country at a time, only after recording the register's reuse terms URL in the ledger.
  3. Connect one approved B2B data provider through the existing HTTP gateway for S3–S5 and for contact roles (engineering lead, CTO, CISO, compliance lead).
  4. Store universe counts per segment and country.
- **Done when:** a discovery run imports the EBA register idempotently (re-run creates no duplicates), every candidate carries its source and jurisdiction, and segment counts appear in the control plane.
- **Verify:** `cargo test -p sales-autopilot discovery`.
- **Owner:** picks the data provider and signs its DPA.

F3 · Provider detection additions

- **Now:** `signals/email_stack.rs` recognises 11 vendors. Resend is read as SES.
- **Do:** add the Resend, Mailjet and Brevo patterns from the Sales engine tab. Probe a fixed list of known vendor DKIM selectors (selectors cannot be enumerated). Keep the module's confidence policy unchanged.
- **Done when:** fixture tests classify each vendor's documented record set correctly, and a lone weak hint still yields only `company_may_use_*`.
- **Verify:** `cargo test -p sales-autopilot email_stack`.

F4 · Domain-audit hook

- **Now:** `GraderEngine::check_domain` (`crates/email-grader/src/grader.rs:226`) checks SPF, DKIM, DMARC, BIMI, MTA-STS, TLS-RPT and blocklists, under a per-tenant DNS budget. Sales does not use it.
- **Do:**
  1. Run the grader for each scored account.
  2. Write each finding as a `sales_evidence` row with source kind `grader`.
  3. Serve a report page from the sales service under `SALES_PUBLIC_BASE_URL`, behind a signed token that expires after 30 days.
- **Done when:** a test account gets evidence rows, a working report link and a correct H1 first email; an expired token returns an honest expired page.
- **Verify:** `cargo test -p sales-autopilot -p email-grader`.

F5 · Trigger signals

- **Do:**
  1. Poll each detected vendor's public status feed. Record each feed URL and its terms in the ledger first; prefer RSS or Atom.
  2. Compute the daily EBA register delta.
  3. Emit product events from api-server: signup, domain verified, quota above 80%, grader run.
  4. Write all of them to `sales_signals` with the decay values from the Sales engine tab.
- **Done when:** a recorded incident fixture raises `timing` only for accounts with "likely uses" evidence for that vendor, and decays as specified.
- **Verify:** `cargo test -p sales-autopilot signals`.

F6 · Scoring weights challenger

- **Do:** implement the proposed weights as a challenger policy, and run `simulation.rs` replay and shadowing. Promote only under the rules in the Sales engine tab, and record the promotion.
- **Done when:** the replay report is attached; the reason-code reconciliation test still passes.
- **Verify:** `cargo test -p sales-autopilot scoring simulation`.

F7 · Sequences, templates, objection library

- **Now:** sequences are versioned and approval-gated (`sequences.rs`). The objection library has a schema with an evidence CHECK and six classes (price, timing, competitor, authority, trust, need), and is empty (migration 242).
- **Do:**
  1. Draft one sequence per segment S1–S6, in EN, DE, FR and ES, from the Sales engine tab's step table and template.
  2. Draft one library entry per objection class, citing evidence.
  3. Submit all of them unapproved.
- **Done when:** every draft passes the claim validator, and the owner has approved them.
- **Verify:** `cargo test -p sales-autopilot sequences` and the knowledge-consistency gate.
- **Owner:** approves each sequence version and library entry.

F8 · Sales sending infrastructure

- **Do:**
  1. Configure DNS for the owner-bought domains: SPF, DKIM, DMARC, PTR.
  2. Create the sales source-IP pool on the relay (needs A2).
  3. Set per-identity `daily_limit` warmup values from the Sales engine tab, enforced through `sales_sender_daily_usage`.
  4. Make the complaint quarantine threshold configurable per pool (today fixed at 0.003 in `sender_health.rs:82`), and set 0.001 for sales pools.
- **Done when:** a sales send passes SPF, DKIM and DMARC alignment at Gmail and Outlook test inboxes, and breaching 0.1% complaints quarantines the identity in a test.
- **Verify:** `cargo test -p sales-autopilot sender_health sender_pool`; header checks on seed inboxes.
- **Owner:** buys the domains; registers them in Google Postmaster Tools.

F9 · Reply auto-send promotion

- **Now:** the mailbot is draft-only by construction (`0cace0d`), and every draft goes through `ai_drafts` approval.
- **Do:**
  1. Measure, per classification and objection class, the owner's edit rate on drafts.
  2. Add a policy that auto-approves a draft only when all four F9 conditions in the Sales engine tab hold.
  3. Record each class's promotion in the registry.
- **Done when:** in replay, the policy auto-approves no draft containing a non-catalog price, a discount or a legal term; promoted classes show an edit rate below 5% over 200 or more drafts.
- **Verify:** `cargo test -p ai-service -p api-server ai_drafts` .

F10 · Call-to-contract automation

- **Do:**
  1. A founder packet page: evidence, score with reason codes, thread, objections.
  2. An order form template next to `dpa.typ` in `crates/pdf-renderer/src/templates/` , priced from the catalog.
  3. A click-accept page that writes an audit log entry.
  4. Invoice creation: billing-service charges through Adyen (cards, SEPA Direct Debit); the accounting automation handles bank-transfer invoices.
  5. A demo session is created through `/v1/admin/demos` when a meeting is booked.
- **Done when:** a test deal goes from booked meeting to accepted order form and issued invoice with no manual step except the owner's click to send the proposal.
- **Verify:** an end-to-end test across sales-autopilot, pdf-renderer and billing-service.

F11 · Experiment program and scoreboard

- **Do:** create the arms in the Sales engine tab through `POST /experiments/:key/arms` (`d66c7bf`), set `sales_experiments.budgets` , and implement the kill rules. Add the weekly scoreboard page to the control plane.
- **Done when:** arms run inside their budgets, an arm breaching the complaint rule pauses in a test, and the scoreboard shows every metric in the Sales engine tab.
- **Verify:** `cargo test -p sales-autopilot experiments` .

F12 · Autonomy promotion gates

- **Now:** modes are `disabled`, `shadow`, `assisted`, `approval_required` and `autonomous_guarded`. Only `autonomous_guarded` executes without a human (`crates/sales-autopilot/src/types.rs:30-34`, `autonomy.rs`).
- **Do:** gate promotions per segment and country, using the `rules` field of `sales_autonomy_state`:
  1. **Shadow → approval_required:** 200 or more shadow decisions, with the owner agreeing with at least 95% of them.
  2. **approval_required → autonomous_guarded:** 300 or more approved sends with complaints below 0.1%, hard bounces below 2%, and zero legal-gate denials overridden.
  3. **Automatic demotion:** one level down on any guardrail breach.
- **Done when:** tests prove promotion is refused below each threshold, and that a breach demotes immediately.
- **Verify:** `cargo test -p sales-autopilot autonomy`.
- **Owner:** each promotion is a recorded owner click.

G — Kept surfaces and the BYOC freeze

G1 · BYOC freeze

- **Now:** BYOC is defined at €6,500/mo (`crates/compliance/src/deployment_products.rs:89-143`). It is referenced from `content/solutions/` (all locales), `content/architecture.md`, the DE and ES data-locations pages, and `docs/marketing/` (enterprise pricing disclosure, private-cloud engagement, billing definitions).
- **Do:**
  1. Remove BYOC from every public page and from the sales knowledge base, objection library and AI canon.
  2. Mark `DeploymentType::BYOC` not-for-sale in the deployment products and enterprise forms (`enterprise_forms.rs`).
  3. Move BYOC tests to the nightly lane. Keep them green and keep the code.
- **Done when:** the built marketing site contains no "BYOC" outside legal history pages, and a test proves the quote flow cannot offer it.
- **Verify:** `rg -i byoc apps/marketing-zola/public` returns nothing after `zola build`; `cargo test -p compliance`; the capability-claims gate.

G2 · Decide on test-only security crates

- **Now:** at `61e3db3`, only `pattern-matcher` is listed solely in test crates' manifests. `isolation` runs as its own production service (`docker-compose.prod.yml:1092`), and every other security crate is a dependency of `api-server`, `mta` or `worker-processors`.
- **Do:** either wire each one into a production binary with tests, or document it as test-only and make sure no public page or questionnaire answer claims it as a runtime protection.
- **Done when:** the capability registry and procurement answers match what runs.
- **Verify:** `python3 tools/check_capability_claims.py`.

G3 · Locale build gate

- **Now:** raw template syntax once leaked onto the English and German homepages (`fixes.md`, historical). `tools/check-forbidden-patterns.sh --require-build` runs after the build.
- **Do:** make the build fail on any missing translation key in EN, DE, FR or ES, and on any unrendered `{%`, `{{` or `i18n_data` in the output.
- **Done when:** a deliberately removed DE key fails the build in a test.
- **Verify:** `zola --root apps/marketing-zola build` followed by the forbidden-patterns check.

H — Fixes from the 15 Oct audit

The switch from Stripe to Adyen (commits `ad6c748` … `9d8cef4`, 14 Oct) moved billing to an EU company. But Stripe's hosted portal, subscription objects and tax calculation have no Adyen equivalent, so ApexMail now owns those jobs. These three packages close the gaps it left. Do them before any paid launch.

H1 · Restore self-service cancellation under Adyen

- **Now:** both cancellation endpoints refuse with "use the Adyen billing portal" (`crates/api-server/src/routes/billing.rs:3400-3418`, `crates/billing-service/src/routes.rs:1444-1465`). The code also states Adyen has no hosted portal (`billing.rs:3281`). The URL returned for the portal, `/web/billing/portal`, is a POST-only form that records a request and changes nothing (`routes/web.rs:328`, `5123-5141`). Renewals charge stored tokens from the maintenance sweep (`f6bc6c8`). The Terms (`content/terms/index.md:52`, four languages) and `templates/partials/generated/pricing-faq-island.html` promise self-service cancellation through an Adyen portal.

- **Do:**
  1. Implement cancellation as a local state change: set the subscription to cancel at period end, and make the renewal sweep skip it. Do not call Adyen to cancel; Adyen holds only the stored token.
  2. Offer an optional "remove saved payment method" action that disables the stored token through Adyen's API.
  3. Add a GET console page at `/web/billing/portal`: current plan, next charge date, payment method, cancel, resume and update-card actions.
  4. Make the JSON cancel endpoints perform the same state change. Remove every "Adyen billing portal" string from code, Terms (four languages), FAQ and docs.
  5. Write audit-log entries for cancel and resume, and send a confirmation email.
- **Done when:** a test tenant on a paid plan cancels from the console; the next renewal run creates no charge; access ends at period end; resume before period end restores renewal; `rg -i "adyen billing portal"` finds nothing outside history files.
- **Verify:** `cargo test -p api-server -p billing-service` with new cancellation tests, including a renewal-sweep test that proves no charge after cancel.

H2 · Correct Adyen's facts on legal pages, and gate them

- **Now:** 20 lines on four public pages — `content/subprocessors/`, `content/privacy/`, `content/dpa/`, `content/data-locations*` — in all four languages describe Adyen N.V. with Stripe's old facts: "USA (primary); India (support)", US storage, US corporate country. The same text is in `templates/compliance/subprocessors.md` and `templates/compliance/data-locations.md`, and in the UI baselines. The env example keys still use Stripe's prefixes (`.env.production.example:130-131`).
- **Do:**
  1. Read Adyen's DPA and published subprocessor list, and record their URLs in the Verification ledger.
  2. Rewrite every Adyen row from those documents: legal entity, corporate country, processing and storage locations, transfer mechanism.
  3. Add the change to the subprocessor change log (all locales) with today's date.
  4. Add a processor-facts file — one entry per subprocessor with its entity, country and locations — and a validate-stage gate that fails when any legal page disagrees with it.
  5. Fix the env-example placeholders.
  6. Regenerate the UI fixtures and goldens.
- **Done when:** the gate passes, and a test proves it fails on a deliberately wrong Adyen location.

- **Verify:** the new gate; `python3 tools/validate_legal_identity.py --build-dir apps/marketing-zola/public` after `zola build`; the ui stage.
- **Owner:** reviews the corrected DPA and privacy wording before publication.

H3 · Wire Adyen into production; live account

- **Now:** the checkout client in api-server reads `ADYEN_API_KEY`, `ADYEN_MERCHANT_ACCOUNT` and `ADYEN_API_BASE_URL` (`routes/billing.rs:1006–1030`). `docker-compose.prod.yml` passes none of them to api-server; only billing-service gets the key and HMAC secret. Neither the merchant account nor the base URL is in `.env.production.example`. The base URL defaults to Adyen's test endpoint, which production refuses.
- **Do:**
  1. Add the three settings to api-server in `docker-compose.prod.yml`, with the key as a secret file bridged by `deploy/scripts/entrypoint-wrapper.sh`.
  2. Add `ADYEN_MERCHANT_ACCOUNT` and `ADYEN_API_BASE_URL` (live URL) to `.env.production.example`, and make startup fail in production when billing is enabled but any of them is missing.
  3. Run a complete test-environment purchase, renewal, refund and cancellation (H1) against Adyen's test endpoint from a staging stack.
  4. Configure webhooks and the HMAC key in Adyen's Customer Area, and confirm signed notifications reach `/webhooks/adyen`.
- **Done when:** staging completes the four flows end to end; production starts with the live settings and its health check reports billing configured.
- **Verify:** staging run log; production health output.
- **Owner:**
  - Applies for the Adyen live account (KYC on company, shareholders and business model).
  - Confirms the website meets Adyen's requirements: terms, privacy and refund policies, contact details, and a terms checkbox at checkout.
  - Asks Adyen for the minimum monthly invoice that applies.
  - Enables SEPA Direct Debit.

S — Sales science and autonomy (16 and 22 Oct audits)

These packages change how the sales engine learns and decides, so its results are causal, adequately powered and reproducible. They supersede the "Experiments and learning loop" rules in the Sales engine tab where the two conflict. Every S package keeps the

existing guardrails, legal gate and evidence rules unchanged. S1–S10 make the learning sound; S11–S24 (added 22 Oct) let the engine sell end to end without the owner, as drawn in the Sales engine tab under "Autonomous loop". No S package may solve, outsource or evade a CAPTCHA.

S1 · Exposure-correct bandit posterior

- **Now:** `apply_reward_to_posterior` (`crates/sales-autopilot/src/experiments.rs:407-437`) increments only `contacts` for delivered and opened sends, adds positive ladder rewards to α and negative ones to β. Non-response never reaches β, and one contact's reply, meeting, trial and paid outcomes each add to α. Selection samples `Beta(α, β)` (`:477`, `:1674`) without using `contacts`.
- **Do:**
  1. Model one binary primary outcome per contact, as defined in S2. Use α = 1 + successes and β = 1 + (matured contacts − successes). A contact counts only once its observation window has closed.
  2. Count at most one success per contact per arm. The outcome ledger's idempotency key becomes (arm, contact, primary metric).
  3. Move complaints, unsubscribes and bounces out of the posterior and into S2's guardrail checks.
  4. Migrate existing posteriors by recomputing them from `sales_experiment_outcomes`, rather than carrying over the reward-weighted values.
- **Done when:**
  - A test with arm A at 10 successes in 1,000 matured contacts and arm B at 2 in 10 prefers B in at least 95% of draws.
  - A contact producing reply, meeting and paid counts once.
  - `ten_thousand_opens_never_win_an_arm` still passes.
- **Verify:** `cargo test -p sales-autopilot experiments`.

S2 · One primary metric with fixed windows

- **Do:**
  1. Define the primary metric as "positive reply or meeting booked within 14 days of the first touch".
  2. Define the north star as "won MRR per 1,000 contacted accounts, measured at 90 days". Both are computed from `sales_outcomes` through `attribution.rs`.

3. Add guardrails per arm and segment that pause the arm automatically: complaint rate below 0.1%, unsubscribe rate below 1%, hard bounce rate below 2%.
4. Store each metric's definition, version and window in one table; the scoreboard reads only from it.

- **Done when:** a contact's outcome is frozen when its window closes, and later events change only the north star.
- **Verify:** `cargo test -p sales-autopilot attribution experiments`.

S3 · Randomized account-level holdout

- **Do:**
  1. For each segment, assign 5–10% of eligible scored accounts to a no-contact holdout, by a stable hash of (account ID, experiment salt).
  2. Record the assignment before any send.
  3. Randomize at account level: all contacts in an account share one arm.
  4. Report incremental pipeline (treated minus holdout) per segment, with 95% intervals, on the scoreboard.
  5. Re-draw the salt only between experiment periods, and never re-assign a holdout account mid-period.
- **Done when:** a test proves assignment is stable, roughly uniform, and that the decision engine refuses any send to a holdout account.
- **Verify:** `cargo test -p sales-autopilot`.
- **Owner:** chooses the holdout share per segment.

S4 · Logged propensities and off-policy evaluation

- **Now:** `simulation.rs` scores a challenger by "agreement with reality", which favours the policy that generated the logged data.
- **Do:**
  1. At every decision, log the policy version, context, chosen action and arm, and the action's selection probability. Estimate the latter with at least 1,000 Monte Carlo Thompson draws.
  2. Add inverse-propensity (self-normalized) and doubly-robust estimators of the S2 metric for any challenger policy, with bootstrap intervals and effective sample size.
  3. Require a challenger to beat the champion's lower interval bound, with an effective sample size of at least 500, before promotion. This applies to scoring weights (F6), auto-send classes (F9), new arms and S6.
- **Done when:** on a simulated log with a known best policy, the estimator recovers it within its interval; promotion is refused below the effective-sample-size threshold.

- **Verify:** `cargo test -p sales-autopilot simulation`.

S5 · Experiment registry, power and sequential tests

- **Do:**
  1. An experiment cannot start without these fields: hypothesis, primary metric (S2), unit (account), minimum detectable effect, α, power, and planned sample per arm computed from the baseline.
  2. Decide fixed comparisons with an always-valid sequential test (mixture SPRT), so checking results daily does not inflate false positives. Bandits may allocate traffic; the registry decides what is concluded.
  3. The scoreboard shows each experiment's progress against its planned sample.
- **Done when:** the registry refuses an experiment without a power calculation; a simulation with no true effect shows a false-positive rate at or below α under daily checks.
- **Verify:** `cargo test -p sales-autopilot experiments`.

S6 · Hierarchical partial pooling for contexts

- **Now:** `MIN_CONTEXT_SAMPLES = 25` (`experiments.rs:120`) switches a bucket from the global posterior to its own in one step.
- **Do:** replace the hard switch with a hierarchical Beta-Binomial (global → segment → bucket) using empirical-Bayes priors, so each bucket shrinks toward its parent in proportion to its data.
- **Done when:** S4's off-policy estimate shows the pooled policy at least as good as the current one, and a sparse bucket's selection probabilities change smoothly with its data.
- **Verify:** `cargo test -p sales-autopilot experiments simulation`.

S7 · Learned, calibrated scores, then uplift

- **Now:** the ten weights in `scoring.rs` are hand-set; `calibration.rs` computes Brier score and log loss.
- **Do:**
  1. Fit the weights by regularized logistic regression on matured S2 outcomes, with a time-based train/test split. Keep the reason-code reconciliation identity.
  2. Promote a model only if its out-of-time Brier score and calibration beat the current model's.
  3. Once S3 has holdout data, add an uplift model (two-model or T-learner) and rank accounts by expected incremental value, not by base propensity.

- **Done when:** the promotion record shows the out-of-time metrics of both models.
- **Verify:** `cargo test -p sales-autopilot scoring calibration`.

S8 · Truth measurement for inferences and copy

- **Do:**
  1. Join each "likely uses vendor X" inference to ground truth (the provider named in `provider_import` reports, or a signup question) and publish precision and recall per vendor.
  2. Disable provider hooks for any vendor below 90% precision.
  3. Every week, sample 50 sent emails at random, check every factual sentence against its evidence row, and log unsupported claims. The target is zero.
- **Done when:** the scoreboard shows per-vendor precision and the weekly audit result.
- **Verify:** `cargo test -p sales-autopilot signals`.

S9 · Speed and throughput targets

- **Do:**
  1. Measure and alert on these speeds:
     - inbound lead to first reply: 5 minutes at p95
     - signal (provider incident, register change, quota event) to first touch: 1 hour inside send windows
  2. Compute daily capacity as sender identities × daily cap. Show days per full pass of each segment, and add identities only while S2 guardrails hold.
  3. Allow factorial experiments (hook × call to action) in the S5 registry.
  4. Re-enter no-reply and closed-lost accounts after 90 days, only when a new signal fires.
- **Done when:** the scoreboard shows latency percentiles and capacity per segment, and an alert fires in a test when p95 latency breaches its target.
- **Verify:** `cargo test -p sales-autopilot`.

S10 · Remove the CAPTCHA-solver hook; lawful sourcing

- **Now:** `crates/sales-autopilot/src/discovery/blocked.rs:1-70` holds an opt-in hook that sends blocked pages to an external solver (`SCRAPE_CAPTCHA_SOLVER_URL`, `_TOKEN`, `_TIMEOUT_MS`). Migration 258 adds `sales_scrape_host_health.solver_enabled` and `sales_scrape_solver_audit`. At `a2f3b08`, `crates/sales-autopilot/src` still mentions `solver` 232 times. `public_web.rs` extracts `mailto:` addresses.

- **Decision (22 Oct, firm):** no CAPTCHA solving, outsourcing or evasion; no rotating or residential proxies after a block; no stealth browsers; no pages behind a login. No setting may re-enable any of it.
- **Do:**
  1. Delete the solver client, its settings, routes and audit path. Drop `solver_enabled` and `sales_scrape_solver_audit` in migration 269. Remove the solver entries from every `.env*.example` and the solver section of `docs/architecture/sales-autopilot.md`.
  2. A CAPTCHA page, a robots.txt disallow, HTTP 401 or 403, or three 429s in a row marks the host `excluded` for good. Only the owner can lift it, with a written reason stored in the audit log.
  3. From `mailto:` links, keep role addresses (info@, contact@, sales@). Store a named person's address only if that country's legal policy row allows it, and send the Article 14 source notice in the first email.
  4. Add `tools/check_no_bypass.py` to the validate stage, required, with `--self-test`. It fails on `solver`, `2captcha`, `anti-captcha`, `capsolver`, `capmonster`, `rotating proxy` and `residential proxy` in `crates/sales-autopilot`, env examples, compose files and migrations above 268.
  5. Integration test: a fixture site that serves a CAPTCHA gets its host excluded and receives no further request, and no discovery request reaches a host outside the allowlist.
- **Done when:** `rg -i solver crates/sales-autopilot` finds nothing; migration 269 drops the column and the table; the gate's self-test fails on a seeded `SCRAPE_CAPTCHA_SOLVER_URL`; the exclusion test passes.
- **Verify:** `cargo test -p sales-autopilot discovery`; `python3 tools/check_no_bypass.py --self-test`; `python3 tools/check_no_bypass.py`.

S11 · Public domain check as the consented lead source

- **Now:** `crates/email-grader` (2,491 lines), `crates/sales-autopilot/src/signals/email_stack.rs` and `crates/inbox-placement` exist, but no public route exposes them and the marketing site has no free tool.
- **Do:**
  1. Add a public page `/check` in four locales. A visitor enters a domain; the server reads SPF, DKIM selectors, DMARC, MX, MTA-STS and TLS-RPT, runs `email_stack` provider detection, and shows where the domain's mail is processed (provider and its legal seat, from a reviewed table). No sign-up needed to see the result.

2. Offer the full PDF report (`pdf-renderer`) and a weekly DNS-change alert by email. Use two checkboxes: one to receive the report, one unticked for product news. Store the consent text version, its hash and the timestamp.
3. Rate-limit per IP and per domain with `crates/rate-limiter`, and protect the form with KiwiCaptcha.
4. Emit a `first_party_tool_use` signal on the domain's account. Consented contacts enter a nurture sequence that is lawful in every country, Germany included.
5. Link each report to the migration guide (D4) for the provider it detected.

- **Done when:** the page answers in under 3 s at p95; a consented German contact enters nurture and an unconsented one does not; the consent row stores the text hash and timestamp.
- **Verify:** an integration test for the consent split; the existing UI gates (links, contrast, form hygiene) pass on the new page.

S12 · Product-qualified leads and lifecycle

- **Now:** `signals/mod.rs:76-79` defines `first_party_product_intent` and `trial_signup`. Guardrail 7 forbids cold sequences to colleagues of paying tenants; keep it.
- **Do:**
  1. Emit activation milestones once per tenant: domain verified, DKIM passing, first 100 sends, webhook configured, first 10,000 sends, 80% of plan quota.
  2. Send lifecycle email to the signed-up user only, keyed to the next missing milestone. Test timing and content as S5 experiments.
  3. Score product-qualified leads as the calibrated probability of paying within 30 days (S7 method).
  4. At 80% of quota, show an in-product upgrade prompt with a payment link for the next plan (S17).
  5. Above the score threshold, with a company-size signal, send a sales-assist email from the owner's identity as an F9 reply class.
- **Done when:** each milestone fires once per tenant (idempotency test); the score reports its Brier score on a held-out month; upgrade prompts reach a working checkout.
- **Verify:** `cargo test -p sales-autopilot signals` ; `cargo test -p worker-processors` .

S13 · Domain universe, registers and trigger feeds

- **Now:** discovery has `first_party.rs`, `public_web.rs` (operator-listed URLs) and `provider.rs`. Nothing supplies domains to `email_stack.rs` at scale.
- **Do:**
  1. Build a domain universe from Certificate Transparency logs, the Tranco top-sites list and website fields in open business registers: UK Companies House, French SIRENE, Norwegian Brønnøysund, Estonian e-Business Register, Danish CVR. Record each source's licence and terms per row.
  2. Run `email_stack` over the universe within a DNS budget through `crates/dns-resolver`'s cache. Store propositions with confidence and evidence ids.
  3. Accounts at this stage hold company data only: domain, register entity, industry code, signals. No personal data.
  4. Add trigger feeds: competitors' public status pages and changelogs, and official public job-board APIs searched for provider names, "deliverability" and "DORA".
- **Done when:** a coverage report by country exists, and provider-detection precision and recall are measured on 200 labelled domains with 95% intervals (S8).
- **Verify:** `cargo test -p sales-autopilot discovery signals`.

S14 · Lawful contact sourcing

- **Now:** contacts come from the enrichment router and from `mailto:` extraction (S10).
- **Do:**
  1. Allow these contact sources only: role addresses from public pages; named people from a licensed EU data provider with documented Article 14 handling, or from the person's own professional publication; inbound and consented contacts.
  2. Store per contact: source kind, source reference, licence or consent id, and the date the Article 14 notice was sent.
  3. The country's policy row decides whether a named person may receive cold email. Germany: consent only. Unknown country: approval required (the existing fail-closed rule).
  4. No address guessing in consent countries, and no SMTP RCPT probing anywhere. Verify addresses through the licensed provider or bounce feedback.
- **Done when:** a test refuses a named German contact without consent; every contact row has a source kind; the first email to a named person carries the notice.
- **Verify:** `cargo test -p sales-autopilot legal_policy enrollments`.

S15 · Canonical answers for price, legal and data-location questions

- **Now:** `reply_autosend.rs` sends any draft containing one of 18 pricing markers or 14 legal markers to a human. `LowRiskClass` has five classes and none covers price or legal facts.
- **Do:**
  1. Add `sales_canonical_answers` in the next free migration: id, version, kind (`pricing`, `legal_fact`, `data_location`, `security`), locale, body template, source path, source content hash, `approved_by`, `approved_at`, `valid_until`.
  2. Render pricing bodies from `crates/platform-catalog`, subprocessors and locations from the generated subprocessor register, and terms from the published legal pages. No free-typed figures.
  3. Add `LowRiskClass::CanonicalPricing` and `LowRiskClass::CanonicalLegalFact`. `classify_draft` accepts a pricing or legal marker only in a sentence that cites a canonical-answer id with a current source hash; everything else keeps the high-risk path.
  4. Add `tools/check_canonical_answers.py`: it recomputes source hashes and fails when an approved answer's source changed without re-approval. At runtime such an answer stops sending.
  5. Promote each class through the F9 gate.
- **Done when:** in shadow mode a price question gets a correct answer; changing a catalog price changes the answer with no edit; an answer with a stale hash is refused.
- **Verify:** `cargo test -p sales-autopilot reply_autosend`; `python3 tools/check_canonical_answers.py --self-test`.

S16 · Security questionnaires from the evidence bank

- **Depends on:** B6.
- **Now:** no questionnaire handling exists; the B6 evidence pack is in progress.
- **Do:**
  1. Map B6 evidence items to the CAIQ v4 question set first (published free by the Cloud Security Alliance). Add other formats only when a buyer sends one.
  2. Accept questionnaires as XLSX or CSV in the reply flow. Fill each question that has a bank answer, with its evidence link, and mark the rest for the owner.
  3. Send the filled file as a draft; promote per question family through F9.
  4. Withdraw an answer when its evidence item expires.
- **Done when:** a sample CAIQ fills with every answer citing an evidence id, the fill rate is reported, and unanswered questions reach the owner as one batch.

- **Verify:** a golden-file test on a sample questionnaire; `cargo test -p sales-autopilot`.

S17 · Deal desk: price bands, payment links, order forms

- **Depends on:** H3, E1, F10.
- **Now:** a sales thread has no price authority, payment link or order form.
- **Do:**
  1. Add `sales_price_bands`: plan, term, currency, maximum discount, minimum commitment, `approved_by`, `valid_until`. Only the owner writes it.
  2. When a buyer asks to buy, send an Adyen payment link or checkout session for the catalog plan, and only inside a band.
  3. Render an order form and the standard DPA with `pdf-renderer`. Acceptance is a click in the console, with the document hash stored.
  4. Issue annual prepay invoices from `crates/accounting-core`; offer SEPA Direct Debit once H3's owner step enables it.
  5. Send out-of-band discounts, redlines and custom DPAs to the owner queue with a drafted recommendation and its evidence.
- **Done when:** in staging, a test tenant accepts an in-band annual offer end to end (link, payment, plan active, invoice), and an out-of-band request lands in the owner queue.
- **Verify:** staging run log; `cargo test -p sales-autopilot -p billing-service`.

S18 · Instant demo: a sandbox in the reply

- **Now:** api-server has an explorer sandbox built on shared sandbox-key rows (`.config/nextest.toml` serialises its tests). `calendar/` books meetings through Google, Microsoft or an internal calendar.
- **Do:**
  1. Add a `demo_request` reply class that offers three things in one reply: an instant sandbox tenant, a three-minute recorded walkthrough per segment, and a booking link for a live call.
  2. The sandbox tenant gets a test domain, sample templates and an API key that can send only to a sink. It expires after 14 days unless converted.
  3. The owner records each walkthrough once; subtitles cover the four locales.
  4. Each booked call gets a generated brief: account signals, questions asked, canonical answers already sent.
  5. Sandbox activity feeds the S12 score.
- **Done when:** provisioning takes under 30 s, a sandbox key cannot send outside the sink (covered by T5), and expired sandboxes are deleted.

- **Verify:** `cargo test -p api-server explorer`; the T5 matrix.

S19 · AI disclosure and audit for autonomous messages

- **Now:** `crates/ai-service/src/chat.rs:44` attaches `AI_DISCLOSURE` to chat answers for EU AI Act Art. 50. Sales replies and sequence steps carry none. Art. 50(1) has applied since 2 Aug 2026.
- **Do:**
  1. Every message sent without a human approving its exact text carries one disclosure line in the recipient's language, for example: "Written with AI assistance by ApexMail's sales system. Reply 'human' to reach the founder."
  2. Its audit row stores the draft, the classifier verdict, cited evidence and canonical-answer ids, the model id and version, and the autonomy mode.
  3. A reply asking for a human, in any supported language, routes the thread to the owner.
- **Done when:** a test fails if any autonomous send path omits the disclosure or the audit row.
- **Verify:** `cargo test -p sales-autopilot dispatcher reply_autosend`.

S20 · Autonomy ladder with automatic demotion

- **Depends on:** F12, S2, S4.
- **Now:** `autonomy.rs` holds one mode for the engine, and `autonomy = disabled` is the kill switch. Promotion exists per reply class (`reply_autosend_grants`, F9). Nothing demotes a class automatically, and nothing shows the owner each day what the engine did.
- **Do:**
  - Extend grants to every action class in the ladder table in the Sales engine tab: first touch, follow-up, reply classes, canonical answers, questionnaires, demos, payment links, onboarding nudges (S22) and expansion offers (S23).
  - Promote on a schedule, not on request. When a class clears its bar (the F9 bar, plus an S4 off-policy estimate showing no loss against the approved-draft baseline), the engine schedules the promotion and lists it in the daily digest. It takes effect after 48 hours unless the owner vetoes it.
  - Evaluate each class daily against its guardrail metrics. A breach demotes it one step at once and records the cause; re-promotion after a demotion needs the owner.
  - Set daily budgets: sends per pool, enrichment spend, and total discount value granted. Once a budget is spent, further actions of that kind are held.

    - Send one daily exception digest: held actions with their reasons, scheduled promotions, demotions, out-of-band asks, onboarding stalls (S22) and budget burn. A day with no exceptions sends one line.
    - Publish a weekly autonomy report: actions by mode, human-touch rate, pipeline and revenue by mode, demotions and causes.
- **Done when:** a simulated complaint spike demotes the class within one daily cycle; a promotion vetoed from the digest never takes effect; a spent budget holds further actions; the kill switch stops every class in one step.
- **Verify:** `cargo test -p sales-autopilot autonomy`.

S21 · Policy packs: approve rules once, not messages

- **Depends on:** F1, F7, S15, S17.
- **Now:** each approval stands alone: legal rows (F1), sequence versions (F7), reply-class grants (F9), canonical answers (S15) and price bands (S17). Nothing ties them to a segment, so the owner cannot approve "what the engine may do for German logistics firms" as one decision.
- **Do:**
    - Add `sales_policy_packs` in the next free migration: id, version, segment (countries, industry codes, size band, detected provider), allowed legal bases (F1 row ids), sequence version ids, canonical-answer ids, price-band ids, daily caps, complaint ceiling, `valid_until`, content hash, `approved_by`, `approved_at`.
    - The dispatcher acts only when an active pack covers both the account and the action. Otherwise it holds the action with reason `outside_pack`. Every audit row records the pack id and version.
    - The console shows a pack as one page, with a diff against its previous version. The owner approves it with one click.
    - When a referenced item changes (a sequence edit, a catalog price, a policy row), the pack's hash no longer matches and the pack suspends until re-approved, as S15 does for answers.
    - Packs expire at `valid_until` (90 days by default); the S20 digest warns 14 days ahead.
    - Agents may draft packs; only the owner approves them.
- **Done when:** an action outside every active pack is held with `outside_pack`; editing a referenced sequence suspends its pack; every autonomous send names its pack version.
- **Verify:** `cargo test -p sales-autopilot policy_pack`; a property test that no send happens without an active covering pack, registered as invariant I22 (T14).

S22 · Onboarding autopilot

- **Depends on:** D2, D4, S12.
- **Now:** D2′s importer exists; its shadow-send verifier does not. D4′s migration guides exist. No per-tenant onboarding state exists, so nobody notices a tenant stuck on DNS.
- **Do:**
  - Track each new tenant through these states: domain added, DNS records published, SPF and DKIM passing, DMARC present, contacts and suppressions imported (D2), shadow send verified (D2), cut-over, first 10,000 sends.
  - Poll DNS through `crates/dns-resolver`, and show the exact missing record with copy-ready values, plus instructions for the tenant′s DNS host when the S11 check can detect it.
  - Give each state a maximum duration. First stall: a product email naming the missing step. Second stall: an entry in the S20 digest and an offer to book a call.
  - Before cut-over, check webhooks, the suppression import and sending limits automatically.
  - Feed milestones into the S12 score and the S23 triggers.
- **Done when:** a staged tenant reaches cut-over with no owner action; a tenant missing a DKIM record gets the exact record within an hour; stalls appear in the digest.
- **Verify:** an integration test of the state machine against the T6 stack′s fake DNS zone; `cargo test -p sales-autopilot onboarding`.

S23 · Expansion, renewal and churn rescue

- **Depends on:** S7, S12, S17.
- **Now:** S12 prompts an upgrade at 80% of quota. `billing-service` already runs renewals and dunning. Nothing offers add-ons from usage, warns before an annual term ends, or acts on churn risk.
- **Do:**
  - Offer add-ons from usage, each as an in-band S17 payment link: a dedicated IP when volume passes its threshold with low complaints; EU-only routing when the tenant is regulated or asks about data location; archive and journaling when compliance signals appear.
  - Annual renewals: notices at 60, 30 and 7 days with the invoice and a payment link, plus an in-band multi-year offer.
  - Churn risk: a calibrated probability of cancelling within 60 days (S7 method), from falling volume, bounce spikes and unanswered support threads. Above the threshold, send a rescue offer from the price band, such as a lower plan or one discounted month.

  - Cancellation stays one click and is never gated behind an offer (H1).
  - Add net revenue retention and gross churn to the weekly autonomy report.
- **Done when:** a simulated tenant crossing a threshold receives one in-band offer; renewal notices fire once per term; a test proves a tenant can cancel without seeing an offer.
- **Verify:** `cargo test -p sales-autopilot expansion`; `cargo test -p billing-service renewal`.

S24 · Referral and partner engine

- **Depends on:** E1, S17, S21.
- **Now:** no referral or partner program exists. `compliance/src/metrics_activation.rs` records an `acquisition_source` that can already carry "referral".
- **Do:**
  - Give every tenant a referral link. When a referred signup pays its first invoice, both sides get an invoice credit, posted through `crates/accounting-core`. Attribution uses the code in the signup URL, stored on the account, with no tracking cookies.
  - Run a partner program for agencies, MSPs and compliance consultants: self-serve application, owner approval once per partner, a partner console built on `enterprise` subaccounts, and revenue share recorded per paid invoice.
  - Produce monthly partner statements and a payout batch as a SEPA credit-transfer file (pain.001) that the owner approves once a month.
  - Give partners the S21 packs and S15 canonical answers as their sales kit.
- **Done when:** a referred signup's first paid invoice creates both credits with balanced postings (I3); a partner statement equals the sum of its invoices; the payout file validates against the pain.001 schema.
- **Verify:** `cargo test -p billing-service referral`; `cargo test -p accounting-core`.

T — Tests and enforcement (22 Oct audit)

These packages make tests binding: a test counts only when a required lane runs it and the signed blessing records that lane. Invariant IDs (I1–I22), tiers and per-crate additions are in the Tests & enforcement tab. The tests are specified here, not yet written.

T1 · Lane-level, signed gate blessing

- **Now:** `.gate-blessing.json` records stage statuses only and is unsigned (`ci/pipeline.sh:459–463`, checked in `ci/lib.sh:381–414`). Off the deploy host, `ci_have_tool` warns and returns success when a tool is missing unless `CI_MISSING_TOOLS=fail` (`ci/lib.sh:566–585`). Gitleaks, cargo-audit, cargo-vet, Semgrep, two Trivy scans and llvm-cov use it (`ci/stages/security.sh:55, 82, 124, 144, 178, 207`; `ci/stages/test.sh:364`).
- **Why first:** GitHub branch protection was retired at `61e3db3`; `main` is unprotected by decision and `scripts/verify-branch-protection.sh` is deleted. The blessing the deploy host checks is now the only thing between a commit and production, and today it is unsigned and records stage status only.
- **Do:**
  1. Record every lane in the blessing: name, `run`, `skip` or `fail`, tool version, duration.
  2. Refuse to write a blessing unless `CI_MISSING_TOOLS=fail` and every lane in a committed `ci/required-lanes.txt` ran and passed.
  3. Sign the blessing with an Ed25519 key held only on the CI machine; the deploy host verifies the signature and the lane list.
  4. An advisory lane needs an entry in `ci/waivers.toml` (lane, reason, owner, expiry at most 14 days out); an expired waiver fails the run.
- **Done when:** a run with a missing scanner writes no blessing; a tampered, unsigned or lane-incomplete blessing is refused; an expired waiver fails the run.
- **Verify:** new cases in the blessing self-test in `ci/pipeline.sh`, next to the existing `deadbeef` cases (lines 765–779).

T2 · Required per-crate coverage floors

- **Now:** `CI_COVERAGE_CHECK=advisory` (`ci/pipeline.conf:73`), with one workspace number in `ci/coverage-baseline.txt`.
- **Do:**
  1. Make the coverage lane required on the CI machine.
  2. Add `ci/coverage-floors.toml` with line and region floors per crate, seeded from the first required run.
  3. Floors only rise. A drop in any crate fails unless a waiver covers it; raise a floor in the same change as the tests that earned it.
  4. Tier-1 crates must also keep full coverage of changed lines that are reachable by tests (diff coverage).
- **Done when:** deleting a test in a tier-1 crate fails the run.

- **Verify:** `cargo llvm-cov nextest --workspace` on the CI machine; the floor checker's `--self-test`.

T3 · Mutation testing that binds

- **Now:** `services/mail-server/mutants.toml` declares mutation testing manual only. The dogfood harness's 23 seeded mutations (`tools/dogfood-v2/mutations/M01–M23`) run only by hand.
- **Do:**
  1. On every change, run `cargo mutants --in-diff` on tier-1 crates. A surviving mutant in changed lines fails the lane.
  2. Weekly, run full `cargo mutants` per tier-1 crate and store each crate's mutation score; scores only rise, as in T2.
  3. Weekly, run the dogfood `--mutation-test` battery against the T6 stack; every seeded mutation must be caught.
- **Done when:** a deliberately weakened assertion in a tier-1 crate fails the per-change lane.
- **Verify:** lane logs on the CI machine.

T4 · Property tests for money, routing, receipts and limits

- **Now:** the workspace has 8 property-test uses, all in `crates/fuzz-tests`.
- **Do:** add `proptest` suites with committed regression files for:
  1. I1: invoice totals equal the sum of lines, rounded per line to the cent, in one currency (`billing-common`, `billing-service`, `accounting-core`).
  2. I2: a cancelled subscription is never charged again, under any order of cancel, resume, renewal and webhook events.
  3. I3: the ledger balances, and each Adyen webhook applies at most once under duplicates and reordering.
  4. I4: an EU-only tenant's message never gets a non-EU hop, for every routing-policy combination.
  5. I5: receipts verify after signing and fail after any field changes.
  6. I6: a suppressed address is never sent to, on any send path.
  7. I10: no contact is allowed without an authoritative, approved, in-date policy row.
  8. I21: rate limits hold under concurrency, and queue claims are exactly-once.
- **Done when:** each listed invariant has a property test that the normal test lane runs.
- **Verify:** `cargo test --workspace`.

T5 · All-routes auth and tenant-isolation matrix

- **Now:** 57 cross-tenant tests cover chosen routes. The dogfood harness has authz probes, but its live battery is off in CI (`CI_DOGFOOD_LIVE=0`).
- **Do:**
  1. At test time, enumerate every route from the routers of api-server, billing-service, tracking-service, sales-autopilot and the control plane.
  2. Commit `tests/authz-matrix.toml`: per route, the expected status for anonymous, wrong-tenant key, read-only key, member, admin, control-plane operator, expired session and sandbox key.
  3. Run the matrix in process against two seeded tenants. A route with no matrix row fails the test.
- **Done when:** re-applying dogfood mutations M01, M02, M12, M13 or M22 makes plain `cargo test` fail.
- **Verify:** `cargo test -p api-server authz_matrix`.

T6 · Live end-to-end lane: dogfood battery and product journeys

- **Now:** `CI_DOGFOOD_LIVE=0` by design. The required browser lane runs `tests/browser/specs` against the KiwiCaptcha PHP port only (`tests/browser/playwright.config.mjs:4, 12`). ApexMail's journeys (`journey-flows.mjs`, `member-journey.mjs`, `cp-*.mjs`) are manual scripts.
- **Do:**
  1. On the CI machine, boot an ephemeral stack: Postgres, Redis, ClickHouse, a local SMTP sink, a fake DNS zone, Adyen's test endpoint, and an SES stub that records calls.
  2. Run the live dogfood battery against it.
  3. Turn the journey scripts into Playwright specs with assertions: sign up, verify a domain, create an API key, send, receive the webhook, suppress, upgrade through Adyen test, cancel, resume, export data, delete the account.
  4. Replay a legitimate-traffic corpus (recorded browser sessions, health probes, a steady API client) through waf-engine, ddos-protection and rate-limiter. Any block or throttle fails the lane. The 22 Oct live sweeps found exactly these failures by hand (`a2f3b08`).
  5. For EU-only tenants, assert that the SES stub received no calls (I4).
  6. Make the lane required and record it in the blessing (T1).
- **Done when:** breaking the handler behind any journey step fails the lane.
- **Verify:** the lane log and Playwright report on the CI machine.

T7 · Coverage-guided fuzzing for every parser

- **Now:** `crates/fuzz-tests/fuzz` has two cargo-fuzz targets, `fuzz_imap_response` and `fuzz_mail_proto`, and nothing runs them.
- **Do:**
  1. Add targets for: the SMTP command parser (`mta`), MIME and header parsing, DKIM, SPF and DMARC record parsers, the IMAP command parser (`imap-server`), Adyen HMAC and SES/SNS webhook verification, the template parser, compat-endpoint JSON (D1), the CSV importer (D2), and the tracking-token decoder.
  2. Run each target for 10 minutes nightly on the CI machine, with a committed corpus.
  3. Every crash becomes a committed regression test before its fix merges.
- **Done when:** all targets run nightly, and a seeded crashing input produces a failing regression test.
- **Verify:** `cargo +nightly fuzz run <target> -- -max_total_time=600`.

T8 · OpenAPI and router drift gate

- **Now:** `crates/compliance/src/openapi_contract.rs` checks that required documentation sections exist. It does not compare the spec with the routes.
- **Do:**
  1. Extract (method, path) pairs from the routers, reusing T5's enumeration.
  2. Fail when a route is missing from the OpenAPI spec, or a spec path has no route.
  3. Validate response bodies against the spec's schemas during the T6 journeys.
- **Done when:** adding a route without a spec entry fails CI.
- **Verify:** `cargo test -p compliance openapi`.

T9 · SDKs against a live API, then published

- **Depends on:** T6, D3.
- **Now:** the six SDKs (Go, Java, PHP, Python, Ruby, TypeScript) test mocked payload contracts, and none has a publish lane.
- **Do:**
  1. Run each SDK's suite against the T6 stack with a sandbox key.
  2. Validate requests and responses against `packages/contract/send-contract.json` and the OpenAPI spec.
  3. Add publish lanes that run only from a signed blessing: npm with provenance, PyPI trusted publishing, RubyGems, Maven Central, Packagist and a Go module tag. Versions follow `packages/VERSIONING.md` and `packages/check_versions.py`.
- **Done when:** all six suites pass against a live api-server, and one tag publishes all six.

- **Verify:** lane logs and the registry pages.

T10 · Every gate proves it can fail

- **Now:** at `61e3db3`, 20 of 55 Python tools have a self-test. CI runs 41 tools, and 22 gates among them have none: 17 Python (`check_audit_coverage`, `check_cargo_cycles`, `check_claim_expiry`, `check_flash_copy`, `check_outbound_delivery_contract`, `check_rust_panic_paths`, `check_topology_contracts`, `check_ui_a11y`, `check_ui_form_hygiene`, `check_ui_links`, `check_ui_terminology`, `extract_ui_strings`, `generate_repo_map`, `i18n-audit`, `migration_lint`, `validate_legal_identity`, `validate_security_feature_flags`) and 5 shell (`check-forbidden-patterns.sh`, `check-kiwi-marketing-isolation.sh`, `check-risk-lua-parity.sh`, `docs-lint.sh`, `validate-prod-env.sh`). Separately, `validate_pricing_drift.py:880` requires the stale "Adyen billing portal" sentence.
- **Do:**
  1. Give each tool CI invokes a `--self-test` with a known-bad fixture that must fail and a known-good fixture that must pass.
  2. Add `tools/check_gate_selftests.py`: it lists every tool invoked from `ci/` and fails when one has no self-test, or when its self-test passes on the known-bad fixture.
  3. Make line 880 require the sentence's absence, then fix `pricing-faq-island.html:31`, the stale UI baselines and the contrast fixtures.
- **Done when:** the meta-gate is green and required.
- **Verify:** `python3 tools/check_gate_selftests.py`.

T11 · Personal-data map and erasure completeness

- **Now:** the erasure map in `crates/compliance/src/gdpr_automation.rs` covers events, contacts, consent, messages, users and invoices, but not `mail_journal` (migration 264). Journal retention defaults to forever.
- **Do:**
  1. Commit `docs/data-map.toml`: every table and column holding personal data, with legal basis, retention and erasure action (`delete`, `anonymise`, or `retain` with a reason).
  2. Add `tools/check_data_map.py`: it scans migrations for personal-data columns (email, name, phone, IP, postal address, message body) and fails when one is missing from the map.
  3. A DSR test seeds one subject across every mapped table and asserts each row's outcome after erasure.

4. Make journal retention configurable per tenant, record the legal-hold reason, and list retained stores in the erasure response.

- **Done when:** a migration that adds an `email` column without a map entry fails CI, and the DSR test covers `mail_journal`.
- **Verify:** `cargo test -p compliance gdpr`; `python3 tools/check_data_map.py --self-test`.

T12 · Claims match infrastructure and records

- **Now:** `tools/check_capability_claims.py` already fails when a page advertises a capability below the runtime-wired stage in `docs/development/capability-registry.json`. The registry does not record hosting locations, own EU MTAs or the evidence pack. Hosting is Finland-only, yet five pages say "Germany primary, Finland backup". `crates/compliance/src/governance.rs:733-760` seeds SES in `us-east-1` and a transfer record `TIA-AWS-SES-US` from a stale configuration value. Production uses `eu-west-1`, so no US transfer happens and the record is false; because seeding never overwrites a row, fixing the seed alone will not remove one already written.
- **Do:**
  1. Record hosting as Finland-only (Hetzner) in the registry, so any page naming another hosting location fails; today that catches "Germany primary, Finland backup" on five pages, which should say Finland. Add entries for "own EU MTAs", "evidence pack" and "DORA/NIS2 evidence" at their true stages (B2, B6).
  2. Record each host's provider, location and role in `docs/development/topology-manifest.json`, and fail when a page names a location the manifest lacks.
  3. Derive the governance register's subprocessor locations and transfers from configuration (`AWS_REGION`, transport type), and fail CI when the seed disagrees with `.env.production.example`.
  4. Ship a forward migration that deletes the seeded `TIA-AWS-SES-US` row and corrects the SES subprocessor location to `eu-west-1`, unless Legal has edited those rows.
- **Done when:** `eu-sovereign/index.md:13` as it stands fails the gate, the governance seed says `eu-west-1` with no transfer record, and the production register lists no US transfer.
- **Verify:** `python3 tools/check_capability_claims.py`; `cargo test -p compliance governance`.

T13 · Restore, failover and load as scheduled tests

- **Depends on:** A3, A5.

- **Now:** no automated restore drill exists. The load test runs inside the workspace suite with a floor of 12,000 ops/s (`CI_LOAD_TEST_OPS_FLOOR`) on a machine shared with other tests.
- **Do:**
  1. Nightly, restore the latest backup on an isolated EU restore host (never the CI machine, which must not hold production data), apply pending migrations, and check row counts and checksums of key tables.
  2. Measure restore time against the stated recovery-time objective and fail when it is exceeded.
  3. Once A3′s second host exists, run a monthly failover test.
  4. Move load tests to their own lane against the T6 stack with an SLO file (send-API p95 latency, sends per second, per-tenant isolation). Fail on a regression above 10% from the median of the last 7 runs.
- **Done when:** a corrupted backup fails the drill, and an injected 20% slowdown fails the load lane.
- **Verify:** the drill log and the load lane report.

T14 · Invariant and expectations registry

- **Do:**
  - Commit `docs/invariants.toml` : id, statement, domain, tier, test paths, enforcing gate. Seed it with I1–I27 from the Tests & enforcement tab (I22: no send without an active policy pack, S21).
  - Commit `ci/test-expectations.toml` with one entry per ApexMail package (55 crates, six SDKs, smtp-auth-proxy, apps and tools): tier, required test kinds, fuzz targets, property-test modules, and the lane that runs it. KiwiCaptcha is a separate project and is not listed.
  - Add `tools/check_invariants.py` . It fails when an invariant lists no test, a listed test no longer exists, a listed gate is not required, a package is missing from the expectations file, or a declared kind is absent (no `proptest` in a crate that must have one, no fuzz target for a declared parser).
  - Run it in the validate stage, and record its result in the blessing (T1).
- **Done when:** every invariant maps to passing tests and required gates, and adding a crate without an expectations entry fails CI.
- **Verify:** `python3 tools/check_invariants.py --self-test` .

T15 · Statistics tests for the sales engine

- **Depends on:** S1–S5.

- **Do:** add simulation tests with fixed seeds:
  1. Posterior: with known true reply rates, posterior means converge, and alpha plus beta minus the prior equals exposures (I13).
  2. Holdout: hash-based assignment is stable across runs, its share stays within tolerance, and no holdout account is ever contacted.
  3. Off-policy: IPS and doubly robust estimates are unbiased on simulated logs with known propensities.
  4. Sequential tests: under the null, the false-positive rate stays at or below α across 10,000 simulated experiments.
  5. Calibration: Brier score and a calibration curve for each scoring model on a held-out month.
- **Done when:** these run in the normal test lane in under 2 minutes.
- **Verify:** `cargo test -p sales-autopilot stats_sim`.

T16 · smtp-auth-proxy and AI training tests

- **Now:** at `61e3db3`, `smtp-auth-proxy` has 1 test, and `apps/ai/training` has 26 test functions that CI only compiles. KiwiCaptcha is a separate project, tested in its own repository, and out of scope here.
- **Do:**
  - smtp-auth-proxy: tests that it refuses unauthenticated relay, requires TLS and accepts valid credentials.
  - apps/ai: move the evaluation scripts into a pytest suite that runs, or retire them.
- **Done when:** both lanes are required and above their floors (T2 rules).
- **Verify:** the package lanes in `ci/stages/test.sh`.

T17 · AI answer evaluation set

- **Depends on:** S15, S19.
- **Do:**
  1. Build an evaluation set of 300 buyer questions (price, DPA, data location, security, migration, deliverability) in four languages, each labelled with the expected canonical-answer id or "route to owner".
  2. Score it weekly and on every change to prompts, models or canonical answers: correct answer, correct hand-off, disclosure present, no uncited claim.
  3. Fail on any uncited claim, or on a drop of more than 2 points in correct-answer rate since the last release.
- **Done when:** the set runs in CI and blocks a seeded prompt regression.

- **Verify:** the evaluation report in the lane log.

V — Deep review fixes

These packages come from the Deep review tab (checked at `61e3db3`); each names the finding IDs it closes. Where an existing package already covers a finding (B2, S1, S10, S19, T7, T8, T10, T12, T13, T14, T15), the finding points there instead. Hosting stays in Finland throughout.

V1 · Adyen live charges that work

- **Findings:** MON-1, MON-2, MON-6, MON-7.
- **Now:** `ADYEN_API_BASE_URL` is `https://checkout-live.adyen.com/v71` in `.env.production.example:163`, `docker-compose.prod.yml:488, 1877` and the fallback in `api-server/src/routes/billing.rs:993–1023`, and `tools/check_prod_billing_wiring.py:38` requires that value. Stored-card charges in `billing-service/src/maintenance.rs:5016–5027` and `overage.rs:2346–2357` send no `shopperInteraction`. A non-hex webhook key is used as raw bytes (`adyen_webhooks.rs:292–295`).
- **Do:**
  1. **Owner:** copy the live URL prefix from the Adyen Customer Area (Developers, API URLs) and switch on the `RECURRING_CONTRACT` webhook event.
  2. Set the live URL to `https://<prefix>-checkout-live.adyenpayments.com/checkout/v71` (a placeholder in the env example), remove the code fallback, and make the gate accept only that pattern.
  3. Build every stored-card payment body in one function that always sets `shopperInteraction: "ContAuth"`, `recurringProcessingModel` and `shopperReference`.
  4. Refuse to start in production when the webhook HMAC key is not hex.
  5. Capture notifications from the test account for a first checkout, a renewal, a refund, a chargeback and a token event, replay them in tests, and fix routing if the first payment lands in the renewal handler.
- **Done when:** the gate fails on `checkout-live.adyen.com`, every replayed fixture reaches its intended handler, and a body test asserts `ContAuth`.
- **Verify:** `python3 tools/check_prod_billing_wiring.py`; `cargo test -p billing-service adyen`.

V2 · Dated VAT rates

- **Findings:** MON-3.
- **Now:** `billing-common/src/vat_rates.rs:59` holds Romania at 19%; the table has no dates.
- **Do:**
  1. Store each rate with `valid_from` and `valid_to`, and pick the rate in force on the invoice's tax point. Romania: 19% until 31 July 2025, 21% from 1 August 2025.
  2. Add a monthly scheduled comparison with the European Commission's VAT rates database that alerts on any difference.
  3. **Owner:** check whether any Romanian consumer invoice was issued since 1 August 2025 and ask the accounting service how to correct it.
- **Done when:** tests price a Romanian consumer at 19% on 31 July 2025 and 21% on 1 August 2025.
- **Verify:** `cargo test -p billing-common vat`.

V3 · Refunds and chargebacks that reach the books

- **Findings:** MON-4.
- **Depends on:** V1.
- **Now:** `REFUND` and `CHARGEBACK` only write an audit row and notify (`adyen_webhooks.rs:1035–1140`); admin credit notes go to the wallet (`api-server/src/routes/billing.rs:4936–4945`).
- **Do:**
  1. On `REFUND`: issue a credit note against the invoice, post the reversal in `accounting-core`, and adjust VAT in the period of the refund.
  2. On `CHARGEBACK`: the same, plus pause paid features and notify the owner; handle `CHARGEBACK_REVERSED` and `REFUND_FAILED`.
  3. Add an operator refund-to-card action through Adyen's refunds endpoint.
- **Done when:** end-to-end tests for each event leave a balanced trial balance and the next KMD shows the adjustment.
- **Verify:** `cargo test -p billing-service refund chargeback`; `cargo test -p accounting-core`.

V4 · Real invoice PDFs, stored in Finland

- **Findings:** MON-5.
- **Depends on:** V24.

- **Now:** the customer "PDF" route returns HTML (`api-server/src/routes/billing.rs:73, 3658`); `generate_invoice_pdf` has no production caller and defaults to AWS S3 in Frankfurt (`billing-service/src/invoices.rs:43, 64–66, 782`).
- **Do:**
  1. Render the invoice with `pdf-renderer` when it is issued, and store it once, immutable, in Postgres or Hetzner Object Storage in Helsinki.
  2. Remove the AWS default; require an explicit storage endpoint in production.
- **Done when:** the download returns `application/pdf`, the stored bytes never change after issue, and no AWS host remains in defaults.
- **Verify:** `cargo test -p billing-service invoice_pdf`.

V5 · SAML that works with real identity providers

- **Findings:** SEC-1, WEB-4.
- **Now:** `enterprise/src/sso.rs:194–252` accepts only `ds:Reference URI=""`; standard IdPs sign `URI="#<ID>"`.
- **Do:**
  1. Accept `URI="#ID"` only when the ID belongs to the Response or to its single Assertion; refuse duplicate IDs and more than one Assertion.
  2. Read claims only from the signed element, and check Audience, Recipient, `NotOnOrAfter` and `InResponseTo`.
  3. **Owner:** create free test tenants (Entra ID, Okta developer) and capture one signed response each; add Google Workspace if available and a local Keycloak.
  4. Add signature-wrapping tests (a second unsigned Assertion, a moved signature, a duplicated ID).
- **Done when:** every captured IdP response logs in and every wrapping case is refused.
- **Verify:** `cargo test -p enterprise saml`.

V6 · Offsite backups and point-in-time recovery in Finland

- **Findings:** OPS-1, SEC-7.
- **Now:** `BACKUP_TARGET` is empty (`.env.production.example:533–539`); dumps use AES-256-CBC without authentication; no WAL archiving.
- **Do:**
  1. **Owner:** order a Hetzner Storage Box in Helsinki and give the backup containers an SSH key for it.

2. Set `BACKUP_TARGET`; encrypt with `age`; refuse to write an unencrypted backup in production.
3. Add continuous WAL archiving (WAL-G or pgBackRest) to the Storage Box; send ClickHouse and Redis backups there too.
4. Verify the newest offsite copy every day by decrypting and listing it.

- **Done when:** a point-in-time restore from the Storage Box to a scratch host succeeds, with data loss under five minutes (T13 runs it monthly).
- **Verify:** the restore drill log.

V7 · Advisories and the old TLS stacks

- **Findings:** DEP-1, DEP-2, DEP-3, DEP-4, DEP-5.
- **Do:**
  1. `cargo update -p webpki-roots -p rustls-webpki` (to 1.0.10 and 0.103.16); review and list the 0.101 case.
  2. Switch the AWS SDK to its current HTTPS client and upgrade `mail-auth` with `mail-send`, retiring `rustls` 0.21, `hickory` 0.24, `h2` 0.3 and `hyper` 0.14.
  3. Replace `imap` 2.4 and the vendored `imap-proto` with a maintained client on rustls.
  4. Add `rust-toolchain.toml` pinned to 1.97.1; decide the Axum 0.8 move in one change.
  5. Run `npm audit`, `pip-audit`, `govulncheck` and `bundler-audit` for the SDKs in CI.
- **Done when:** `cargo audit` passes on a fresh advisory database and every remaining ignore carries a review date.
- **Verify:** `cargo audit`; the SDK audit lane.

V8 · Container hardening for every service

- **Findings:** SEC-4.
- **Now:** mailstore, status-server, migrator and the backup containers lack `read_only` and `no-new-privileges`; no service drops capabilities.
- **Do:**
  1. Give every service `read_only: true` with tmpfs where needed, `no-new-privileges` and `cap_drop: [ALL]`, adding back only `NET_BIND_SERVICE` where a port below 1024 is bound.
  2. Add `tools/check_compose_hardening.py` with a self-test, run on the merged compose.
- **Done when:** the gate is green and required, and every service starts.
- **Verify:** `python3 tools/check_compose_hardening.py --self-test`.

V9 · Checked queries, caught panics, no silent test skips

- **Findings:** SEC-5, API-2; the SQL gaps on the Security page.
- **Now:** 2,226 runtime-checked queries, 227 built with `format!`, no `CatchPanicLayer`, and database tests that skip when no database is reachable.
- **Do:**
  1. Check every query against the migrated schema in CI (`sqlx` offline data, or a test that runs `EXPLAIN` on each).
  2. Lint `format!` SQL so only allow-listed identifiers are interpolated.
  3. Add `CatchPanicLayer` with a panic metric to every Axum service; deny `clippy::unwrap_used` and `clippy::expect_used` in handler modules.
  4. In the database lane, count skipped tests and fail when any test skipped.
  5. When Redis is unreachable, fall back to a bounded in-process rate limiter so sending continues; keep session revocation fail-closed, and alert while the fallback is active.
- **Done when:** renaming a column fails CI, a panicking handler returns 500, and the database lane reports zero skips.
- **Verify:** the CI database lane report.

V10 · Row-level security on tenant tables

- **Findings:** DP-7; the tenant-scoping gap on the API page.
- **Depends on:** V9.
- **Now:** 221 of 373 tables carry `tenant_id`; no table has an RLS policy; the isolation service runs but has no caller.
- **Do:**
  1. Enable RLS in batches, mail content and contacts first: `USING (tenant_id = current_setting('app.tenant_id'))`.
  2. Set `app.tenant_id` per transaction in `apexmail-db` and in every crate that opens its own pool; give the operator control plane a separate role for its cross-tenant reads.
  3. Use the isolation crate's policy generator for the migrations, then remove the isolation container if nothing else needs it.
- **Done when:** a query run without `app.tenant_id` returns no rows from a protected table, and the cross-tenant suite passes.
- **Verify:** `cargo test -p api-server tenant_isolation`.

V11 · A second, small Helsinki VM for status, alerts and builds

- **Findings:** OPS-2, OPS-3.

- **Now:** the status page, synthetic monitor and Alertmanager run on the production host; every alert destination is empty; the production host builds its own images.
- **Do:**
  1. **Owner:** create a small Hetzner Cloud VM in Helsinki and choose one alert channel that reaches your phone.
  2. Move `status-server` there, fed by external probes of the API, SMTP 25, 587 and 465, IMAP 993 and tracking.
  3. Run Alertmanager there with that channel configured; keep the main host's alerts flowing to it.
  4. Run A1's build and test lanes there, push images to a private registry on the VM, and deploy to production by digest.
- **Done when:** stopping nginx on the main host raises an alert within five minutes and the status page shows it; the production host has no Rust toolchain.
- **Verify:** a fire drill log.

V12 · Config manifest, connection budget, dead crates and docs

- **Findings:** OPS-4, OPS-5, OPS-7, OPS-8, SAI-5, SAI-6.
- **Now:** 252 of 380 variables appear in neither compose nor the env file; four services ask for 50 connections each against Postgres' default 100; five crates ship nothing.
- **Do:**
  1. Generate `docs/config-manifest.json` (variable, crate, default, production value, owner) and fail CI when code reads a variable without an entry.
  2. Give each service a pool size that sums below `max_connections` minus a reserve, or put PgBouncer in transaction mode in front of Postgres; add a gate on the sum.
  3. Delete `devex-service`, `edge-cases`, `ai-embeddings`, `pattern-matcher` and `queue-provider`, or give each a production user (decide the security crates with G2); add a crate-reachability gate.
  4. Fix the migrator docs that cite `.github/workflows`, the `sales-knowledge` doc that names `billing-service/src/plans.rs`, and delete `Role::from_plan`.
- **Done when:** all three gates are green and required.
- **Verify:** `python3 tools/check_config_manifest.py --self-test`.

V13 · Inbound mail filed per tenant

- **Findings:** DEL-2.
- **Now:** `mta/src/servers/inbound.rs:1717-1727` takes the tenant from the first recipient; the webhook lists every envelope recipient (`:2018-2050`).

- **Do:**
  1. At DATA, group recipients by owning tenant and write one `inbound_messages` row per tenant holding only that tenant's recipients.
  2. Queue one webhook per tenant with only its recipients.
- **Done when:** a test transaction to two tenants with a Bcc gives each tenant only its own recipients and its own webhook.
- **Verify:** `cargo test -p mta two_tenant`.

V14 · Inbound filtering that protects mailboxes

- **Findings:** DEL-3, SEC-3, SEC-6.
- **Now:** spam and IDS are tag-only, only DMARC quarantine reaches the Spam folder, the Bayesian model is empty, no antivirus runs, and threat-intel feeds are unset.
- **Do:**
  1. File messages whose spam score passes a threshold into the Junk folder; keep rejection off.
  2. Ship a trained base model, persist per-tenant models, and train from users moving mail into and out of Junk over IMAP.
  3. Run ClamAV as a container on the Finland host and wire `ClamAvSocketAnalyzer`; set the attachment mode to `strip` for detected malware.
  4. Configure the URLhaus and ThreatFox feeds, or switch the lookups off.
- **Done when:** a scored spam lands in Junk, an EICAR attachment is stripped, and the spam corpus test passes its accuracy floor.
- **Verify:** `cargo test -p mta junk eicar`; `cargo test -p spam-filter corpus`.

V15 · Retry budgets, implicit MX and DSN codes

- **Findings:** DEL-4, DEL-5.
- **Now:** 12 attempts, 5 minutes doubling to a 4-hour cap, about 25 hours in all (`outbound-mta/src/retry.rs:186-197`); no implicit MX (`mx.rs:9-10, 50`); domain failures reported as `5.1.1` (`relay.rs:1809`).
- **Do:**
  1. A retry budget per message category: short for one-time codes, four to five days for the rest; a delay notice and webhook at four hours.
  2. Use the A/AAAA record as an implicit MX per RFC 5321 §5.1, or document the deviation on the deliverability page.
  3. Report `5.1.2` for an unroutable domain and `5.1.10` for a null MX.
- **Done when:** a table test pins each category's window and the DSN codes.

- **Verify:** `cargo test -p outbound-mta retry mx dsn`.

V16 · Load tests on the real send path

- **Findings:** DEL-7.
- **Depends on:** T6.
- **Now:** `load-tests` and `smoke-tests` exercise `queue-provider`, which production never uses.
- **Do:**
  1. Drive load through `POST /v1/messages` into the real `email_queue` claim, including lease expiry under load.
  2. Feed the results into T13's load lane, then delete `queue-provider` (V12).
- **Done when:** the load lane reports send-path throughput and p95 latency from the real claim.
- **Verify:** the load lane report.

V17 · Routing receipt v2 and key history

- **Findings:** DEL-8.
- **Depends on:** B3.
- **Now:** the signed payload omits the routing mode, the receiving host and a message digest (`mail-common/src/routing_receipt.rs:24-33`); only the current key is published (`api-server/src/routes/routing.rs:79, 124-160`).
- **Do:**
  1. Add `apexmail-routing-receipt/v2` with `routing_mode`, `relay_host`, `recipient_mx` and `sha256` of the delivered message; keep verifying v1.
  2. Publish every key with its validity window at a key-history endpoint, and the current fingerprint in DNS and on the EU-sovereign page.
  3. Publish test vectors (fixed key, payload, signature) for third-party verifiers.
- **Done when:** a v2 receipt from an EU-only send verifies against the published key and names the route; a receipt signed under a rotated key still verifies.
- **Verify:** `cargo test -p mail-common receipt`.

V18 · Honest open tracking

- **Findings:** DEL-6.
- **Now:** `tracking-service/src/bot.rs:27-30, 67-68, 112-116` drops Gmail, Yahoo and Outlook-desktop image loads as bots; Apple privacy prefetches count as human opens.

- **Do:**
  1. Record every open with a class: human, mailbox proxy (Gmail, Yahoo), privacy prefetch (Apple), security scanner.
  2. Report "opens" as human plus mailbox proxy, and show prefetches separately; keep scanners out of clicks.
- **Done when:** fixtures for each class land in the right counter.
- **Verify:** `cargo test -p tracking-service open_class`.

V19 · Encrypt and expire the inbound copy

- **Findings:** DEL-9.
- **Now:** `inbound_messages` keeps raw MIME, bodies and headers in plaintext with no retention window (`mta/src/servers/inbound.rs:1842-1880`; `compliance/src/retention_sweep.rs:130-176`).
- **Do:**
  1. Encrypt `raw_message`, `body_text`, `body_html` and `headers` with the mailstore envelope scheme (scope-bound additional data).
  2. Null the content once every recipient job is delivered or terminal; keep the metadata the reply pipeline needs.
  3. Add the table to the retention sweep with the tenant's window, and to the erasure map (V23).
- **Done when:** a delivered message's row holds no plaintext body, and a row past its window is purged.
- **Verify:** `cargo test -p mta inbound_retention`; `cargo test -p compliance retention_sweep`.

V20 · One published API spec, generated from the router

- **Findings:** API-3, API-6, WEB-6.
- **Unlocks:** T8, T9.
- **Now:** the published spec (22 paths) lists seven unrouted paths; `docs/api/openapi.yaml` (203 paths) differs; `devex-service` carries a third description.
- **Do:**
  1. Generate the spec from the Axum routers (`utoipa` or `aide`) and publish that one file at `/specs/openapi.yaml`.
  2. Delete `docs/api/openapi.yaml` and `devex-service` (or fold its webhook tester into api-server).

3. Generate the SDKs from the spec where practical; T8 then gates drift and T9 publishes.

- **Done when:** the published spec and the router match exactly.
- **Verify:** T8's gate.

V21 · Webhooks that are easy to switch to

- **Findings:** API-4, API-5.
- **Now:** events arrive only in ApexMail's shape; `X-ApexMail-Delivery-Id` changes on every attempt (`worker-processors/src/webhook/processor.rs:673, 705-711`).
- **Do:**
  1. Send a stable event id (the queue row id) on every attempt, and offer Standard Webhooks headers (`webhook-id` , `webhook-timestamp` , `webhook-signature`).
  2. Add a per-endpoint payload format: `apexmail` , `sendgrid` , `postmark` , `mailgun` , `resend` , mapped from the canonical event.
- **Done when:** two attempts of one event carry the same id, and each format validates against the provider's published event schema.
- **Verify:** `cargo test -p worker-processors webhook_format` .

V22 · Credential cleanup and passkeys

- **Findings:** API-1, API-7.
- **Now:** three API-key hash formats are accepted (`api-server/src/middleware/auth.rs:490-491, 556, 641-690`); the only second factor is TOTP.
- **Do:**
  1. Re-hash a legacy key on its next successful use, expose a count of legacy keys, and remove the fallbacks when it reaches zero.
  2. Add WebAuthn passkeys for console login, required for operator accounts.
- **Done when:** the legacy count is zero and the fallbacks are gone; an operator cannot log in without a passkey.
- **Verify:** `cargo test -p api-server legacy_key passkey` .

V23 · Data subject requests that cover every store

- **Findings:** DP-1, DP-2, SAI-3. Extends T11, which owns the data map, its gate and journal retention (DP-3).
- **Depends on:** V19.

- **Now:** `compliance/src/gdpr_automation.rs:2820–2900` never mentions a sales table, `inbound_messages` or `email_queue`; ClickHouse erasure is off in production; the mail journal has no default window.
- **Do:**
  1. Add `sales_leads`, `sales_accounts`, `sales_contacts`, `sales_contact_points`, the evidence and signal tables, `inbound_messages` and `email_queue` to both the access and erasure maps.
  2. On erasure of a prospect, keep a keyed hash in suppressions and set the contact to `do_not_contact`.
  3. Turn on `GDPR_CLICKHOUSE_ERASURE_ENABLED` and wait for the mutation to finish, or store a keyed hash instead of the address in ClickHouse.
  4. Add every store above to T11′s data map with its erasure action.
  5. Extend T11′s DSR test to seed one prospect across every sales store, their replies and the mail sent to them.
- **Done when:** a seeded prospect′s access request returns their sales profile, erasure removes it, and T11′s gate lists every one of these stores.
- **Verify:** `cargo test -p compliance dsr_prospect`.

V24 · Finland in the configuration and the register

- **Findings:** DP-4, DP-6, WEB-1.
- **Complements:** T12, which gates the page text.
- **Now:** `HETZNER_DEFAULT_LOCATION` defaults to `fsn1` in `api-server/src/ip_provider.rs:1525`, `docker-compose.prod.yml:454` and `.env.production.example:456`; `tools/generate_subprocessors.py:129–135` defaults to `fsn1` and publishes Germany; the generator has no entry for `AI_MODEL_ENDPOINT`; Datadog streaming is fixed to the US intake.
- **Do:**
  1. Set `hel1` in code, compose and the env file; refuse any other Hetzner location at startup and in a gate.
  2. Make the generator read the production location, regenerate the register, and add the AI endpoint (EU-only routing requires an EU endpoint).
  3. Let tenants choose the Datadog site, with `datadoghq.eu` as the default.
  4. Replace "Germany primary, Finland backup" with "hosted in Finland (Hetzner, Helsinki)" on every page T12 lists, the privacy policy and the DPA.
- **Done when:** the gate fails on `fsn1` anywhere and the register says Finland.
- **Verify:** `python3 tools/generate_subprocessors.py --check`; T12′s gate.

V25 · One internal credential per service

- **Findings:** SEC-2.
- **Now:** eleven services share `internal_service_token` (`mail-common/src/internal_auth.rs:62-66`).
- **Do:**
  1. Issue one token per calling service as its own Docker secret.
  2. Give each callee an allow-list of callers: mailstore accepts only mta and imap-server; billing only api-server, mta and worker.
- **Done when:** a call to mailstore with ai-service's token is refused.
- **Verify:** `cargo test -p mail-common internal_auth`.

V26 · Public claims that match the product

- **Findings:** WEB-2, WEB-3, WEB-4.
- **Do:**
  1. Remove DANE and MTA-STS from the home features card (English fallback and `data/i18n.json` German) until B2 ships.
  2. Use the accurate German transport wording in every language; claim message-content encryption at rest only after V19.
  3. Until V5 ships, describe SSO as "OIDC; SAML on request".
  4. Add each claim to `docs/development/capability-registry.json` at its true stage so `tools/check_capability_claims.py` catches regressions.
- **Done when:** the claims gate passes with the new registry entries.
- **Verify:** `python3 tools/check_capability_claims.py`.

V27 · A privacy notice for prospects

- **Findings:** WEB-5, WEB-8.
- **Now:** `privacy/_index.md:22` says prospects' data is provided via forms or email; the objection right lists only legitimate interest (`:73`); response time says 30 days (`:75`).
- **Do:**
  1. Add a prospects section: sources (business registers, company websites, enrichment providers), purposes, legal basis, retention, recipients, and the unconditional right to object to direct marketing.
  2. Link it from every first-touch email (S14).
  3. Say "within one month".
  4. **Owner:** have counsel review the section in each language.
- **Done when:** the page is live in all four languages and first-touch templates link to it.

- **Verify:** a test that every first-touch template contains the link.

Tests & enforcement

Oct 22, 2026 · @Aaron

A test is binding only when a required lane runs it and a signed blessing records the result. Checked at `61e3db3` (22 Oct): 13,403 Rust tests in 55 crates, plus SDK and browser suites. Enforcement is the weak part: coverage is advisory, mutation and live end-to-end runs are manual, two fuzz targets never run, and 22 gates that CI runs have no self-test. GitHub branch protection was retired at `61e3db3` because a one-person repo could only bypass it, so the gate blessing checked by the deploy host is now the only enforcement point. That makes T1 the first package to build.

Enforcement rules

Eight rules turn tests into guarantees; work packages T1–T17 implement them.

1. **Required means recorded.** Required lanes are listed in `ci/required-lanes.txt`. The blessing records every lane's result and is signed on the CI machine, and the deploy host refuses anything else (T1).
2. **Missing tools fail.** Gate runs set `CI_MISSING_TOOLS=fail`; a run that skips a required lane cannot bless (T1).
3. **Advisory needs a dated waiver.** `ci/waivers.toml` holds lane, reason, owner and an expiry at most 14 days out. An expired waiver fails the run (T1).
4. **Ratchets only rise.** Per-crate line and region coverage and per-crate mutation score may not fall without a waiver (T2, T3).
5. **Every gate proves it can fail** on a known-bad fixture (T10).
6. **Every critical invariant names its test and its gate** in `docs/invariants.toml` (T14).
7. **Every package declares what it must prove** in `ci/test-expectations.toml`: tier, required test kinds, fuzz targets, property-test modules. `tools/check_invariants.py` fails when a package is missing from the file or a declared kind does not exist, such as no `proptest` in a crate that must have one (T14).
8. **Tiers set the bar.**
   - Tier 1 (money, legal, routing, auth and tenant isolation, personal data, the sales send path): coverage and mutation ratchets climbing to 95% line coverage and an 80% mutation score, no surviving mutant in changed lines, property tests for its invariants.
   - Tier 2 (mail transport, product features, security filters, support services): coverage ratchet climbing to 90% line coverage, weekly mutation report, fuzzing for any parser. Security filters also need a legitimate-traffic corpus that must pass with

zero blocks.

- Tier 3 (test-only crates): run in a required lane, with every `#[ignore]` carrying a reason and an expiry date.

Critical invariants

Twenty-seven promises the product cannot break. Each needs at least one test that fails when the promise breaks, and a required gate that runs it; T14 turns this table into `docs/invariants.toml`.

ID	Invariant	Code	Test today	Missing	Enforced by
I1	An invoice total equals the sum of its lines, rounded per line to the cent, in one currency	billing-common, billing-service, accounting-core	Unit tests	Property test over random carts, currencies and VAT cases	T4, T2, T3
I2	A cancelled subscription is never charged again	billing-service `subscriptions.rs`, renewal sweep	Cancel and sweep tests (`98a60a5c`); dogfood M23, manual	Property test over any order of cancel, resume, renewal and webhook	T4, T6
I3	The ledger balances, and each payment webhook applies at most once	accounting-core, billing-service	51 tests in accounting-core	Replay test with duplicated and reordered webhooks	T4, T3
I4	An EU-only tenant's message never takes a non-EU hop	routing policy, outbound-mta	Routing tests (B1, B4)	Property test over all policy combinations; SES stub sees no calls	T4, T6
I5	Every routed message has a receipt that verifies, and any change breaks it	receipts (migration 255)	Sign and verify tests	Tamper property test	T4
I6	A suppressed address is never sent to, on any send path	api-server, worker-processors, sales dispatcher, compat endpoints	Dogfood M09, manual	Property test across all send paths	T4, T5
I7	Every route enforces its auth and tenant scope	api-server and services	57 cross-tenant tests; dogfood authz probes, manual	All-routes matrix	T5
I8	A sandbox key sends only to the sink	api-server explorer sandbox	Explorer tests	A matrix row per sandbox route	T5, S18
I9	Erasure removes or anonymises the subject in every store, and retained stores state a reason	compliance `gdpr_automation.rs`	Erasure tests, without `mail_journal`	Data-map completeness gate; seeded DSR test	T11
I10	No contact is allowed without an authoritative, approved, in-date policy row	sales-autopilot `legal_policy.rs`	Exhaustive unit tests of the pure functions	Property test; a test that every send path calls `revalidate_execution`	T4
I11	Every autonomous message carries the AI disclosure and an audit row, and cites canonical ids for price or legal claims	sales-autopilot	None	Send-path test	S19, S15, T17
I12	Discovery never contacts a host outside the allowlist, and a CAPTCHA or robots refusal excludes the host	sales-autopilot `discovery/`	Challenge-detection tests	Exclusion integration test; `check_no_bypass.py`	S10
I13	Posterior counts equal exposures, holdout accounts are never contacted, and sequential tests hold α	sales-autopilot `experiments.rs`	Unit tests	Simulation tests	T15

ID	Invariant	Code	Test today	Missing	Enforced by
I14	Every public capability or location claim matches the topology and readiness stage	marketing site, `capability-registry.json`, `governance.rs`	`check_capability_claims.py`, without location entries	Registry entries; governance seed check	T12
I15	No parser panics on any input	mta, imap-server, mail-proto, edge-cases, webhook handlers	2 fuzz targets, never run; `check_rust_panic_paths`	Nightly fuzzing per parser	T7
I16	Pending migrations apply to a restored backup without data loss	migrator	Migrator tests; `migration_lint`	Restore-and-migrate drill	T13
I17	The latest backup restores within the recovery-time objective	ha, backups	None	Nightly restore drill	T13
I18	Every route is in the OpenAPI spec, and every SDK call reaches a real route	api-server, devex-service, SDKs	Section check in `openapi_contract.rs`; mocked SDK tests	Drift gate; live SDK suites	T8, T9
I19	Every gate fails on its known-bad fixture	`tools/`	20 of 55 Python tools; 22 gates that CI runs have none	Meta-gate	T10
I20	Only a signed, lane-complete blessing deploys	`ci/`	Stage-level, unsigned check	Signed lane-level blessing	T1
I21	No tenant exceeds its rate budget or starves another, and queue claims are exactly-once	rate-limiter, queue-provider	Unit tests; load-isolation test at a 12,000 ops/s floor	Concurrency property tests; SLO lane	T4, T13
I22	No autonomous action happens unless an active, owner-approved policy pack covers the account and the action	sales-autopilot dispatcher (S21)	None (packs not built)	Property test over accounts, actions and pack states; suspension test when a referenced item changes	S21, T14
I23	Hosting and dedicated-IP provisioning stay in Finland, and the public register says so	`api-server/src/ip_provider.rs`; `tools/generate_subprocessors.py`	None	A gate over code, compose, the env file and the generated register	V24, T12
I24	Every stored copy of a message body is encrypted at rest and has a retention window	`mta/src/servers/inbound.rs` (`inbound_messages`); `mailstore-core/src/storage.rs`	Mailstore encryption tests only	A test that a delivered inbound row holds no plaintext body; the sweep covers the table	V19, T11
I25	A data-subject request reaches every store holding that person, sales data included	`compliance/src/gdpr_automation.rs`	Store-map tests without the sales tables	A prospect access and erasure test end to end	V23, T11
I26	Every stored-card charge carries `shopperInteraction: ContAuth`, and the live URL carries the merchant prefix	`billing-service/src/maintenance.rs`; `overage.rs`; `tools/check_prod_billing_wiring.py`	The gate requires the wrong URL	A body assertion and a URL-pattern gate	V1
I27	A message addressed to several tenants is visible to each with only its own recipients	`mta/src/servers/inbound.rs`	None	A two-tenant test with a Bcc	V13

Rust crates

All 55 crates in `services/mail-server/crates`, tier 1 first, then by size. Lines are non-test Rust lines without comments or blanks; tests are counted test attributes (`#[test]`, `#[tokio::test]`, `#[sqlx::test]` and similar), not runs. Coverage floors come from the

first required coverage run (T2), so they are not listed here.

Crate	Role	Lines (k)	Tests	Per 1k lines	Tier	Add
api-server	REST API and SSR console	66.5	2,411	36	1	All-routes matrix (T5); OpenAPI drift (T8); product journeys (T6); diff-mode mutants (T3)
compliance	GDPR, consent, claims registry, audit	44.7	1,139	26	1	Erasure completeness incl. `mail_journal` (T11); governance seed from config (T12); spec-vs-route check (T8)
sales-autopilot	Outbound sales engine	31.9	1,053	33	1	Statistics simulations (T15); no-bypass test (S10); disclosure, canonical-answer and price-band tests (S15, S17, S19); every send path calls `revalidate_execution` (I10)
enterprise	SSO, sub-accounts, field encryption, dedicated tenant	16.2	445	28	1	SSO assertion tamper and replay tests; sub-account scope in the matrix (T5); encryption round-trip property tests (T4)
billing-service	Subscriptions, Adyen, renewals	14.3	571	40	1	Event-order property tests for cancel, resume and renewal (I2); webhook replay idempotency (I3); Adyen test journey (T6)
mta	SMTP inbound and submission	11.7	763	66	1	Fuzz SMTP commands and MIME (T7); submission auth in the matrix; EU-only routing property test (I4)
tracking-service	Open and click tracking, signed IDs	10.2	253	25	1	Token tamper and expiry property tests; fuzz the token decoder (T7); per-tenant event isolation (T5)
outbound-mta	EU-only relay	5.3	199	38	1	Non-EU hop impossible (I4); throttling and MTA-STS/DANE tests when B2 lands; SES stub sees no calls (T6)
isolation	Tenant data isolation and encryption	4.5	166	37	1	Cross-tenant matrix (T5); encryption round-trip and tamper property tests (T4)

Crate	Role	Lines (k)	Tests	Per 1k lines	Tier	Add
accounting-core	Statutory accounting	4.0	51	13	1	Lowest density among tier-1 crates: double-entry and VAT property tests (I1, I3); period-close and FX rounding tests; mutation ratchet (T3)
apexmail-lib	Crypto, IDs, validation	2.4	156	64	1	Known-answer vectors for every crypto primitive; fuzz validators (T7)
ato-protection	Account-takeover prevention	1.6	93	57	1	Lockout and step-up in the login journey (T6); bypass mutants (T3)
migrator	Deploy-time migration gate	1.1	37	34	1	Apply pending migrations to a restored backup (I16, T13); destructive-migration marker test
billing-common	Shared billing logic	0.7	81	111	1	Totals, rounding and currency property tests (I1)
billing-entitlements	Runtime feature entitlements	0.6	17	28	1	Plan × feature matrix against `platform-catalog`; a downgrade removes access
sales-knowledge	Shared claim validator	0.5	12	24	1	Table tests per claim kind; adversarial unbacked-claim cases; mutation ratchet (T3)
platform-catalog	Plan and price source of truth	0.3	8	29	1	Catalog equals marketing pricing equals checkout; canonical pricing answers render from it (S15)
auth-server	Status and retained-auth server	0.04	35	—	1	Include its routes in the matrix (T5)
ui-foundation	SSR UI components, golden tests	19.5	584	30	2	Refresh the stale pricing and terms baselines; fail when a baseline differs from rendered output
worker-processors	Queue workers	18.5	832	45	2	Idempotent retry per job kind; poison-message handling; suppression check on every send path (I6)
ai-service	Mailbot, classifier, chat	9.5	466	49	2	Evaluation set with a regression floor (T17); disclosure on every path

Crate	Role	Lines (k)	Tests	Per 1k lines	Tier	Add
imap-server	IMAP4rev1	6.6	297	45	2	Fuzz the IMAP command parser (T7); mailbox isolation in the matrix (T5)
analytics	Query engine, churn, send-time optimisation	5.0	256	52	2	Tenant filter on every ClickHouse query (T5); aggregation property tests
ddos-protection	DDoS protection	4.7	592	126	2	In production (api-server). Health and probe paths never throttled, and a steady legitimate client never blocked (both broke on 22 Oct, `a2f3b08`); attack-traffic corpus
inbox-placement	Seed-based placement tests	4.6	103	22	2	Classifier accuracy on a labelled set; IMAP poller timeouts; feeds S11
ha	Health, failover, backup	4.3	222	51	2	Restore drill and failover tests (T13); fencing tests
waf-engine	Web application firewall	3.5	286	82	2	In production (api-server). A legitimate-traffic corpus of recorded browser sessions must pass with zero blocks (it blocked real browsers on their second page on 22 Oct); attack corpus; fuzz HTTP requests (T7)
mailstore-core	Mail storage and journal	3.5	93	27	2	Store and retrieve round-trip property tests; journal retention and erasure (T11)
spam-filter	Spam filter	3.2	82	26	2	Labelled corpus with precision and recall floors
apexmail-db	Pool and repositories	2.8	98	35	2	Every repository query carries a tenant filter (static check plus T5)
edge-cases	EAI, attachments, calendar	2.7	104	38	2	Fuzz attachment and calendar parsing (T7)
observability-service	Alerts, metrics, SLOs	2.7	123	45	2	Make the compose alert smoke a required lane
email-grader	Deliverability grading	2.5	96	39	2	Golden reports for 20 DNS configurations; powers S11

Crate	Role	Lines (k)	Tests	Per 1k lines	Tier	Add
devex-service	OpenAPI, SDK manager, webhook tester	2.4	58	24	2	OpenAPI output feeds T8; webhook tester isolation
sandbox	Attachment inspection	2.3	103	45	2	In production (mta). Fuzz archives and attachments (T7); nesting and decompression-size limits
template-renderer	Sandboxed templates	2.3	151	67	2	Escaping property tests (no injection); resource limits; fuzz (T7)
ids-engine	Intrusion detection	2.0	114	57	2	In production (mta). Replay of benign SMTP sessions with zero alerts; fuzz SMTP sessions (T7)
threat-intel	Feed ingestion, reputation	1.9	92	48	2	Fuzz feed parsers; stale-feed alarm test
dlp-engine	Data-loss prevention	1.8	102	56	2	In production. Labelled message corpus with precision and recall floors; fuzz message bodies (T7)
imap-proto-patched	IMAP protocol parser	1.5	45	30	2	Run its existing fuzz target nightly (T7)
mail-common	Shared types and config	1.5	53	35	2	Config parsing fails closed on unknown keys
ai-embeddings	Embeddings and vector search	1.5	101	69	2	Tenant filter on similarity search (T5)
rate-limiter	Rate limiting	1.1	87	77	2	Budget never exceeded under concurrency, and a steady legitimate client never starved (I21)
dns-resolver	Cached DNS	1.0	64	65	2	TTL and negative-cache tests; fuzz record parsing (T7)
queue-provider	Postgres job queue	0.8	53	68	2	Fairness and exactly-once claim property tests (I21)
fingerprint	TLS and HTTP/2 fingerprinting	0.8	44	58	2	In production through the security crates. Known-answer tests for current browsers' TLS and HTTP/2 fingerprints, so a browser update cannot turn into a block

Crate	Role	Lines (k)	Tests	Per 1k lines	Tier	Add
pattern-matcher	Aho-Corasick matching	0.7	44	62	2	No production crate uses it: wire it in or mark it test-only (G2). If kept, a differential test against a naive matcher
pdf-renderer	Typst documents	0.6	32	57	2	Golden PDFs for invoice, DPA, order form and S11 report
mail-proto	Protocol definitions	0.1	7	51	2	Run its existing fuzz target nightly (T7)
integration-tests	Cross-crate tests	0	257	—	3	Run against the T6 stack
fuzz-tests	Fuzz and property helpers	0.1	95	—	3	Hosts the T7 targets; holds all 8 property-test uses today
functional-tests	Functional tests	0	90	—	3	Run against the T6 stack
smoke-tests	Smoke tests	0	42	—	3	Run after each deploy in the verify stage
load-tests	Load and stress tests	0	26	—	3	Own SLO lane (T13)
perf-tests	Benchmarks	0	18	—	3	Regression threshold in the T13 lane

Packages, apps and tools

Everything outside the Rust workspace. Each SDK and PHP lane already runs as required in `ci/stages/test.sh`; what they test is the gap. Sizes are non-blank, non-comment source lines with test code excluded, counted at `61e3db3`. KiwiCaptcha is a separate project with its own repository and tests, so its packages are not listed.

Package	Size	Tests today	Add	Enforced by
`packages/sdk-typescript`	1,317 lines	113, mocked payloads	Live suite against the T6 stack; npm with provenance	T9
`packages/sdk-python`	1,090 lines	88, mocked	Live suite; PyPI trusted publishing	T9
`packages/sdk-go`	1,818 lines	63, mocked	Live suite; module tag	T9
`packages/sdk-java`	1,823 lines	49, mocked	Live suite; Maven Central	T9
`packages/sdk-php`	2,262 lines	49, mocked	Live suite; Packagist	T9
`packages/sdk-ruby`	1,244 lines	46 checks in one file (`test/payload_contract_test.rb`)	A Minitest suite; live suite; RubyGems	T9

Package	Size	Tests today	Add	Enforced by
`packages/contract`	`send-contract.json`	Used by the SDK suites	Validate live responses against it	T9
`packages/smtp-auth-proxy`	47 lines	1	Refuses unauthenticated relay; requires TLS; accepts valid credentials	T16
`apps/ai`	7,696 lines of training scripts	26 test functions; CI only compiles them (py_compile)	A pytest suite, or retire the scripts	T16
`apps/marketing-zola`	4 locales	Link, contrast, layout, i18n, legal-identity, pricing and capability-claims gates	Fix the FAQ sentence and `validate_pricing_drift.py:880`; add location claims to the registry	T10, T12
`tools/`	70 tools (55 Python, 15 shell)	20 with a self-test; 22 of the 41 that CI runs have none	A self-test for every tool CI invokes; meta-gate	T10
`ci/`	Pipeline shell	Blessing self-test cases; shellcheck	Lane-level, signed blessing cases	T1
`deploy/`	Scripts and configs	Rollback and unit-cleanup self-tests in `deploy/tests`	Restore drill; a test for secret-file bridging in `entrypoint-wrapper.sh`	T13
`tests/browser`	Playwright specs	Required chromium lane, KiwiCaptcha PHP port only	ApexMail journey specs on the T6 stack	T6

Gates to add or fix

Twenty-seven gates, each with the fixture that proves it can fail. Build T1 and T10 first, because they make every other gate binding; then the gates for the highest-risk invariants (T5, T4, T11, T12, S10); then the rest.

Gate	Stage	Fails when	Self-test fixture	WP
Signed lane-level blessing	Deploy-host fetch	The blessing is unsigned, a lane is missing or skipped, or a waiver has expired	New cases beside the `deadbeef` cases in `ci/pipeline.sh`	T1
Waiver check (`ci/waivers.toml`)	Validate	An advisory lane has no unexpired waiver	An expired waiver	T1
Per-crate coverage floors	Test	A crate falls below its floor, or tier-1 diff coverage drops	An lcov file below the floor	T2
`cargo mutants --in-diff`	Test	A mutant survives in changed tier-1 lines	A weakened assertion	T3
Live end-to-end lane	Test, CI machine	A journey step or dogfood probe fails	The dogfood `--self-test` (exists)	T6
Nightly fuzzing	Scheduled	A target crashes, or a listed parser has no target	A seeded crashing input	T7
OpenAPI drift	Validate	A route has no spec path, or a spec path has no route	A router with one extra route	T8
SDK live suites and publish	Test, release	An SDK fails against the live stack	The suites themselves	T9

Gate	Stage	Fails when	Self-test fixture	WP
`check_gate_selftests.py`	Validate	A tool CI invokes has no self-test, or its self-test passes on known-bad input	A tool stub without a self-test	T10
`validate_pricing_drift.py:880`, inverted	Validate	"Adyen billing portal" appears in the pricing FAQ	Today's `pricing-faq-island.html`	T10
`check_data_map.py`	Validate	A personal-data column is missing from `docs/data-map.toml`	A migration that adds an `email` column	T11
`check_capability_claims.py`, extended	Validate	A location or capability claim sits above its registry stage	Today's `eu-sovereign/index.md`	T12
Governance seed check	Test	A seeded subprocessor region differs from `.env.production.example`	A `us-east-1` seed	T12
Restore drill	Scheduled	The restore fails, checksums differ, or the recovery-time objective is missed	A corrupted backup	T13
Load SLO lane	Scheduled	A regression above 10% against the median of the last 7 runs	An injected slowdown	T13
`check_invariants.py`	Validate	An invariant has no test, a listed test is gone, its gate is not required, or a package is missing from ci/test-expectations.toml or lacks a declared test kind	A registry fixture	T14
`check_no_bypass.py`	Validate	Solver or proxy-rotation vocabulary appears in sales code, env examples, compose files or new migrations	A seeded `SCRAPE_CAPTCHA_SOLVER_URL`	S10
`check_canonical_answers.py`	Validate	An approved answer's source hash changed without re-approval	A changed catalog price	S15
AI evaluation set	Test, weekly	Any uncited claim, or a drop of more than 2 points in correct answers	A seeded prompt regression	T17
Legitimate-traffic replay	Test	A recorded browser session, health probe or steady API client is blocked or throttled by waf-engine, ddos-protection or rate-limiter	A recorded session that the WAF rule fixed in a2f3b08 blocked	T6
`check_compose_hardening.py`	Validate	A service lacks `read_only`, `no-new-privileges` or `cap_drop: [ALL]` without a written exception	A service stub without them	V8
Finland location gate	Validate	A Hetzner location other than `hel1` appears in code, compose, the env file or the register	A seeded `fsn1`	V24
`check_config_manifest.py`	Validate	Code reads an environment variable that has no manifest entry	A new `env::var` call	V12

Gate	Stage	Fails when	Self-test fixture	WP
Connection budget	Validate	Database pool sizes in the merged compose sum above `max_connections` minus a reserve	Four pools of 50 against 100	V12
Crate reachability	Validate	A workspace crate is neither deployed, linked into a deployed binary, nor test-only by name	A new unused crate	V12
Query schema check	Test	A query names a table or column the migrated schema lacks	A renamed column	V9
SDK dependency audits	Validate	`npm audit`, `pip-audit`, `govulncheck` or `bundler-audit` reports an unwaived advisory	A pinned vulnerable version	V7

Verification ledger

Every factual claim in this doc traces to a row here. A claim with no row is not to be acted on.

Repo facts

Checked against `sbelakho2/ApexMail` at commit `1987043` (2026-10-13), and re-checked at 9d8cef4 on 2026-10-15: every reference still holds except R1 (moved one line) and R44 (updated); rows R45–R51 are new; re-checked at a2f3b08 on 2026-10-22, where rows R59–R74 are new; and re-checked at 61e3db3 the same day, where R37, R72 and R74 are corrected and R75–R81 are new; rows R82–R102 come from the Deep review on 23 Oct, still at 61e3db3. Paths use the Work packages tab's shorthand: `crates/` = `services/mail-server/crates/`, `migrations/` = `services/mail-server/migrations/`.

ID	Claim	Evidence	Used in
R1	Production config sends through SES, region `eu-west-1`	`.env.production.example:340, 350`	Plan, A2, B1
R2	The code's default SES region is `us-east-1`	`crates/api-server/src/config.rs:1064`	A4, B1
R3	Transport selection is deployment-wide	`README.md:286`	A2, B1
R4	`DeliveryRoute` has only `SesShared` and `Dedicated`	`crates/worker-processors/src/email/types.rs:310`	B1
R5	The `outbound-mta` relay (about 13k lines) is defined in production compose	`crates/outbound-mta/src/lib.rs`; `docker-compose.prod.yml:1251`	B2
R6	Sales and customer sender pools are separated by a database CHECK	`crates/sales-autopilot/src/sender_pool.rs` module doc	A2, Sales engine
R7	The sales dispatcher's transport gate reads the global setting	`crates/sales-autopilot/src/dispatcher.rs:811–815`	A2
R8	Sales mail carries `List-Unsubscribe` and one-click `List-Unsubscribe-Post`	`dispatcher.rs:1348–1349`	Sales engine
R9	The legal engine maps all EU/EEA countries to one key and fails closed	`crates/sales-autopilot/src/legal_policy.rs:13–21, 40–52`	F1
R10	Only `EU` (`approval_required`) and `UNKNOWN` policy rows are seeded	`migrations/200_sales_autopilot_v2_unification.sql:1055–1065`	F1, Sales engine
R11	Migration 200 sets autonomy to `shadow` or `disabled`. The live production value was not checked: run `SELECT mode FROM sales_autonomy_state`	`migrations/200_…sql:985`	Sales engine
R12	Five autonomy modes; only `autonomous_guarded` executes without a human	`crates/sales-autopilot/src/types.rs:30–34`; `autonomy.rs` tests	F12
R13	Current scoring weights and formula	`crates/sales-autopilot/src/scoring.rs` module doc	F6

ID	Claim	Evidence	Used in
R14	Reward ladder values	`crates/sales-autopilot/src/experiments.rs:261-270`	Sales engine
R15	Email-stack detection covers 11 vendors; Resend is read as SES	`crates/sales-autopilot/src/signals/email_stack.rs:248-294`	F3
R16	Discovery forbids scraping and enforces declared jurisdictions	`crates/sales-autopilot/src/discovery/mod.rs` module doc	F2
R17	Enrichment is one Clearbit-shaped HTTP provider	`crates/sales-autopilot/src/enrichment/providers/http.rs:10, 42`	F2
R18	The grader checks SPF, DKIM, DMARC, BIMI, MTA-STS, TLS-RPT and blocklists	`crates/email-grader/src/grader.rs:226-287`	F4
R19	Sender-health complaint quarantine is 0.3%	`crates/sales-autopilot/src/sender_health.rs:67, 82`	F8
R20	Reply taxonomy (11 dispositions) and objection classes (6)	`crates/ai-service/src/reply_classify.rs:54-66` ; `migrations/242_objection_library.sql:25`	Sales engine
R21	The mailbot runs draft-only and grounded	commit `0cace0d`	F9
R22	Instant response with a priority-100 lane	commit `4c3e60d` ; migration 241	Sales engine
R23	The objection library is not seeded	commit `0b962ed`	F7
R24	Server-driven demo sessions exist	commit `2bc19bd` ; migration 243	F10
R25	The MTA fills the reply-pipeline columns on inbound mail	commit `f22381b`	Sales engine
R26	Homepage stats are hard-coded	`apps/marketing-zola/templates/partials/home/hero.html:95, 100, 105`	A4
R27	The data-locations page says SES defaults to an EU region	`apps/marketing-zola/content/data-locations.md:35`	A4
R28	The repo's first commit falls between 2026-01-15 and 2026-03-04	GitHub commit list: none before 2026-01-15, one on 2026-03-04	A4
R29	CI runs on the production host; ~12.6k tests; a coverage run filled the 436 GB disk	commits `bbb16ce` , `0cb9855`	A1
R30	49 of the last 50 commits are fixes, chores, style or repo-map updates	`git log` at `1987043`	A1
R31	The catalog stores one EUR price in cents; Developer is `2_900`	`crates/platform-catalog/src/lib.rs:19, 78`	C1, E1
R32	Dedicated Tenant €4,000/mo, 12-month minimum, €10k–40k setup; BYOC €6,500/mo	`crates/compliance/src/deployment_products.rs:51-72, 107-112`	E3, G1
R33	Envelope encryption with a per-tenant KEK exists	`crates/enterprise/src/field_encryption.rs:1-8`	B5
R34	The AI service calls an OpenAI-compatible endpoint	`crates/ai-service/src/config.rs:11-13`	B4
R35	SSR auth forms call KiwiCaptcha verification	`crates/api-server/src/routes/web.rs:2425`	A6
R36	GitHub SSO now requires a verified address	`crates/api-server/src/routes/sso.rs:328-354`	A6

ID	Claim	Evidence	Used in
R37	`pattern-matcher` is only a test-crate dependency; `isolation` runs as its own production service (corrected 22 Oct)	`Cargo.toml` manifests under `crates/`; `docker-compose.prod.yml:1092` at `61e3db3`	G2
R38	Five SDKs at 1.0.1; no TypeScript SDK	`packages/README.md`	D3
R39	No SDK was on any registry as of the September audit. Not re-checked: the registries were unreachable from this check's network	`docs/audit/full-repo-audit-2026-09-05.md:85`	D3
R40	Ed25519 receipts were specified and deferred	`docs/audit/full-repo-audit-2026-09-05.md:418, 438`	B3
R41	Typst templates exist for DPA, invoice, compliance report, QBR and analytics export	`crates/pdf-renderer/src/templates/`	B6, F10
R42	The contact-sales form offers a CCPA option	`apps/marketing-zola/content/contact/sales.md:117–118`	C3
R43	The validate-stage gates (pricing drift, knowledge consistency, capability claims, repo map, migration lint, delivery contract)	`ci/stages/validate.sh`	Definition of done
R44	The latest migration is 252 (Adyen billing renames, 14 Oct), and the header form is gated	commits of 2026-10-13 on migration 251	Invariant 10
R45	Both cancellation endpoints refuse and point to an "Adyen billing portal" that the code says does not exist; the console portal route is POST-only and changes nothing	crates/api-server/src/routes/billing.rs:3281, 3400–3418; crates/billing-service/src/routes.rs:1444–1465; crates/api-server/src/routes/web.rs:328, 5123–5141	Audit, H1
R46	20 lines on four legal pages, in four languages, give Adyen N.V. Stripe's old US/India locations	apps/marketing-zola/content/ subprocessors, privacy, dpa, data-locations (all locales); templates/compliance/subprocessors.md, data-locations.md	Audit, H2
R47	api-server's checkout needs ADYEN_API_KEY, ADYEN_MERCHANT_ACCOUNT and ADYEN_API_BASE_URL; production compose passes none of them to api-server; the base URL defaults to Adyen's test endpoint, which production refuses	crates/api-server/src/routes/billing.rs:990–1030; docker-compose.prod.yml (api-server block); .env.production.example	Audit, H3
R48	Local tax computation covers EU VAT only; US addresses get zero tax	crates/billing-common/src/vat_rates.rs:626, tests at 806–864	C2
R49	14 commits since 1987043; sales-autopilot, outbound-mta, platform-catalog and email-grader unchanged; no plan work on any branch or PR	git log 1987043..9d8cef4; git ls-remote --heads; open PRs are Dependabot only	Audit
R50	Migration 252 is the Adyen billing renames	services/mail-server/migrations/252_adyen_billing_renames.sql (commit ad6c748)	Invariant 10, WP format
R51	The env example's Adyen keys still use Stripe's sk_live_ and whsec_ prefixes	.env.production.example:130–131	H2
R52	The arm posterior ignores non-response (beta grows only on negative events) and adds every ladder outcome of one contact to alpha; selection samples Beta(alpha, beta) without contacts	crates/sales-autopilot/src/experiments.rs:407–437, 477, 1674 at f9221fc	Audit 16 Oct, S1

ID	Claim	Evidence	Used in
R53	No holdout or control group exists in sales-autopilot; replay scores challengers by agreement with logged reality; context buckets switch at 25 samples	rg holdout|control group in crates/sales-autopilot/src (no hits); simulation.rs:12–157; experiments.rs:120	S3, S4, S6
R54	An opt-in external CAPTCHA-solver hook exists for scraping; public_web.rs extracts mailto addresses	crates/sales-autopilot/src/discovery/blocked.rs:1–70; public_web.rs:280–318; migration 258; commit 986d053	S10
R55	At f9221fc: R45 (cancellation) and R47 (Adyen config) unchanged; R46 down from 20 to 19 wrong lines (English subprocessors page fixed by the generator)	api-server/src/routes/billing.rs:3415–3430; docker-compose.prod.yml api-server block; content/{subprocessors,privacy,dpa,data-locations}	Audit 16 Oct, H1–H3
R56	The sovereignty page says EU-only sends leave through own EU MTAs, sells a DORA/NIS2 evidence pack, and states Germany primary / Finland backup; ARCHITECTURE.md says one production host in Finland	content/eu-sovereign/index.md:13, 87; content/data-locations.md:16–20; ARCHITECTURE.md:12	Audit 16 Oct
R57	The catalog sells Mailbox Archive + Journaling at +200/+200 cents per seat; the commit states journaling is not built	crates/platform-catalog/src/lib.rs:375–376, 583; commit 1705d60	Audit 16 Oct, E5
R58	Migrations run to 261; the deploy host refuses commits without a gate blessing	services/mail-server/migrations/261_dedicated_tenant_provisioning.sql; commits 9d2eec9, f9221fc	Invariant 10; Audit 16 Oct
R59	Cancellation is a local state change at period end, the renewal sweep skips cancelled rows, and the console posts to /web/billing/cancel	crates/billing-service/src/subscriptions.rs:97; crates/api-server/src/routes/web.rs:335; commit 98a60a5c	H1, Audit 22 Oct
R60	The pricing FAQ still promises an "Adyen billing portal", and the pricing-drift gate requires that phrase	apps/marketing-zola/templates/partials/generated/pricing-faq-island.html:31; tools/validate_pricing_drift.py:880	H2, T10
R61	The governance register seeds AWS SES in us-east-1 and a US transfer, citing an env value that is now eu-west-1; production sends through eu-west-1, so the transfer record is false, and the seed runs at every boot without overwriting	crates/compliance/src/governance.rs:733–760; .env.example:118; crates/api-server/src/config.rs:1071	T12
R62	The CAPTCHA-solver hook is still present: 232 mentions of "solver" in sales-autopilot sources	crates/sales-autopilot/src/discovery/blocked.rs:1–70; migration 258	S10
R63	Reply auto-send sends drafts with any of 18 pricing or 14 legal markers to a human; five low-risk classes; promotion needs 20 approvals (10 minimum) in a 30-day window (7–90)	crates/sales-autopilot/src/reply_autosend.rs:104–119, 169–181, 382–420	S15, S20, Sales engine
R64	Chat answers carry an EU AI Act Art. 50 disclosure; sales replies carry none	crates/ai-service/src/chat.rs:43–46; crates/sales-autopilot/src (no disclosure)	S19
R65	No public route exposes email-grader or the email-stack signals as a free tool	crates/api-server/src/routes/; apps/marketing-zola/content	S11
R66	Off the deploy host, a missing scanner is skipped with a warning unless CI_MISSING_TOOLS=fail; the blessing records stage status only and is unsigned	ci/lib.sh:381–414, 566–585; ci/stages/security.sh:55, 82, 124, 144, 178, 207; ci/stages/test.sh:364; ci/pipeline.sh:459–463	T1

ID	Claim	Evidence	Used in
R67	Coverage is advisory and workspace-wide only	ci/pipeline.conf:73; ci/coverage-baseline.txt	T2
R68	Mutation testing is manual only, and the dogfood live battery is off in CI	services/mail-server/mutants.toml; ci/pipeline.conf (CI_DOGFOOD_LIVE=0)	T3, T6
R69	The required browser lane runs KiwiCaptcha specs against the PHP port only; ApexMail journeys are manual scripts	tests/browser/playwright.config.mjs:4, 12; tests/browser/journey-flows.mjs	T6
R70	Two cargo-fuzz targets exist and no CI stage runs them; the workspace has 8 property-test uses, all in fuzz-tests	crates/fuzz-tests/fuzz/fuzz_targets/; scan of all 55 crates	T4, T7
R71	mail_journal is missing from the erasure map, and journal retention defaults to forever	crates/compliance/src/gdpr_automation.rs; migrations/264_mail_journal.sql	T11
R72	20 of 55 Python tools have a self-test; CI runs 41 tools, and 22 of them (17 Python, 5 shell) have none	tools/ matched against ci/, .kiwi/, .woodpecker.yml, .pre-commit-config.yaml and Makefile, at 61e3db3	T10
R73	Journal retrieval exists at /v1/journal, with raw download	crates/api-server/src/routes/journal.rs; crates/api-server/src/app.rs:812	E5
R74	Test inventory: 55 crates and 13,403 test attributes at 61e3db3 (13,402 and 332,471 non-test lines at a2f3b08); counted, not run	Scans of services/mail-server/crates at a2f3b08 and 61e3db3	Tests & enforcement
R75	GitHub branch protection was retired; main is unprotected by decision, and the gate blessing is the release check	commit 61e3db3 (scripts/verify-branch-protection.sh deleted; ci/README §13)	T1, Audit 22 Oct
R76	Outside the workspace: SDKs have 113 (TS), 88 (Python), 63 (Go), 49 (Java), 49 (PHP) tests and a 46-check Ruby suite, all mocked; smtp-auth-proxy 1; apps/ai 26, only compiled	Scan of packages/ and apps/ at 61e3db3; ci/stages/test.sh:722–876, 942–953	T9, T16
R77	The 22 Oct journey sweep scripts are tracked in tests/browser, but no CI file runs them	tests/browser/journey-*.mjs, cp-*.mjs; no reference in ci/, tools/ or Makefile at 61e3db3	T6
R78	"Germany primary, Finland backup" appears in five site files, including the homepage partial, although hosting is Finland-only	content/eu-sovereign/index.md:13; content/data-locations.md:46; content/compare/amazon-ses, compare/mailgun; templates/partials/home/sovereignty.html	T12, A3
R79	99.9% uptime appears in 8 site files, including the SLA page and pricing plans, with one production host	apps/marketing-zola content and templates at 61e3db3; ARCHITECTURE.md:12	A3, T12
R80	The public claims registry and DORA/NIS2 control mappings are served publicly; B6, the evidence-pack generator, is still in progress	crates/compliance/src/admin_routes.rs:130–138; control_mappings.rs	B6, T12
R81	Migrations run to 268 (268_drop_orphan_tables.sql); the next is 269	services/mail-server/migrations at 61e3db3	Plan invariant, S10, S21
R82	The live Adyen base URL is https://checkout-live.adyen.com/v71 in the env example and compose, and the production gate requires it	.env.production.example:163; docker-compose.prod.yml:488, 1877; tools/check_prod_billing_wiring.py:38	MON-1, V1
R83	Stored-card renewal and usage charges send no shopperInteraction	crates/billing-service/src/maintenance.rs:5016–5027; crates/billing-service/src/overage.rs:2346–2357	MON-2, V1

ID	Claim	Evidence	Used in
R84	Romania's VAT rate is 19% in the table, which has no effective dates	crates/billing-common/src/vat_rates.rs:59	MON-3, V2
R85	HETZNER_DEFAULT_LOCATION defaults to fsn1, and the generated register publishes Germany	crates/api-server/src/ip_provider.rs:1525; docker-compose.prod.yml:454; .env.production.example:456; apps/marketing-zola/content/subprocessors/index.md:24	DP-4, V24
R86	BACKUP_TARGET is empty and nothing configures WAL archiving	.env.production.example:533–539; no archive_mode in the repo	OPS-1, V6
R87	The status page, synthetic monitor and Alertmanager run on the production host; every alert destination is empty	deploy/nginx/nginx.conf:242; docker-compose.yml:2073–2079; .env.production.example:234–243	OPS-2, V11
R88	The GDPR access and erasure store map contains no sales table	crates/compliance/src/gdpr_automation.rs:2820–2900	DP-1, V23
R89	inbound_messages stores raw MIME and bodies in plaintext, and the retention sweep does not cover it	crates/mta/src/servers/inbound.rs:1842–1880; crates/compliance/src/retention_sweep.rs:130–176	DEL-9, V19
R90	The SAML verifier accepts only ds:Reference URI=""	crates/enterprise/src/sso.rs:194–252	SEC-1, V5
R91	Inbound mail takes its tenant from the first recipient, and the webhook lists every envelope recipient	crates/mta/src/servers/inbound.rs:1717–1727, 2018–2050	DEL-2, V13
R92	Production runs spam and IDS tag-only; only DMARC quarantine reaches the Spam folder; the Bayesian model is never trained; ClamAV is never constructed	docker-compose.prod.yml:1336–1337; crates/mta/src/servers/inbound_delivery.rs:1128–1134; crates/mta/src/servers/content_security.rs:105–113; crates/sandbox/src/dynamic_analyzers.rs:419	DEL-3, SEC-3, V14
R93	GoogleImageProxy, Yahoo proxies, Microsoft Office user agents and Google proxy ranges are classed as bots and their opens are not recorded	crates/tracking-service/src/bot.rs:27–30, 67–68, 112–116; crates/tracking-service/src/routes/pixel.rs:131–135	DEL-6, V18
R94	verify_dane has no caller; port 25 continues in cleartext when STARTTLS is not offered	crates/mta/src/auth/dane.rs:30–33, 103; crates/outbound-mta/src/tls.rs:28–45; crates/outbound-mta/src/relay.rs:1119–1125	DEL-1, B2
R95	The published OpenAPI spec lists /team, /team/invite, /analytics/summary, /ips, /ips/pools and /api-keys, which are not routed	apps/marketing-zola/static/specs/openapi.yaml; crates/api-server/src/routes/account.rs:16–22; crates/api-server/src/routes/auth.rs:2085–2086	API-3, V20
R96	The bandit posterior moves only on reward events and stacks a contact's successive rewards	crates/sales-autopilot/src/experiments.rs:171–185, 407–437	SAI-2, S1
R97	Eleven services mount the same internal_service_token	docker-compose.prod.yml (23 references); crates/mail-common/src/internal_auth.rs:62–66	SEC-2, V25
R98	tracking, api-server, mta and enterprise each set DB_MAX_CONNECTIONS 50; Postgres runs with its default max_connections	docker-compose.yml:270, 406; docker-compose.prod.yml:1304, 1603	OPS-8, V12
R99	RUSTSEC-2026-0381 and RUSTSEC-2026-0382 match the lockfile and are not in the ignore list	services/mail-server/Cargo.lock against advisory-db 640bf5a; ci/pipeline.conf:156	DEP-1, V7

ID	Claim	Evidence	Used in
R100	The privacy policy says prospects' data is provided via forms or email, lists only the legitimate-interest objection, and promises a reply within 30 days	apps/marketing-zola/content/privacy/_index.md:22, 73, 75	WEB-5, WEB-8, V27
R101	The home page features card claims DANE and MTA-STS are built in (English and German)	apps/marketing-zola/templates/partials/home/features.html:20; apps/marketing-zola/data/i18n.json:461	WEB-2, V26
R102	The production host builds every image from source	ci/stages/images.sh:3–10; docker-compose.prod.yml:14–20	OPS-3, A1

External facts

Each page below was opened and read on Oct 13, 2026. Prices and policies change: re-open the page before acting on a row that is older than 90 days.

ID	Claim	Source	Status
X1	SES charges $0.10 per 1,000 outbound emails	Amazon SES pricing	Verified
X2	SES reviews accounts at 5% bounces or 0.1% complaints, may pause at 10% or 0.5%, and recommends staying below 2% and 0.1%	SES sending review FAQ	Verified
X3	Gmail requires, for all senders, SPF or DKIM, PTR, TLS and a spam rate below 0.30%. Above 5,000 a day it also requires SPF and DKIM, DMARC with alignment, and one-click unsubscribe. It recommends staying below 0.10%	Gmail sender guidelines	Verified
X4	Outlook.com requires SPF, DKIM and DMARC with alignment from high-volume senders and rejects failures with `550 5.7.515`	Microsoft Q&A on 5.7.515; the official announcement did not render	Partly verified: threshold period and start date unconfirmed
X5	Hetzner Cloud blocks outbound ports 25 and 465 by default; unblocking needs one month as a customer, a paid first invoice and an approved request; port 587 is open	Hetzner Cloud FAQ	Verified

ID	Claim	Source	Status
X6	Resend offers regions `us-east-1`, `eu-west-1`, `sa-east-1` and `ap-northeast-1`, chosen per domain	Resend: choosing a region	Verified
X7	Resend's DNS setup: MX and SPF (`include:amazonses.com`) on a `send` subdomain, DKIM at `resend._domainkey`	Resend Cloudflare guide	Verified
X8	Mailjet's SPF include is `spf.mailjet.com`; its example DKIM name is `mailjet._domainkey`	Mailjet SPF and DKIM validation	Verified (selector inferred from the example)
X9	Brevo needs no SPF include for domain authentication; its DMARC example uses `rua=mailto:rua@dmarc.brevo.com`	Brevo domain authentication	Verified
X10	SendGrid offers EU data residency through EU subusers, `api.eu.sendgrid.com` and an EU dedicated IP	SendGrid data residency FAQ	Verified
X11	Mailgun offers an EU region, chosen per sending domain	Mailgun EU region announcement	Verified
X12	Postmark hosts in a US data center and on AWS, and has no plans for EU servers	Postmark EU data protection	Verified
X13	France: B2B email needs no prior consent if it relates to the recipient's profession, identifies the sender and offers a simple opt-out	CNIL	Verified
X14	Germany: email advertising without prior express consent is an unreasonable nuisance (UWG §7(2) Nr. 2), with an existing-customer exception (§7(3))	UWG §7 on dejure.org	Verified
X15	UK: corporate subscribers may be emailed without consent; sole traders and some partnerships need consent; identity and opt-out always required	ICO electronic mail marketing	Verified

ID	Claim	Source	Status
X16	CAN-SPAM covers B2B; opt-outs within 10 business days; penalties up to $53,088 per email	FTC CAN-SPAM guide	Verified
X17	The EBA PSD2 register is free to search and download, has a JSON specification, is updated at least daily, and carries a no-legal-effect disclaimer	EBA register	Verified; no reuse licence is stated
X18	DORA has applied since 17 January 2025	ESMA on DORA, EIOPA on DORA	Verified
X19	DORA registers of information are reported annually, in xBRL-CSV, under the EBA taxonomy	AFM register of information	Verified for the Netherlands; check per supervisor
X20	61% of Western European CIOs expect geopolitics to increase reliance on local or regional cloud providers	Gartner via ChannelWeb	Verified (survey expectation, not measured migration)
X21	Resend Pro is $20 for 50,000 emails	Resend pricing	Verified
X22	Lettermint is built in the Netherlands, ISO/IEC 27001:2022 certified, from €10/mo	Lettermint pricing	Verified
X23	mailbox.org business plans cost €4 (Standard) and €12 (Premium) per user	mailbox.org business	Verified
X24	Adyen charges $0.13 per transaction plus the payment-method fee (cards: Interchange++ plus 0.60%; SEPA Direct Debit: €0.27); no setup or monthly fee; a minimum invoice that depends on industry or business model	Adyen pricing	Verified 15 Oct; minimum invoice amount not published
X25	A live Adyen account requires checks on the company, shareholders and business model, registration, VAT, bank and ID documents; the website must show terms, privacy and refund policies, contact details and a terms checkbox at checkout	Adyen live account requirements	Verified 15 Oct

ID	Claim	Source	Status
X26	CNIL: a site that refuses scraping through robots.txt or a CAPTCHA must be excluded; legitimate interest may not hold without such safeguards	CNIL, intérêt légitime et moissonnage	Verified 16 Oct
X27	Firms contacting a web lead within an hour were nearly 7x as likely to qualify it as those waiting an hour longer, and over 60x as likely as those waiting 24 hours (1.25M leads)	HBR, The Short Life of Online Sales Leads (2011)	Verified via a secondary summary; the HBR page itself was not opened
X28	Continuous monitoring makes fixed-horizon p-values unreliable; always-valid p-values stay valid at any stopping time	Johari, Pekelis, Walsh: Always Valid Inference	Verified 16 Oct
X29	EU AI Act Article 50 transparency duties, including telling people they are interacting with an AI system, were not postponed by the AI Omnibus and apply from 2 Aug 2026	Gibson Dunn, EU AI Act Omnibus agreement	Verified 22 Oct; confirm against the Official Journal text
X30	Live Checkout API calls use a merchant-specific prefix: https://[prefix]-checkout-live.adyenpayments.com/checkout/v71	Adyen live endpoints	Verified 22 Oct
X31	Subscription payments with a stored token send shopperInteraction ContAuth with recurringProcessingModel Subscription	Adyen, make token payments	Verified 22 Oct
X32	Romania's standard VAT rate is 21% from 1 August 2025 (Law 141/2025)	PwC Romania, Law 141/2025	Verified 23 Oct
X33	An SMTP sender's give-up time generally needs to be at least 4–5 days (§4.5.4.1); a domain without MX is treated as an implicit MX at its A/AAAA address (§5.1)	RFC 5321	From the standard; not refetched
X34	A SAML signature's Reference URI names the ID of the signed assertion or message (§5.4.2)	OASIS SAML 2.0 Core	From the standard; not refetched
X35	A GoogleImageProxy request indicates the email was opened in Gmail	Bloomreach, Gmail opens	Verified 23 Oct

Not verified in this pass, and therefore not relied on anywhere in this doc:

- the exact DORA article on exit strategies
- NIS2 supplier-security wording
- AWS's terms on unsolicited email through SES
- the format of each vendor's status feed

WPs that touch these topics must look them up first.

Assumptions

These numbers are estimates and design choices, not facts. Each has a defined way to be replaced by a measurement. When the measurement exists, update the number everywhere it appears and mark the row Replaced.

ID	Assumption	Where it appears	Replace with	When
AS1	Funnel rates per contacted account (EU: 6% / 2% / 1.2% / 0.3%; US: 5% / 2% / 1.0% / 0.25%)	Sales engine: goal	`sales_outcomes` by segment via `attribution.rs`	After 1,000 contacted accounts per segment
AS2	Blended ARPU per line (€80, €1,050, €1,900, €2,400, €5,000, €6.50 per seat)	Plan: MRR model	Billing data per plan	After 20 paying accounts per line
AS3	US share of MRR per line (40%, 25%, 15%, 40%, 0%, 5%)	Plan: MRR model	Billing country of each paying account	After 50 paying accounts in total
AS4	Account counts in the Proof, Scale and Very high mixes	Plan: MRR model	Targets, not forecasts; keep them, track actuals beside them	Continuous
AS5	Cost per account and gross margin ranges	Plan: unit economics	Hetzner invoices, SES bills, payment fees	Monthly

ID	Assumption	Where it appears	Replace with	When
AS6	Solo ceiling of about 60 contract accounts	Plan: operating model	Founder hours logged on support and on-call	Monthly
AS7	Warmup ramp: 20 a day, +20% a day, cap 150 per sender identity	Sales engine: infrastructure	Sender-health data per identity	After the first 30 days of sending
AS8	Proposed scoring weights	Sales engine: scoring	Simulation replay result (F6)	Before promotion
AS9	Score thresholds 70 and 50	Sales engine: scoring	Positive-reply rate by score band	After 1,000 scored and contacted accounts
AS10	Signal decay half-lives (7, 30 and 14 days)	Sales engine: signals	Positive-reply rate by signal age	After 500 signal-triggered sends
AS11	F9 thresholds: confidence 0.9, owner edit rate below 5% over 200 drafts	Sales engine: after a reply; WP F9	Owner policy; revisit after the first promoted class	After first promotion
AS12	F12 thresholds: 200 shadow decisions at 95% agreement; 300 approved sends	WP F12	Owner policy; revisit after the first promotion	After first promotion
AS13	Experiment rules: pause above 0.2% complaints after 300 sends; 400 sends per arm before picking a champion	Sales engine: experiments	Owner policy	After the first completed test

ID	Assumption	Where it appears	Replace with	When
AS14	EU-only placement within 5 points of Global routing as the readiness bar	WP B2	Inbox-placement reports	When B2 starts

Audit — 16 October 2026

Oct 16, 2026 · @Aaron

Real progress: 12 commits and about 65,000 lines landed between `9d8cef4` and `f9221fc` (16 Oct, 16:44).

- Of the 32 non-sales work packages, 8 are done in code, 10 are partly done, 2 wait only on owner input, and 12 have not started.
- The new prices, the four-provider switching surface, fail-closed EU-only routing, signed receipts, sales-transport isolation and US tax are real, with tests.
- But none of the three launch blockers from the 15 Oct audit is fully fixed: cancellation, Adyen's legal-page facts, and Adyen's production config.
- The new sovereignty marketing now promises four things the product or infrastructure does not yet deliver.

Verdicts

Question	15 Oct	16 Oct
Is it a good business model?	Sound on paper, unproven	Stronger. The EU-sovereign offer now has working code behind its core claims: EU-only routing that holds rather than falls back, and per-message signed receipts. Still no evidence of paying customers
Is it close to launching?	Further away than on 13 Oct	Closer on product, not on revenue. A customer still cannot cancel, checkout still cannot run with the production config, and the DPA still misstates the payment processor in all four languages
How much of the plan is done?	None of 41	8 of 32 non-sales packages done, 10 partly done; the sales group was not assessed, as requested

Still blocking a paid launch

From the 15 Oct audit, still open

1. **H1 — customers cannot cancel.** Not changed.
   - Both cancel endpoints still refuse with "use the Adyen billing portal" (`api-server/src/routes/billing.rs:3415-3430`; `billing-service/src/routes.rs:1444`).
   - `/web/billing/portal` is still POST-only (`routes/web.rs:328`).
   - 20 references to the nonexistent portal remain, including the Terms, the enterprise page, the pricing FAQ, the API docs and the OpenAPI spec.
2. **H2 — legal pages, partly fixed.**
   - The English subprocessors page is now generated from deployment config and names Adyen N.V., Netherlands.
   - 19 lines still say "USA (primary); India (support)": the DE, FR and ES subprocessors pages, plus the privacy policy, DPA and data-locations pages in all four languages.
   - `templates/compliance/data-locations.md:45` still says "EU + US".
   - The env example keys still carry Stripe prefixes (`.env.production.example:143-144`).
   - The DPA is a contract; it must not contradict the register.
3. **H3 — Adyen production config.** Not changed.
   - `docker-compose.prod.yml` still passes no Adyen setting to api-server, which creates checkouts.
   - Billing-service gets the key and HMAC secret but not `ADYEN_MERCHANT_ACCOUNT`, which overage charging also needs (`billing-service/src/overage.rs:2309`).
   - Neither the merchant account nor the live base URL appears in `.env.production.example`.

New: public claims ahead of the product

The 16 Oct sovereignty pages (`72bd8b3`) are careful in tone, but four statements outrun what exists.

Claim	Where	What is true	Fix
"Every [EU-only] send leaves through ApexMail's own EU MTAs"	`content/eu-sovereign/index.md:13` and the pricing add-on	Routing holds correctly, but the relay has no per-provider throttling, no outbound MTA-STS/DANE and no placement evidence (WP B2 not started). Hetzner Cloud blocks port 25 until a request is approved	Sell EU-only "on onboarding" until B2 passes, or gate the add-on purchase behind a readiness flag
"DORA/NIS2 evidence pack" in the Compliance line	`eu-sovereign/index.md:87`	A served control-mapping index exists (`1705d60`); no evidence-pack generator, register-of-information export or exit plan exists (WP B6)	Rename to "DORA/NIS2 control mapping" until B6 ships
"Germany primary, Finland backup"	`eu-sovereign` , `data-locations` , two compare pages	`ARCHITECTURE.md:12` says the production host is one Hetzner host in Finland; no replica exists (WP A3)	Make all pages match the real host
"Archive and journaling, +€2 per seat"	catalog and pricing	The add-on bills, but the commit itself says the journaling destination and retrieval UI are not built (`1705d60`)	Stop charging for it, or sell "retention folder" until E5 ships

The 99.9% SLA is also still advertised in 7 template and SLA files on a single host (WP A3).

Work package check

Each package was tested against its own "Done when" criteria in the code at `f9221fc` . "Done" means done in code with tests; production state was not observable (see the last sections). The sales group (F) was not assessed, as requested.

WP	Status	Evidence	Gap left
H1	Not started	Cancel endpoints unchanged (`billing.rs:3415`)	All of H1
H2	Partly	English register generated, Adyen = Netherlands (`tools/generate_subprocessors.py`)	19 wrong lines in other pages and locales; template; env placeholders
H3	Not started	api-server compose block has no `ADYEN_*`	All of H3
A1	Partly	Gate line runs on a separate machine; the deploy host refuses a SHA without a fresh blessing (`9d2eec9`, `f9221fc`)	Images are still built on the production host (deploy line includes `images`; no registry)
A2	Done	Sales transport slot, fail-closed hold, separate suppressions; invariant test in `worker-processors/src/email/processor.rs` (`21a5d20`)	Production uses `SALES_TRANSPORT=none` until a sales relay or account is configured
A3	Not started	No replication or secondary MX	All of A3; 99.9% SLA still advertised
A4	Partly	Hero literals gone; reads `data/public_metrics.json`, shows "not measured yet"	The file is committed by hand; no daily export, no staleness gate
A5	Not started	No restore drill	All of A5
A6	Not started	No new probe records in `docs/audit/`	All of A6
B1	Partly	Tenant-level `global` / `eu_only`, fail-closed hold, 5 hold arms, tests `eu_only_without_own_mta_route_holds_and_never_calls_ses` (`b451562`)	No subaccount or domain scope; `AWS_REGION` still defaults to `us-east-1` (`config.rs:1064`)
B2	Not started	Only a source-IP allowlist was added (for E3)	Throttling, MTA-STS/DANE, warmup run, placement parity
B3	Done	Ed25519 receipts, signed in the acceptance UPDATE, refuse without signer; verify endpoints and CLI (`1705d60`)	—
B4	Partly	Register generator with a validate gate	The "zero-US" check tests processing region only; EU-only tenants still get Google/GitHub login, S3 telemetry and the default AI endpoint
B5	Not started	—	All of B5

WP	Status	Evidence	Gap left
B6	Partly	Claims served with 10 DORA and 11 NIS2 control mappings (`1705d60`)	No bundle, no register-of-information export, no exit plan — yet sold
C1	Done	USD columns in catalog and plans (migration 253); checkout in tenant currency (`ddaffde`)	—
C2	Owner	Nexus, taxability, exemptions, filing report, fail-closed on stale rates; 35 tests (`9177362` , `986d053`)	The rate file ships empty; rates and registrations are owner and accountant inputs
C3	Owner	Draft at `templates/legal/us-dpa-addendum.md` , unapproved	Counsel approval
C4	Not started	—	All of C4
D1	Done	SendGrid, Mailgun, Postmark, Resend endpoints; 27 tests (`b451562`)	—
D2	Done	`POST /v1/import/{provider}/{kind}` , dry-run default, durable reports (migration 254)	—
D3	Partly	`packages/sdk-typescript` , 117 tests, required CI lane	No registry publication step in CI
D4	Done	20 `/migrate/<provider>/` pages in four languages	—
E1	Done	Developer €20/$20 and the new lines at the source and all mirrors (`ddaffde`)	Live checkout blocked by H3
E2	Partly	Platform billing: base, per-1k, per-subaccount, both currencies (`1705d60`)	Per-subaccount routing, complaint auto-pause, abuse scoring, white-label domains
E3	Partly	Bundle generator, fail-closed validation, lifecycle, review packet (`e6764ad`)	A real host group provisioned end to end
E4	Partly	Seat billing, 10-seat floor, entitlement gates (`1705d60`)	Self-serve domain onboarding, IMAP import, per-seat MFA
E5	Not started	Commit says journaling is "not built"	Journaling store — while the add-on already bills
E6	Not started	—	All of E6
G1	Not started	BYOC still in 32 marketing files	All of G1
G2	Not started	`isolation` , `pattern-matcher` still test-only, undocumented	All of G2

WP	Status	Evidence	Gap left
G3	Done	Already covered before the plan: the required i18n gate in `ci/stages/test.sh:1218` (my plan missed it)	—

Repo gates at `f9221fc`:

- **Passed:** knowledge consistency, capability claims, migration lint (233 migrations), outbound delivery contract, repo map, topology contracts, subprocessor generator check, security posture, feature entitlements.
- **Not run:** the pricing-drift gate, which needs a Zola build.

Sales engine: making it scientific, fact-based and aggressive

The engine's architecture is strong: decision gates, a fail-closed legal check, evidence-grounded copy, calibration metrics, and a bandit in the send path. What limits it is how it learns.

- It cannot tell a good arm from a high-volume one.
- It cannot measure whether outreach causes revenue.
- It promotes changes on samples too small to separate signal from noise.

Ten changes fix this. Each is a work package (S1–S10 in the Work packages tab), ordered by impact.

Learn correctly

1. **S1 — Fix the bandit's posterior.**
   - In `experiments.rs:407–437`, a send with no response adds nothing to β.
   - Each step of one conversion adds to α again: reply 0.2, positive reply 0.5, meeting 0.7, attended 0.8, trial 0.9, paid 1.0. So one deal can add up to 4.1 to α (5.3 with retained MRR).
   - Result: an arm with 10 replies from 1,000 sends outscores one with 2 replies from 10, and Thompson sampling (`experiments.rs:477, 1674`) favours whichever arm got the most volume.
   - Fix: one binary primary outcome per contact, with α = 1 + successes and β = 1 + (matured contacts − successes).
2. **S2 — One primary metric, fixed windows.**
   - Primary metric: a positive reply or a meeting within 14 days of the first touch.
   - North star: won MRR per 1,000 contacted accounts at 90 days.

- A contact enters the posterior only once its window has closed, so slow outcomes don't bias towards fast ones.
- Complaints, unsubscribes and bounces become guardrails that pause an arm, not negative pseudo-counts.

3. **S3 — A randomized holdout.**
   - No module keeps a control group, so nothing can show that outreach causes pipeline rather than coinciding with it.
   - Hold out 5–10% of eligible accounts per segment, assigned by hashing the account ID with an experiment salt.
   - Randomize at account level, so colleagues are never split across arms.
   - Report incremental pipeline per segment, with confidence intervals.
4. **S4 — Off-policy evaluation.**
   - `simulation.rs` scores a challenger by "agreement with reality", which is biased towards whatever policy produced the data.
   - Log each decision's selection probability (a Monte Carlo estimate over the Thompson draw).
   - Evaluate new weights, arms and auto-send classes with inverse-propensity and doubly-robust estimators before they touch live traffic.
5. **S5 — Pre-registration and real sample sizes.**
   - Every experiment declares its hypothesis, primary metric, unit, minimum detectable effect and planned sample before it starts.
   - Detecting a reply-rate lift from 2% to 3%, at 80% power and 5% two-sided significance, needs about 3,800 contacts per arm. The Sales engine tab's "400 sends per arm" rule, which I wrote, would see about 8 replies per arm: noise.
   - Conclusions use always-valid sequential tests. Repeatedly checking fixed-horizon p-values makes them "wholly unreliable" (Johari et al.).

```
n_{\text{per arm}} \approx \frac{(z_{1-\alpha/2} + z_{1-\beta})^2 \,
\big(p_1(1-p_1) + p_2(1-p_2)\big)}{(p_2 - p_1)^2}
```

6. **S6 — Partial pooling instead of a cliff.** `MIN_CONTEXT_SAMPLES = 25` (`experiments.rs:120`) switches a context bucket from the global posterior to its own in a single step. A hierarchical model shrinks each bucket towards its segment and the global rate in proportion to its data. It learns faster in small segments and never jumps.

Score what matters

7. **S7 — Learned, calibrated scores, then uplift.**
   - The ten weights in `scoring.rs` are set by hand. Fit them on matured outcomes with a time-based split.

- Promote a model only if its Brier score and calibration beat the current one. `calibration.rs` already computes both.
- Once the S3 holdout has data, rank accounts by uplift: the extra chance of a deal because you contacted them. Today the score is the chance they'd buy anyway.

8. **S8 — Measure the truth of every inference.**
   - Check each "likely uses vendor X" against ground truth: the provider named in a `provider_import`, or a signup question. Publish precision per vendor.
   - Turn off the provider hooks for any vendor whose precision is below 90%.
   - Audit 50 randomly chosen sent emails a week for unsupported claims, with a target of zero.

Go faster and wider, inside the hard limits

9. **S9 — Speed and throughput as measured targets.**
   - Answer inbound leads and product signals within 5 minutes at the 95th percentile, and measure it. In HBR's study of 1.25 million leads, firms that responded within an hour were nearly 7× as likely to qualify the lead as those that waited an hour longer, and over 60× as likely as those that took 24 hours.
   - Reach a first touch within 1 hour of a provider incident, register change or quota event, inside send windows.
   - Plan capacity with accounts per pass = sender identities × daily cap × working days. At the Scale mix's roughly 21,000 accounts and a 150-a-day cap, 10 identities cover one pass in 14 working days. Add identities and domains only while complaint and bounce guardrails hold.
   - Test hook × call to action together in factorial designs, not one dimension at a time.
   - Re-enter no-reply and closed-lost accounts after 90 days when a new signal fires.
10. **S10 — Lawful sourcing: remove the CAPTCHA-solver hook.**
    - `discovery/blocked.rs:18-70` lets an operator send blocked pages to an external CAPTCHA-solving service.
    - France's data regulator, the CNIL, says a site that refuses scraping with robots.txt or a CAPTCHA must be excluded, and that legitimate interest may not hold without such safeguards. A hook built to get past CAPTCHAs also sits badly next to KiwiCaptcha, the CAPTCHA you sell.
    - Delete the hook, and treat a CAPTCHA as a permanent "no" for that host.
    - Prefer role addresses such as info@ or contact@, which CNIL places outside the B2B prospecting rules, over named people's addresses taken from mailto links.

Other findings

1. **Production may not be running any of this.**
   - Since the CI split, the deploy host refuses any commit without a gate blessing pushed from the CI machine.
   - Commit `f9221fc` records the host refusing `9d2eec9` for exactly that reason.
   - Check `.last-good-sha` on the host before assuming the 15–16 Oct work is live.
2. **The "zero-US" gate checks region, not control.**
   - `sovereign_chain_zero_us` passes because every processor runs in an EU region.
   - The active set still includes AWS (SES, S3), Google and GitHub, which are US companies.
   - Either rename the check to what it proves, or add corporate control to it and run it per routing mode.
3. **US sales tax ships with no rates.** That is correct fail-closed behaviour. But once a state is registered, its invoices are refused until you or the accountant fill in that state's row.
4. **Sales mail is held by default.** `SALES_TRANSPORT=none` holds every sales send until a sales relay or account is configured. This is as intended.
5. **Migrations now run to 261.** The plan's "start at 253" rule is outdated; the next migration is 262.

What this check could not verify

- **The live site and the production host.** The site is unreachable from this sandbox, so it is unknown which commit is deployed and which settings are live.
- **Owner actions:** the Hetzner port 25 request, sales domains, the Adyen live account, package-registry accounts, and US tax registrations.
- **The full test suite** (about 12.6k tests). Only the quick Python gates above were run. A targeted run of the routing-receipt tests failed to start because the sandbox cannot reach the crates.io index. So every "Done" rests on reading the code and confirming the named tests exist, not on running them.
- **Adyen's actual processing locations.** The generator states "Netherlands" for processing and storage; Adyen's DPA was not opened to confirm it.

Next steps

1. **H1–H3 before anything else.** Cancellation, the 19 wrong legal lines (generate the DPA, privacy and data-locations rows from the same register), and the Adyen production settings.

2. **Bring four claims in line with the product:** EU-only "own EU MTAs", the evidence pack, "Germany primary, Finland backup", and "archive and journaling". Also either remove the 99.9% SLA or do A3.
3. **Push a gate blessing,** and confirm on the host which commit is live.
4. **S1, S2 and S10 next.** S1 and S2 change what the engine learns from. S10 removes a legal exposure.
5. **Then S3–S5,** so every later sales change is judged on causal, adequately powered evidence.
6. **Remaining plan work:** B2 (EU-only relay hardening) before marketing EU-only further; then A3, A5, B6 and E5, which back things already being sold.

Audit — 15 October 2026

Oct 15, 2026 · @Aaron

The plan has not been implemented: none of the 41 work packages has started in the code at commit `9d8cef4` (14 Oct, 23:19). The 14 commits since the plan's baseline (`1987043`) are CI upkeep, a KiwiCaptcha mirror update, and an unplanned switch from Stripe to Adyen. That switch moves billing to an EU company, which helps the EU positioning. It also introduced two new launch blockers: customers cannot cancel, and the legal pages misstate where Adyen processes data. It carried over a third from the Stripe setup: the production config does not supply payment settings to the service that creates checkouts.

Verdicts

Question	13 Oct	15 Oct
Is it a good business model?	The category is good. ApexMail's version was an undifferentiated, pricier email API	Unchanged on paper. The model in the Plan tab is sound but has no customers to prove it. Moving billing to Adyen, a Dutch company, strengthens the EU pitch once the legal pages state it correctly
Is it close to launching?	Technically live, commercially not launched	Further from a paid launch than on 13 Oct. Cancellation is broken and the legal pages are wrong; as before, checkout cannot run with the production config in the repo. All the 13 Oct blockers remain
How much of the plan is done?	—	None of the 41 work packages. The crates the sales, routing and pricing work lives in have no changes since the baseline

If the plan's work exists somewhere unpushed (another machine, a local branch), push it to `main` and this check can be re-run against it. Everything below describes what is in the repository.

What changed since the plan

Fourteen commits landed on `main` between `1987043` (13 Oct, 18:28) and `9d8cef4` (14 Oct, 23:19). No other branch or pull request carries plan work. The only other open branches are Dependabot dependency bumps.

Date	Change	Commits	In the plan?
14 Oct	Stripe replaced by Adyen across billing: schema migration 252, a repo-wide rename of 2,800+ references, a new checkout client, rewritten webhooks	`ad6c748`, `7172ca5`, `033d04c`, `f6bc6c8`, `c86efb1`, `2cfd418`, `9d8cef4`	No. Owner directive of 14 Oct
14 Oct	The last two excluded tests fixed (SNS replay, billing sweep)	`6992ab4`	No
13 Oct	Dogfood coverage made adversarial; previously advisory CI gates made required again; obsolete CI files removed	`420642f`, `0c26c88`, `806c4d9`	No. CI still runs on the production host
13 Oct	KiwiCaptcha mirror updated to upstream `6fdffee0`: 304 of the 581 changed files	`3c022fb`	No
13 Oct	Load-test slack scale; PHP lane fix; security-advisory ledgers aligned	`47746b7`, `12600d0`	No

Crates with no changes at all since the baseline: `sales-autopilot`, `outbound-mta`, `platform-catalog` and `email-grader`. In `pdf-renderer`, one line changed.

Effect on the plan. Migration 252 is now taken by the Adyen schema, so the next migration is 253. Every work package that assumed Stripe (B4, C1, C2, E1, F10) has been rewritten for Adyen in the Work packages tab.

New launch blockers from the Adyen switch

Stripe provided a hosted billing portal, subscription objects and tax calculation. Adyen provides none of these, so ApexMail now has to do them itself. The rename carried the old assumptions over without replacing them. New work packages H1–H3 in the Work

packages tab cover these blockers. Blocker 3 predates the switch, but the switch is the moment to fix it.

1. Customers cannot cancel a paid plan.

- Both cancellation endpoints refuse and tell the caller to use "the Adyen billing portal": `crates/api-server/src/routes/billing.rs:3400-3418` and `crates/billing-service/src/routes.rs:1444-1465`.
- The code itself says that portal does not exist ("Adyen has no hosted billing portal", `billing.rs:3281`).
- The portal URL the API returns is `/web/billing/portal`. That route accepts only a form POST (`routes/web.rs:328`), and the form only records a request: "Nothing was changed." (`web.rs:5123-5141`).
- Renewals still charge stored payment tokens (maintenance autopay, `f6bc6c8`).
- The Terms (`content/terms/index.md:52`, all four languages) and the pricing FAQ still promise self-service cancellation through "the Adyen billing portal".
- Net effect: a customer can be charged again with no self-service way to stop it.

2. The legal pages say Adyen processes and stores data in the USA and India.

- 20 lines on four public pages, in all four languages, describe Adyen N.V. with Stripe's old facts: "USA (primary); India (support)", US storage, US corporate country, transfers under SCCs.
- The pages are subprocessors, privacy policy, DPA and data locations.
- The same text appears in `templates/compliance/subprocessors.md` and `templates/compliance/data-locations.md`.
- Adyen N.V. is a Dutch company. The correct locations must come from Adyen's own DPA and subprocessor list; this check did not open those.
- As written, the pages undercut the EU positioning and misdescribe a processor in a DPA.

3. The production config cannot run a checkout.

- The checkout client in api-server needs `ADYEN_API_KEY`, `ADYEN_MERCHANT_ACCOUNT` and a live `ADYEN_API_BASE_URL` (`routes/billing.rs:1006-1030`).
- `docker-compose.prod.yml` passes none of them to api-server; only billing-service gets the key and HMAC secret. `.env.production.example` documents neither the merchant account nor the base URL.
- The base URL defaults to Adyen's test endpoint, which production refuses, so checkout fails closed.
- The example keys still show Stripe prefixes (`sk_live_`, `whsec_`) at `.env.production.example:130-131`.

- The same wiring gap existed for Stripe before the switch, so paid checkout may never have worked in production. The live host's environment was not checked.

Owner preconditions for Adyen (from Adyen's own pages):

- A live account requires checks on the company, its shareholders and its business model, plus company registration, VAT, bank and ID documents.
- The website must show terms, privacy and refund policies, contact details, and a checkout checkbox accepting the terms.
- Fees are $0.13 per transaction plus the payment-method fee: cards at Interchange++ plus 0.60%; SEPA Direct Debit at €0.27.
- There are no setup or monthly fees, but there is "a minimum invoice depending on industry or business model". Ask Adyen for that amount before relying on it at low volume.

Also changed: US sales tax. Stripe Tax is gone. The local tax code computes EU VAT only (`crates/billing-common/src/vat_rates.rs`), and US addresses get zero tax. WP C2 now has to supply a US tax calculation itself.

Work package check

Each work package was tested against its own "Done when" criteria in the code at `9d8cef4`. Hits that predate the plan (for example the September `soc2.rs`, or accounting "journal" entries) were excluded.

WP	Finding	Evidence at `9d8cef4`
A1	Not started	Images still built on the production host (`ci/stages/images.sh:169`); no build host or registry anywhere in the repo
A2	Not started	No sales transport setting; the dispatcher still reads the global SES gate (`sales-autopilot/src/dispatcher.rs:811-815`)
A3	Not started	No replication or secondary MX config; the 99.9% SLA is still on 8 template and SLA files
A4	Not started	`hero.html:95, 100, 105` still hard-code 99.9%, 1.8 s and 5.2m
A5	Not started	No restore-drill script or results
A6	Not started	No new production probe records in `docs/audit/`

WP	Finding	Evidence at `9d8cef4`
B1	Not started	No routing-policy table, no EU-only route; the `AWS_REGION` default is still `us-east-1` (`api-server/src/config.rs:1064`)
B2	Not started	`outbound-mta` unchanged
B3	Not started	No receipt signing, no `/proof` route
B4	Not started; partly overtaken	Stripe is gone from billing, but the pages now misplace Adyen (blocker 2). Google, GitHub and AWS unchanged; no generated per-tenant list
B5	Not started	No customer-held keys for message content
B6	Not started	No register-of-information or evidence-pack code
C1	Not started	The catalog has no currency field
C2	Not started; scope changed	No US tax code. Stripe Tax is no longer an option
C3	Not started	No CCPA addendum; the DPA has no CCPA terms
C4	Not started	Only the pre-existing `compliance/src/soc2.rs` (Sept.)
D1	Not started	No SendGrid, Postmark, Resend or Mailgun compatible routes
D2	Not started	No importer or shadow send
D3	Not started	No TypeScript SDK; registry publication not re-checked (registries unreachable from this check)
D4	Not started	Only the generic migration page from 9 Oct
E1	Not started	Developer still `2_900` (`platform-catalog/src/lib.rs:78`); no Compliance or Platform plan
E2	Not started	No subaccount pause or abuse scoring
E3	Not started	No provisioning script in `deploy/scripts/`
E4	Not started	No seat billing
E5	Not started	No mail journaling
E6	Not started	No regulated-domain match

WP	Finding	Evidence at `9d8cef4`
F1–F12	Not started	`sales-autopilot` has zero changes since the baseline. No country policy rows, register source, new provider detection, grader hook, status signals, weight changes, seeded sequences or objection entries, per-pool thresholds, auto-approve policy, order-form template, scoreboard or promotion gates
G1	Not started	BYOC still appears in 32 marketing content files; no not-for-sale marker
G2	Not started	`isolation` and `pattern-matcher` still test-only and undocumented
G3	Not started	No missing-translation-key gate

Repo gates at `9d8cef4`:

- **Passed:** knowledge consistency, capability claims, migration lint (224 migrations), outbound delivery contract, repo map, topology contracts.
- **Not run:** the pricing-drift gate, which needs a Zola build first.
- **Gap:** no gate checks processor facts, which is how blocker 2 got through. WP H2 adds one.

What this check could not verify

- **The live site and the production host.** Fetching apexmail.ee needed a permission that was not granted, and the sandbox network blocks it. So it is unknown whether `9d8cef4` is deployed, or what the live environment variables are.
- **Owner actions outside the repo:** a Hetzner port 25 request, sales domains, an Adyen live account, package-registry accounts.
- **The full test suite** (about 12.6k tests). Only the quick Python gates above were run.
- **Adyen's real data locations.** Its DPA and subprocessor list were not opened, so this report says only that the current rows are Stripe's, not what the correct rows are.

Next steps

1. **H1: restore self-service cancellation** before any paid customer exists. ApexMail now owns the subscription, so cancellation is a local state change that stops the next renewal charge.

2. **H2: correct Adyen's facts** on the four legal pages in four languages and in `templates/compliance/`, from Adyen's own DPA. Add a gate so a processor's location cannot drift again.
3. **H3: wire Adyen into production** and get the live account. Ask Adyen for the minimum invoice amount first.
4. **Resume the plan** where the index says: A1 and A2 first (CI off the production host; sales sending isolated), F1 and F2 in parallel because their owner steps take longest.
5. **Re-run this check** after each batch of work packages. Each Done WP needs its Evidence line, or it will be reported as not started.